Arjun Technologies Pvt. Ltd.

Bengaluru, Karnataka — 560 001

CIN: U72200KA2008PTC044521 | www.arjuntech.in

DATA PRIVACY POLICY AND PROCEDURES FRAMEWORK

Segment 1 of 3 — Purpose and Scope · Statutory Framework · Data Fiduciary Obligations · Consent · Data Classification · Lawful Bases · Data Subject Rights · Revision History

Version	2.1	**Effective Date**	01 April 2024
Review Date	31 March 2025	**Classification**	Internal Use Only
Approved By	Mr. Rajesh Arjun	**Document Owner**	Mr. Sandeep Iyer
Legal Author	Mr. Sandeep Iyer	**Department**	Legal & Compliance
Doc Reference	LEGAL-POL-004-v2.1	**Applies To**	All Employees, Contractors, and Third-Party Data Processors
Segment	1 of 3 (Pages 1–50)	**Total Segments**	3

This is Segment 1 of the Arjun Technologies Pvt. Ltd. Data Privacy Policy and Procedures Framework, Version 2.1, effective 01 April 2024. This version has been comprehensively updated to incorporate the Digital Personal Data Protection Act 2023 (DPDP Act), which received presidential assent on 11 August 2023 and represents the most significant development in Indian data protection law since the Information Technology Act 2000. Segment 1 establishes the foundational framework: the General Counsel's message, purpose and scope, the complete statutory framework including the DPDP Act and all relevant antecedent and concurrent legislation, the company's obligations as a Data Fiduciary, the consent framework and all lawful bases for processing, the data classification scheme, data subject rights and the company's response obligations, and the governance structure for data privacy across the organisation. Segment 2 covers operational data handling standards by context, data breach management, third-party and processor management, and employee monitoring. Segment 3 covers cross-border data transfers, sector-specific obligations, the privacy by design framework, enforcement and consequences, and all appendices. For queries contact legal@arjuntech.in or the Data Protection Officer.

Revision History

The table below records the complete version history of the Arjun Technologies Data Privacy Policy since first publication. Each revision has been approved by the CEO and reviewed by the General Counsel and the Board Audit Committee. Material changes are communicated to all employees before the effective date. The current version is on the HRMS portal under Policies and Documents. This policy is the definitive data privacy statement for the organisation. Where a specific processing activity requires a more detailed privacy notice — such as the employee privacy notice, the client privacy notice, or the website privacy notice — those notices operate alongside and consistently with this policy.

Version	Date	Summary of Material Changes	Approved By
1.0	Apr 2015	Initial publication. Basic personal data handling requirements under the IT Act 2000 and IT Rules 2011. Sensitive personal data provisions. Data security requirements for client engagements.	CEO
1.1	Sep 2016	Third-party data processor provisions added. Client data handling agreement requirements formalised. Employee personal data provisions expanded.	CEO
1.2	Mar 2018	Data ethics provisions added ahead of anticipated data protection legislation. Consent management provisions introduced. Data subject access request process established.	CEO
1.3	Nov 2019	Privacy by design framework introduced. Data Protection Impact Assessment (DPIA) process established. Cross-border data transfer provisions added.	CEO
1.4	Jun 2021	Data retention schedules formalised. Data breach notification procedures updated. Data localisation considerations for financial sector clients added.	CEO
2.0	Jan 2023	Major revision anticipating the DPDP Act. Data Fiduciary/Data Principal framework adopted in advance of the Act. Consent framework substantially expanded. Data Principal rights provisions added.	CEO
2.1	Apr 2024	DPDP Act 2023 fully integrated throughout. Data Protection Board of India notification procedures. Consent Manager provisions. Significant harm definition incorporated. Cross-border transfer rules updated per draft Rules. DPO role formally constituted. Penalty provisions added.	CEO

Table of Contents — Segment 1

SEGMENT 1 — This Document (Pages 1–50)

Section 1 — Message from the General Counsel

Section 2 — Purpose, Scope, and Application of This Policy

2.1 Purpose — The Company's Data Privacy Commitment
2.2 Scope — Who and What This Policy Covers
2.3 Relationship to Other Policies, Notices, and Agreements
2.4 Personal Responsibility of Every Employee

Section 3 — Statutory and Regulatory Framework

3.1 The Digital Personal Data Protection Act 2023 — Overview and Status
3.2 Key Concepts and Defined Terms Under the DPDP Act
3.3 The Information Technology Act 2000 and IT Rules 2011 — Continued Applicability
3.4 Sector-Specific Data Regulations Applicable to the Company
3.5 International Data Protection Frameworks — Client Engagement Context

Section 4 — The Company as Data Fiduciary — Obligations and Accountability

4.1 Data Fiduciary Status and the Accountability Principle
4.2 Significant Data Fiduciary — Assessment and Obligations
4.3 The Data Protection Officer — Role, Authority, and Independence
4.4 Privacy Governance Structure — Roles and Accountabilities
4.5 Data Protection Register — Maintaining Records of Processing Activities

Section 5 — Lawful Bases for Processing Personal Data

5.1 The Consent Basis — Requirements for Valid Consent
5.2 Legitimate Uses — Processing Without Consent
5.3 Deemed Consent — Scope and Limitations
5.4 The Consent Manager Framework
5.5 Processing of Children's Data

Section 6 — Data Classification Framework

6.1 Classification Categories — Personal, Sensitive, and Non-Personal
6.2 The Information Classification Scheme — Company Labels and Handling
6.3 Special Category Personal Data — Enhanced Protection Requirements
6.4 Non-Personal Data — Distinction and Governance

Section 7 — Data Subject Rights Under the DPDP Act

7.1 Overview of Data Principal Rights
7.2 Right of Access — Information and Summary of Processing
7.3 Right of Correction, Completion, and Updating
7.4 Right of Erasure
7.5 Right of Grievance Redressal
7.6 Right to Nominate
7.7 Response Timelines and Process Standards
7.8 Data Principal Rights — Internal Handling Procedures

SEGMENT 2 (Pages 51–100)

8–13 Operational Standards · Data Handling by Context · Breach Management · Processor Management · Employee Monitoring · Retention and Deletion

1. Message from the General Counsel

The publication of this Version 2.1 of the Data Privacy Policy marks an important milestone in the company's data governance journey. The Digital Personal Data Protection Act 2023, which received presidential assent on 11 August 2023, fundamentally transforms the legal landscape for personal data processing in India. For the first time, Indian law provides a comprehensive, rights-based framework for personal data protection that places enforceable obligations on organisations that process personal data and enforceable rights in the hands of the individuals whose data is processed. The penalties for violation — up to ■250 crore for a single category of breach — are substantial. The reputational consequences of a material data privacy failure are potentially more damaging still.

Every one of us at Arjun Technologies touches personal data in the course of our professional work. The software we build processes the personal data of our clients' customers. The client management systems we use contain the personal and commercial data of the individuals and organisations we serve. The HR systems we operate hold the sensitive personal data of every colleague. The analytics platforms we deploy ingest personal data to produce insights that inform consequential decisions. Personal data is not an abstraction in our business — it is the raw material of a significant portion of the work we do, and the individuals whose data we process have entrusted it to us with the reasonable expectation that we will handle it lawfully, fairly, transparently, and securely.

This policy does not ask you to be a data protection lawyer. It asks you to understand the principles that govern how personal data should be handled, to apply those principles in the decisions you make every day, to ask for guidance from the Legal team when a processing situation raises a question you cannot answer with confidence, and to report actual or suspected data breaches immediately rather than hoping the situation will resolve itself. The cost of reporting a potential breach that turns out to be nothing is zero. The cost of not reporting a genuine breach while the window for notification closes is measured in regulatory penalties and destroyed client trust. Please read this policy carefully, engage with the mandatory training, and treat the personal data of the people you serve with the care and respect it deserves. — Mr. Sandeep Iyer, General Counsel, Arjun Technologies Pvt. Ltd.

2. Purpose, Scope, and Application of This Policy

2.1 Purpose — The Company's Data Privacy Commitment

The Data Privacy Policy of Arjun Technologies Pvt. Ltd. is the company's definitive statement of how it collects, uses, stores, shares, protects, and deletes personal data across every dimension of its operations. Its purpose is threefold. First, it establishes the legal compliance framework — ensuring that the company meets all obligations imposed by the Digital Personal Data Protection Act 2023, the Information Technology Act 2000 and its associated Rules, and all sector-specific data regulations applicable to the company's client engagements and operational activities. Compliance with these obligations is a non-negotiable baseline: the DPDP Act creates specific, enforceable duties for Data Fiduciaries, and the company has both a legal obligation and a reputational interest in meeting them.

Second, it establishes the operational standards that every employee, contractor, and third-party data processor must apply in their handling of personal data. The law sets the minimum; this policy sets the standard the company has chosen to hold itself to — and in several respects, that standard goes beyond the legal minimum, reflecting the company's understanding that data privacy is a genuine value, not merely a compliance obligation. A technology services company that handles the personal data of millions of end-users through the systems it builds and operates has a professional and ethical responsibility that extends beyond the letter of the law.

Third, it provides the evidence of the company's genuine, documented, and enforced commitment to data privacy that clients, regulators, audit partners, and prospective employees have the right to examine. The company's ability to win and retain enterprise client relationships in regulated sectors — financial services, healthcare, public sector — depends significantly on the quality and credibility of its data governance framework. This policy, alongside the company's information security programme, its data processing agreements, and its breach management track record, forms the core of that framework.

2.2 Scope — Who and What This Policy Covers

This policy applies to all personal data processed by Arjun Technologies Pvt. Ltd. in any capacity — as a Data Fiduciary processing data for its own purposes, and as a Data Processor processing personal data on behalf of its clients under the terms of data processing agreements. It applies to all natural persons who are covered by the DPDP Act as Data Principals whose data the company processes: the company's own employees and contractors; the employees, customers, and users of its clients whose data is processed in the course of client engagements; visitors to the company's websites and digital platforms; candidates in the company's recruitment process; and any other natural person whose personal data the company collects or processes.

Data Category	Data Principal Category	Company Role	Applicable Processing Context
Employee personal data (name, address, salary, bank details, health, performance)	Arjun Technologies employees and contractors	Data Fiduciary	Employment administration, payroll, HRMS, performance management, leave management, benefits.
Candidate personal data (CV, interview notes, background check data)	Job applicants and candidates	Data Fiduciary	Recruitment and selection process. Retention for future opportunities with consent.
Client contact data (name, email, phone, designation)	Client employees and representatives	Data Fiduciary (for CRM and relationship management)	Client relationship management, project communication, contract management.

Data Category	Data Principal Category	Company Role	Applicable Processing Context
End-user personal data processed within client systems	Customers, users, or members of the client organisations	Data Processor (processing on the client's instructions under a DPA)	Client delivery engagements where the company builds, operates, or maintains systems that process end-user personal data.
Website visitor data (IP address, cookies, analytics)	Website visitors and online users	Data Fiduciary	Website analytics, cookie consent management, online contact form processing.
Supplier and vendor contact data	Supplier and vendor representatives	Data Fiduciary	Procurement, vendor management, contract administration.
Training and event attendee data	External participants in company-hosted events or training	Data Fiduciary	Event management, training delivery, CPD record.

2.3 Relationship to Other Policies, Notices, and Agreements

This policy operates as the overarching internal data privacy framework. It does not replace or supersede the specific privacy notices and data processing agreements that govern individual processing relationships — it provides the internal governance framework within which those external documents are created, maintained, and complied with. The hierarchy is: this policy establishes the standards; the specific privacy notices and DPAs give effect to those standards in the specific processing relationships they govern; and the individual employee and manager decisions in daily data handling give operational effect to both.

Related Document	Reference	Relationship to This Policy
Employee Privacy Notice	HR-PN-001-v2.1	The notice provided to employees describing how their personal data is processed during employment. Operationalises the consent, transparency, and rights provisions of this policy for the employment context.
Client Privacy Notice (Website)	LEGAL-PN-002-v2.0	The public-facing privacy notice for the company website. Operationalises this policy for the online context.
Recruitment Privacy Notice	HR-PN-003-v1.2	The notice provided to job candidates. Operationalises consent and rights provisions for the recruitment context.
Data Processing Agreement (Standard)	LEGAL-DPA-001-v3.1	The company's standard DPA for client engagements where the company processes personal data as a processor. Gives contractual effect to the processor obligations in this policy.
IT Security Policy	IT-SEC-POL-001-v5.2	The companion document governing technical and organisational security measures. Data security obligations in this policy are operationalised through the IT Security Policy.
Code of Conduct	HR-COC-001-v2.4	Section 10.3 of the Code of Conduct establishes the AI and data ethics obligations that complement this policy. Both documents must be read together for AI-related data processing.
Data Privacy Policy (Employee Handbook reference)	HR-POL-001	The Employee Handbook summarises the key employee data privacy obligations. This policy provides the detailed framework.
International Data Transfer Standard Contractual Clauses	LEGAL-DPA-SCC-001	Standard contractual clauses used for cross-border transfers to non-approved countries under the DPDP Act. Governed by this policy, Section covered in Segment 3.

2.4 Personal Responsibility of Every Employee

Every person covered by this policy — permanent employees, contractors, interns, and any individual who handles personal data in the course of their work for or on behalf of Arjun Technologies — has a personal, non-delegable responsibility to understand and apply its provisions in their daily work. The DPDP Act creates obligations for the company as an organisation, and the company satisfies those obligations through the individual actions of every person who touches personal data. A data breach caused by a single employee's careless handling of personal data — sending a spreadsheet containing client customer data to an external email account, leaving a laptop containing personal data unattended in a public space, or sharing a password with a colleague — is a breach for which the company may be penalised up to ■250 crore and which may destroy years of client trust. Personal responsibility for data privacy is not an administrative compliance obligation — it is a fundamental professional duty.

3. Statutory and Regulatory Framework

3.1 The Digital Personal Data Protection Act 2023 — Overview and Status

The Digital Personal Data Protection Act 2023 (Act No. 22 of 2023) is the primary legislation governing the processing of digital personal data in India. It applies to the processing of digital personal data within India where the personal data is collected in digital form or collected in non-digital form and subsequently digitised. It also applies to the processing of digital personal data outside India where the processing is in connection with any activity related to offering of goods or services to Data Principals within India.

The Act received presidential assent on 11 August 2023. As at the effective date of this policy (01 April 2024), the Central Government has not yet notified the commencement date of the Act, and the Digital Personal Data Protection Rules under the Act are in draft form following public consultation. However, the company's position — consistent with best practice and with the Legal team's advice — is that the Act should be treated as operationally effective for compliance planning purposes from this date, so that the company is fully compliant from the moment commencement is notified. Building compliance retroactively after notification carries both legal risk (the notification may leave limited lead time) and reputational risk (clients in regulated sectors who have already begun DPDP compliance programmes will expect their technology partners to be similarly advanced).

DPDP Act Element	Key Provision	Company Impact	This Policy Section
Data Fiduciary definition	Any person who alone or in conjunction with other persons determines the purpose and means of processing of personal data is a Data Fiduciary. Companies that collect and process personal data for their own purposes are Data Fiduciaries.	Arjun Technologies is a Data Fiduciary for all personal data it processes for its own purposes (employment, client management, marketing, etc.). Subject to all Data Fiduciary obligations in the Act.	Section 4
Data Processor definition	Any person who processes personal data on behalf of a Data Fiduciary. A contractor or service provider who processes data under instructions from a Data Fiduciary.	Arjun Technologies is a Data Processor when it processes personal data on behalf of its clients under a Data Processing Agreement. Different obligations apply in processor capacity.	Section 4 and Segment 2
Data Principal rights	Rights of access (information summary), correction, erasure, grievance redressal, and nomination. Must be exercised directly with the Data Fiduciary.	Company must maintain mechanisms for Data Principals to exercise rights and must respond within prescribed timelines.	Section 7
Consent requirements	Processing personal data requires consent from the Data Principal, unless a legitimate use basis applies. Consent must be free, specific, informed, unconditional, and unambiguous (a clear affirmative action).	All consent collection must meet these standards. Pre-ticked boxes, bundled consent, and vague consent language are not valid.	Section 5
Data breach notification	Data Fiduciaries must notify the Data Protection Board of India and affected Data Principals of personal data breaches. The notification timeline is specified in the Rules (expected: 72 hours for Board; prompt for Data Principals).	Company must maintain an operational breach detection, assessment, and notification process.	Segment 2

DPDP Act Element	Key Provision	Company Impact	This Policy Section
Penalty provisions	Financial penalties up to ■50 crore for specific breaches (e.g. failure to notify breach); up to ■200 crore for failure to implement security safeguards; up to ■250 crore for failure to protect children's data.	Significant financial exposure for non-compliance. Penalties are per breach, not per year.	Segment 3
Cross-border data transfer	Transfer of personal data outside India is permitted to countries approved by the Central Government by notification. The approved country list is pending publication.	Company cannot transfer personal data to non-approved countries until the approved list is published. Current cross-border transfers are reviewed on a risk basis with Legal.	Segment 3
Data Protection Board of India	An independent adjudicatory body with powers to investigate complaints, conduct inquiries, and impose penalties. Distinct from courts.	Company is subject to DPBI jurisdiction for complaints and investigations.	All segments

3.2 Key Concepts and Defined Terms Under the DPDP Act

The DPDP Act introduces specific defined terms that have precise legal meanings distinct from their ordinary usage. Every employee who handles personal data should be familiar with these terms, as the obligations and rights they trigger depend on their precise application.

Defined Term	DPDP Act Definition	Plain Language Explanation	Examples in Company Context
Personal Data	Any data about an individual who is identifiable by or in relation to such data.	Any information that identifies or can identify a real person, directly or indirectly. Broad definition — includes name, email, phone, IP address, employee ID, biometric data.	Employee names and salary details. Client contact email addresses. End-user account numbers in client systems. Website visitor IP addresses.
Digital Personal Data	Personal data in digital form, or personal data collected in non-digital form but subsequently digitised.	Personal data that is stored, transmitted, or processed electronically — which includes virtually all data the company handles given its technology operations.	HRMS employee records. CRM client contact records. Excel spreadsheets with employee data. Scanned and digitised identity documents.
Data Fiduciary	A person who alone or jointly with others determines the purpose and means of processing personal data.	The organisation or person who decides WHY personal data is collected and HOW it will be used. Responsible for compliance.	Arjun Technologies is a Data Fiduciary when it collects employee HR data, client contact data, or processes data for its own purposes.
Data Principal	The individual to whom the personal data relates.	The natural person (the human being) whose data is being processed. The data subject — the person the data is about.	Each individual employee (for HR data). Each client contact (for CRM data). Each end-user of a client system (when we operate the system).
Data Processor	Any person who processes personal data on behalf of a Data Fiduciary.	An organisation that processes data under the instructions of a Data Fiduciary. Does not decide why or how — operates on instructions.	Arjun Technologies is a Data Processor when a client instructs it to build, operate, or maintain a system that processes the client's end-user data.

Defined Term	DPDP Act Definition	Plain Language Explanation	Examples in Company Context
Processing	Any operation or set of operations performed on digital personal data, including collection, recording, storage, alteration, retrieval, use, alignment, combination, indexing, sharing, disclosure, or erasure.	Virtually any action taken in relation to personal data — from collecting it to deleting it. Viewing, storing, sharing, analysing — all are processing.	Running a report in HRMS (retrieval). Sending a client contact's details to a colleague (sharing). Correcting an employee address record (alteration).
Consent	A free, specific, informed, unconditional, and unambiguous indication of the Data Principal's wishes, by a clear affirmative action.	Valid consent must tick all five boxes: freely given (no coercion), specific (for a defined purpose), informed (person understands), unconditional (no bundling), and unambiguous (a positive action not silence or pre-ticking).	Checking a clearly labelled box on a recruitment form to consent to reference checking. Not valid: a pre-ticked box. Not valid: a bundled consent in employment contract terms.
Significant Harm	A category of harm defined in the Act including financial loss, reputational damage, loss of employment, bodily harm, mental injury, and other specified harms arising from a personal data breach.	The types of serious harm to a Data Principal that can result from a data breach — the standard against which breach seriousness is assessed.	A breach exposing employee salary data may cause financial harm. A breach exposing health data may cause reputational or employment harm.
Consent Manager	A person registered with the Data Protection Board who enables Data Principals to give, manage, review, and withdraw consent through a single platform.	A third-party intermediary that manages consent on behalf of Data Principals — a new concept in Indian law enabling individuals to manage their privacy permissions centrally.	The company must ensure its consent mechanisms can interface with Consent Managers once the registration framework is operational.

3.3 The Information Technology Act 2000 and IT Rules 2011 — Continued Applicability

The Information Technology Act 2000 (as amended by the IT Amendment Act 2008) and the Information Technology (Reasonable Security Practices and Procedures and Sensitive Personal Data or Information) Rules 2011 continue to apply alongside the DPDP Act. The DPDP Act does not repeal the IT Act or the 2011 Rules in their entirety — specific provisions of the IT Act relating to cybercrime, electronic records, and digital signatures remain in force. The 2011 SPDI Rules, which established the first framework for sensitive personal data in India, continue to govern specific categories of processing until the DPDP Act commencement notification specifies otherwise.

Provision	Source Legislation	Current Status (April 2024)	Company Obligation
Sensitive Personal Data or Information (SPDI) — definition and protection requirements	IT (SPDI) Rules 2011	Active. Continues to apply pending DPDP Act commencement.	SPDI (including passwords, financial information, physical/mental health, sexual orientation, biometric data, and medical records) must be handled with the enhanced protections in the 2011 Rules.
Reasonable security practices for SPDI	IT (SPDI) Rules 2011, Rule 8	Active. IS/ISO/IEC 27001 or equivalent standard required.	Company must maintain ISO 27001 or DSCI DPSA certification. Current status: ISO 27001 certified. Certification details in IT Security Policy.
Body corporate liability for SPDI breach	IT Act Section 43A	Active.	Company is liable in negligence for failure to protect SPDI. Civil liability to affected persons. Complements DPDP Act penalties.

Provision	Source Legislation	Current Status (April 2024)	Company Obligation
Electronic records and digital signatures	IT Act Sections 4–10	Active — not affected by DPDP Act.	All company digital records, electronic contracts, and digital communications are governed by IT Act provisions. Not a data privacy provision but operationally relevant.
Cybercrime provisions (hacking, data theft, identity fraud)	IT Act Sections 43, 66, 66C, 66D	Active — not affected by DPDP Act.	Company and its employees may be subject to criminal liability for unauthorised access to data systems, data theft, and identity fraud. Reference to IT Security Policy and Code of Conduct.
Data localisation requirements for financial sector	RBI/SEBI/IRDAI guidelines (sector-specific)	Active — independent of DPDP Act.	For client engagements in financial services, insurance, or securities: specific data localisation requirements may apply. Legal team confirms per engagement.

3.4 Sector-Specific Data Regulations Applicable to the Company

The company's work across multiple industry verticals means that sector-specific data regulations apply to specific client engagements in addition to the general framework of the DPDP Act and IT Act. These sector-specific requirements are the responsibility of the engagement team in co-ordination with the Legal team — they cannot be satisfied through the general data privacy framework alone. The following table identifies the key sector-specific frameworks that are most frequently relevant to the company's client portfolio.

Sector	Regulator	Key Data Regulation	Primary Obligation for Company Engagements
Banking and Financial Services	Reserve Bank of India (RBI)	RBI guidelines on storage of payment system data (2018). Master Direction on Digital Payment Security Controls (2021). Account Aggregator framework.	Payment system data must be stored only in India. Company systems built for banking clients must comply with RBI storage and security requirements. Account Aggregator integrations require specific consent architecture.
Insurance	Insurance Regulatory and Development Authority (IRDAI)	IRDAI guidelines on insurance repositories and protection of policyholders.	Policyholder personal data handled in insurance technology engagements must meet IRDAI data protection standards.
Securities and Capital Markets	Securities and Exchange Board of India (SEBI)	SEBI circular on cybersecurity and cyber resilience framework for market infrastructure institutions and intermediaries.	Systems built for SEBI-regulated entities must meet the specific cybersecurity and data protection requirements of the SEBI framework.
Healthcare	Ministry of Health and Family Welfare	Digital Information Security in Health Act (DISHA — pending enactment). National Digital Health Mission data standards.	Health data is the most sensitive category under both DPDP Act and anticipated DISHA provisions. Health sector engagements require specific DPIAs and enhanced security measures.
Telecommunications	Telecom Regulatory Authority of India (TRAI)	TRAI regulations on privacy, security, and unsolicited commercial communications.	Systems built for telecom clients must comply with TRAI data protection provisions including consent for marketing communications.
Government and Public Sector	Ministry of Electronics and IT (MeitY)	Government data classification policy. Cloud computing security guidelines for government.	Government sector engagements have specific data sovereignty and security requirements that may include data localisation, security clearances, and audit rights.

Sector	Regulator	Key Data Regulation	Primary Obligation for Company Engagements
UK-linked client engagements	ICO (UK Information Commissioner)	UK GDPR / UK Data Protection Act 2018	Where the company provides services to UK clients or processes data of UK data subjects, UK GDPR may apply alongside Indian law. Legal team confirms per engagement.

3.5 International Data Protection Frameworks — Client Engagement Context

Several of the company's client engagements involve clients who are subject to international data protection frameworks — most commonly the European Union's General Data Protection Regulation (GDPR) and its national implementing legislation, and the UK General Data Protection Regulation (UK GDPR). Where the company acts as a data processor for such clients, it must comply with the processor obligations imposed by those frameworks in addition to the requirements of Indian law. The company's standard Data Processing Agreement is designed to satisfy both GDPR processor requirements and the DPDP Act processor obligations simultaneously, avoiding the need for separate contract sets for each framework.

The most practically significant international framework overlap arises where a client subject to GDPR sends personal data of European data subjects to Arjun Technologies in India for processing. This constitutes a transfer of personal data to a third country under GDPR, which requires a lawful transfer mechanism. The company maintains Standard Contractual Clauses (EU SCCs) for this purpose, which are entered into with EU/UK clients for engagements involving the processing of EU/UK personal data. The Legal team manages the SCC process and maintains a register of engagements that involve EU or UK personal data.

4. The Company as Data Fiduciary — Obligations and Accountability

4.1 Data Fiduciary Status and the Accountability Principle

Arjun Technologies Pvt. Ltd. is a Data Fiduciary under the DPDP Act 2023 in respect of all personal data that it processes for its own purposes — including the personal data of its employees, clients, candidates, website visitors, and supplier contacts. As a Data Fiduciary, the company bears primary legal responsibility for ensuring that all processing of personal data in the company's control is lawful, fair, and transparent; that personal data is processed only for the purposes for which it was collected; that personal data is accurate, complete, and current; that personal data is retained only for as long as necessary; and that appropriate technical and organisational security measures are in place to protect personal data.

The accountability principle — which runs through both the DPDP Act and the international frameworks with which the company must align for client engagements — requires that the company be able to demonstrate its compliance, not merely assert it. Accountability means maintaining records of all processing activities (the Data Protection Register), conducting Data Protection Impact Assessments for high-risk processing, implementing privacy by design in all new systems and processes, appointing a Data Protection Officer with defined authority and independence, and responding effectively and promptly to regulator inquiries and Data Principal rights requests.

Data Fiduciary Obligation	DPDP Act Basis	Company Standard	Accountability Evidence
Purpose limitation — process only for the stated purpose	Section 6(1) — consent must be specific to the purpose	Company Standard: processing must be authorised by a specific purpose documented in the Data Protection Register and communicated to the Data Principal in the applicable privacy notice.	Data Protection Register entries. Privacy notices. Processing logs for high-risk activities.
Data minimisation — collect only what is necessary	Section 6(1) — consent is for specific data	Company Standard: before any new data collection, a documented assessment confirms that each data element collected is necessary for the stated purpose. The Privacy by Design checklist (Segment 3) must be completed for new systems.	PbD checklists. DPIA records. Data Protection Register purpose and data element mapping.
Data quality — ensure accuracy and currency	Section 4(2)(ii) — completeness, accuracy, consistency, and up-to-dateness where necessary	Company Standard: data quality mechanisms in place for all personal data categories. Employee and client data: subject to regular accuracy checks and self-service correction facilities.	HRMS data quality reports. Client contact database hygiene procedures. Employee self-service profile update audit.
Storage limitation — retain only as long as necessary	Section 8(7) — erase upon withdrawal of consent or fulfilment of purpose	Company Standard: data retention schedules documented for each data category in the Data Retention Schedule (Segment 2 Appendix). Automated deletion where technically feasible; scheduled manual deletion otherwise.	Data Retention Schedule. Deletion logs. Annual deletion audit.
Security measures — protect against breach	Section 8(5) — reasonable security safeguards	Company Standard: ISO 27001-aligned security controls per the IT Security Policy. Technical measures: encryption at rest and in transit, access controls, multi-factor authentication, vulnerability management. Organisational measures: this policy, security training, incident response.	ISO 27001 certification. Security audit reports. Training completion records.
Grievance redressal — provide accessible mechanism	Section 13 — Data Principal must be able to contact DPO and make complaints	Company Standard: Data Protection Officer contact details published in all privacy notices and on company website. Grievance registration through the DPO portal. Response within 30 days.	DPO portal. Grievance log. Response time records.

4.2 Significant Data Fiduciary — Assessment and Obligations

The DPDP Act introduces the concept of a Significant Data Fiduciary — a Data Fiduciary designated as such by the Central Government based on criteria including the volume and sensitivity of personal data processed, the potential risk to the rights of Data Principals, the potential impact on national security or public order, and the risk to electoral democracy. Significant Data Fiduciaries are subject to enhanced obligations including the mandatory appointment of a Data Protection Officer, the mandatory appointment of an independent data auditor, periodic Data Protection Impact Assessments, and additional compliance reporting.

Arjun Technologies has conducted a self-assessment against the published and anticipated criteria for Significant Data Fiduciary designation. Based on the company's current scale of personal data processing, the nature of the data processed, and the sectors served, the Legal team's current assessment is that the company may be designated as a Significant Data Fiduciary following the publication of the designation criteria in the Rules. The company is therefore implementing the enhanced obligations proactively — appointing a DPO, engaging an independent data auditor, and establishing the DPIA programme — so that it is fully compliant from the moment any designation takes effect.

4.3 The Data Protection Officer — Role, Authority, and Independence

The company has formally constituted the role of Data Protection Officer with effect from 01 April 2024. The DPO is a senior member of the Legal team designated by the General Counsel and approved by the CEO, with specific authority and independence in the discharge of data privacy oversight responsibilities. The DPO is the company's primary point of contact with the Data Protection Board of India and with Data Principals exercising their rights.

DPO Responsibility	Description	Authority Level
Policy oversight	Ensuring this policy and all subsidiary data privacy documents remain current, accurate, and effectively implemented. Annual review and update.	Independent authority to require policy changes and operational procedure updates where the current state creates compliance risk.
Training and awareness	Designing and overseeing the mandatory data privacy training programme. Ensuring all employees with data handling responsibilities receive appropriate training.	Authority to make data privacy training mandatory and to restrict system access for employees with outstanding training obligations.
DPIA oversight	Reviewing and approving Data Protection Impact Assessments for new and changed processing activities. Identifying processing activities that require a DPIA.	Authority to halt or modify a processing activity that has not completed a required DPIA.
Breach management	Receiving and assessing data breach notifications. Determining notification obligations to the DPBI and affected Data Principals. Maintaining the breach register.	Authority to make breach notification decisions on behalf of the company. Escalates to General Counsel and CEO for material breaches.
Rights request handling	Overseeing the Data Principal rights request process. Reviewing rights request decisions. Escalation point for complex or disputed requests.	Authority to override a business-side decision to decline a rights request where the decline would not be legally defensible.
Regulator liaison	Primary contact for the Data Protection Board of India, the Ministry of Electronics and IT, and sector regulators on data privacy matters.	Authority to respond to regulatory inquiries within the company's stated positions and to escalate to General Counsel where the matter requires legal advice.
Third-party oversight	Reviewing data processing agreements and vendor data privacy assessments. Approval of new data processors for sensitive processing categories.	Authority to veto engagement of a data processor whose data privacy standards are assessed as inadequate.

The DPO can be contacted at dpo@arjuntech.in. Data Principal rights requests, privacy complaints, and data breach reports should all be directed to this address in the first instance. The DPO's identity and contact details are published in all privacy notices and on the company website. The DPO reports functionally to the General Counsel and has direct access to the CEO and the Board Audit Committee for matters that require escalation beyond the General Counsel.

4.4 Privacy Governance Structure — Roles and Accountabilities

Data privacy cannot be governed effectively through a single role or a single team. The company's privacy governance structure distributes accountability for data privacy across the organisation — from the Board through senior management to individual employees — while maintaining the centralised oversight and expertise that effective data privacy compliance requires. Every person in this governance structure has specific, documented obligations that are assessed in their performance review.

Role	Primary Data Privacy Accountability	Reporting Line	Assessment
Board Audit Committee	Ultimate oversight of the company's data privacy governance. Review of the DPO's annual data privacy report. Approval of the data privacy risk appetite.	CEO and General Counsel report to the Board on data privacy matters.	Annual Board review of the data privacy programme report.
CEO	Final approval authority for the Data Privacy Policy. Ultimate accountability for the company's compliance with the DPDP Act as the Data Fiduciary.	Audit Committee	Annual personal certification of data privacy governance adequacy.
General Counsel / DPO	Policy ownership. Legal advice on all data privacy matters. Breach notification decisions. DPBI liaison. Third-party oversight.	CEO directly. Audit Committee for significant matters.	Annual programme review. Breach metrics. Rights request outcomes.
VP Human Resources	Employee data governance. HRMS data privacy controls. Leave and attendance data handling per DPDP Act obligations. Employee privacy notices.	CEO	Annual HR data privacy assessment. HRMS access control audit.
Head of IT / CISO	Technical and organisational security measures. IT Security Policy alignment with data privacy obligations. Data encryption, access management, and breach detection.	CTO / CEO	ISO 27001 audit. Security incident metrics. Access control review.
Business Unit Heads (SVPs)	BU-level compliance with this policy in all client-facing and internal data processing activities within their unit. Escalation of data privacy concerns to the Legal team.	CEO	BU data privacy audit assessment (annual). DPIA completion rate.
All Employees	Personal compliance with this policy in daily data handling. Reporting actual or suspected data breaches immediately. Completing mandatory data privacy training.	Line managers	Performance assessment includes data privacy compliance.

4.5 Data Protection Register — Maintaining Records of Processing Activities

The company maintains a Data Protection Register (also called a Record of Processing Activities or ROPA) as a central inventory of all personal data processing activities conducted by the company as a Data Fiduciary. The register is maintained by the Legal team with input from all business functions and is updated whenever a new processing activity is initiated, an existing activity changes materially, or a processing activity is discontinued. It is reviewed quarterly by the DPO and annually by the Audit Committee. The register is an internal governance document — it is not publicly disclosed, but selected entries may be shared with regulators and enterprise clients who have an audit right under their data processing agreements.

Register Field	Description	Example Entry
Processing Activity Name	A clear and specific name for the processing activity that distinguishes it from other activities in the register.	Employee Payroll Processing

Register Field	Description	Example Entry
Processing Purpose	The specific, documented purpose for which the personal data is collected and processed.	Calculation and payment of employee salary, deductions, and statutory contributions (PF, ESI, TDS).
Legal Basis	The lawful basis under the DPDP Act for the processing — consent, legitimate use, or deemed consent.	Legitimate Use — Section 7(a) of DPDP Act 2023 (employment contract performance and legal obligation).
Data Categories	The categories of personal data processed in this activity.	Name, employee ID, PAN, bank account details, salary, deductions, tax declarations, PF and ESI numbers.
Data Principals	The categories of individuals whose data is processed.	All permanent and fixed-term employees. Contractors where payroll is processed by the company.
Retention Period	How long the personal data is retained before deletion.	7 years from the end of the financial year in which the payment was made — per Income Tax Act record-keeping requirements.
Recipients / Disclosures	Third parties to whom the personal data is disclosed.	Finance software (SAP — data processor). Government portals (TRACES, EPFO, ESIC — statutory disclosure). Statutory auditors (annual audit — legitimate use).
Security Measures	The primary technical and organisational security measures applied.	Access restricted to Finance and HR teams by role. Payroll data encrypted at rest. MFA required. IT Security Policy applies.
Cross-Border Transfer	Whether the personal data is transferred outside India.	No cross-border transfer. All payroll data stored on India-hosted servers.
DPIA Required?	Whether a Data Protection Impact Assessment has been completed or is required.	No DPIA required — standard, well-established processing with low risk.

5. Lawful Bases for Processing Personal Data

5.1 The Consent Basis — Requirements for Valid Consent

Consent is one of the primary lawful bases for processing personal data under the DPDP Act 2023. The Act sets a high standard for valid consent — one that is significantly more demanding than the implicit or bundled consents that were common practice under the earlier IT Rules framework. Valid consent under the DPDP Act must simultaneously meet five requirements: it must be free (not coerced by conditioning a service on consent to unrelated processing); specific (given for a specific purpose, not a general permission to process data for any purpose); informed (the Data Principal must have been given a clear and plain-language notice of the processing before consenting); unconditional (not bundled with consent to unrelated processing as a condition of a service); and unambiguous (given by a clear affirmative action — a positive act such as checking a box or clicking a button, not silence or a pre-ticked box).

Consent Requirement	What It Means	Compliant Practice	Non-Compliant Practice
Free	The Data Principal's choice to consent must not be conditioned on withholding a service or benefit that is not contingent on that processing.	Providing a service regardless of consent to analytics tracking. Consent to non-essential processing is genuinely optional.	Refusing to onboard an employee unless they consent to their data being shared for unrelated marketing purposes.
Specific	Consent must be for a precisely defined processing purpose, not a general permission.	Separate consent requests for: (1) sending marketing communications; (2) sharing data with partner organisations.	A single checkbox: "I consent to Arjun Technologies using my data for all business purposes."
Informed	The Data Principal must have received a clear notice of the processing activity before the consent request is presented.	Privacy notice delivered and confirmed read before the consent checkbox appears. Notice uses plain language — not legal jargon.	Consent checkbox presented without a prior privacy notice. Or notice available only via a link with no confirmation it was accessed.
Unconditional	Consent must not require the Data Principal to agree to other, unrelated processing as a condition of providing consent.	Employment consent requests are separate from any optional processing consents.	Making participation in an optional company event contingent on consenting to photography and social media publication.
Unambiguous	Consent must be a clear positive action — not silence, inaction, pre-ticked boxes, or implied from other conduct.	A blank checkbox that the user actively checks. A button labelled "I consent to [specific purpose]" that the user clicks.	A pre-ticked box. "By using this service you consent to..." A note that consent will be assumed unless the user contacts HR.

The DPDP Act also requires that consent notices be provided in a clear and plain language that a layperson can understand — not in the legal or technical language that has historically characterised privacy notices. The DPO reviews all consent notices and privacy notices for plain language compliance before they are published or distributed. All consent notices must be capable of being provided in the languages specified in the Eighth Schedule of the Constitution of India at the Data Principal's request — the company currently maintains consent notices in English, Hindi, Kannada, Telugu, and Tamil for the geographies in which it operates.

The right to withdraw consent is an integral and irrevocable element of the consent framework. The DPDP Act requires that withdrawing consent be as easy as giving it. The company must provide a simple, accessible mechanism for Data Principals to withdraw consent for any processing activity that relies on the consent basis. Withdrawal of consent does not affect the lawfulness of processing conducted before the withdrawal. However, from the moment of withdrawal, the company must cease processing based on that consent unless an alternative lawful basis applies.

5.2 Legitimate Uses — Processing Without Consent

The DPDP Act recognises categories of processing that do not require consent — referred to as 'legitimate uses' in the Act. These are specific, bounded categories where the purpose of the processing is sufficiently important and the legitimate expectation of the Data Principal sufficiently clear that requiring specific consent would be impractical or disproportionate. The company relies on legitimate use bases for a significant proportion of its data processing — particularly employment-related processing, where conditioning the employment relationship on consent to every element of HR data processing would not represent genuine consent.

Legitimate Use Category	DPDP Act Provision	Company Processing Examples	Conditions and Limits
Voluntary disclosure by Data Principal	Section 7(b)	An employee who voluntarily provides their emergency contact details, dietary preferences for events, or professional certifications not required for their role.	Processing is limited to what the Data Principal chose to disclose. Cannot be used as a basis to request additional data.
State and state instrumentalities	Section 7(a)	Processing required by law or government order — tax compliance, provident fund, statutory filings, court orders.	Processing is lawful only to the extent required by the applicable legal obligation. Cannot be extended beyond the statutory purpose.
Performance of contract	Section 7(c) — implied from the employment of "contract" in the context of functions of Parliament and State Legislature	Employment contract performance: salary processing, leave management, performance management. Client contract performance: delivering contracted services.	Processing must be necessary for the specific contract. The contract purpose cannot be used as a blanket basis for unrelated processing.
Medical emergency and vital interest	Section 7(d) — threat to life or health	Processing employee health data in a medical emergency. Sharing an employee's emergency contact details with medical services when the employee is incapacitated.	Limited to genuine emergencies. Not available as a basis for routine health data processing.
Employment and HR functions	Section 7(f) — purpose of employment or related safeguarding and assessment of performance	Employee performance management, attendance management, training, and disciplinary processes. Background verification.	Must be reasonably necessary for the employment purpose. Cannot be used to justify extensive surveillance or processing not genuinely required for the HR function.
Public interest and research	Section 7(e) — functions of the State, compliance with judgements, medical emergencies, disaster management	Processing required for legitimate public interest purposes — such as providing employee data to a statutory inquiry or regulatory investigation.	Specific to the enumerated categories. Not a general public interest exception.

5.3 Deemed Consent — Scope and Limitations

Deemed consent applies where personal data has been made publicly available by the Data Principal themselves — such as information published on a professional network like LinkedIn — and the processing is for purposes consistent with the context in which the data was made public. Deemed consent also applies where the Data Principal voluntarily provides personal data for a specific purpose and the processing is reasonably expected in that context. The concept is narrow and should not be used as a substitute for obtaining valid consent where the processing is not clearly within the expected scope of the data disclosure.

The most common company context for deemed consent is the use of publicly available professional information — contact details and professional profiles published on LinkedIn and similar platforms — for legitimate business development and recruitment outreach. The company may contact an individual whose professional details are publicly available for genuinely relevant professional purposes (a recruitment inquiry for a role the person's background suggests they may be interested in; a business development inquiry where the person's professional role makes them a genuine potential client contact). Deemed consent does not extend to mass marketing, data harvesting, or purposes that the Data Principal would not reasonably anticipate from the context of their public disclosure.

5.4 The Consent Manager Framework

The DPDP Act introduces the Consent Manager — a new intermediary mechanism that enables Data Principals to give, manage, review, and withdraw consent across multiple Data Fiduciaries through a single centralised platform. Consent Managers must be registered with the Data Protection Board and must meet specific accountability and technical standards set by the Board. The Consent Manager framework is designed to address the consent fatigue problem — the difficulty for individuals in managing consent across hundreds of digital services — by creating a trusted intermediary through which consent can be managed centrally.

The company's current position is that Consent Manager integration will be implemented for consumer-facing processing activities (website, marketing, and product services) as the Consent Manager ecosystem becomes operational following the DPBI's registration programme. For employment-related processing, the employment relationship and the legitimate use bases reduce the dependency on consent as a primary lawful basis, which in turn reduces the scope of Consent Manager integration required for HR processing. The DPO monitors the Consent Manager regulatory framework development and will update the company's implementation plan accordingly.

5.5 Processing of Children's Data

The DPDP Act 2023 provides specific and enhanced protections for the personal data of children — defined as individuals under the age of 18. These enhanced protections reflect the particular vulnerability of children in digital environments and the potential for serious harm from inappropriate processing of their data. Processing the personal data of a child requires verifiable parental consent — not merely a checkbox assertion of parental status, but a genuine verification mechanism. The Act also prohibits tracking and behavioural monitoring of children, and the use of children's personal data for targeted advertising.

Obligation	DPDP Act Provision	Company Application	Implementation Measure
Verifiable parental consent required	Section 9(1) — parental consent before processing child's personal data	Where any company system or product processes personal data of users who may be minors, age verification and parental consent mechanisms must be implemented.	DPIAs for all consumer-facing products must assess child data risk. Age verification design incorporated in system architecture for applicable products.
No tracking or behavioural monitoring of children	Section 9(3)(b) — prohibition on tracking and monitoring	No tracking cookies, behavioural analytics, or user profiling may be applied to users identified or verified as minors.	Cookie consent systems must be configured to exclude tracking from verified or likely minor users.
No targeted advertising directed at children	Section 9(3)(c) — prohibition on targeted advertising	No advertising algorithms may use a verified minor's data to target advertising at them.	Ad targeting systems used in company products must exclude verified minor profiles from targeting parameters.
Data minimisation for children's data	Section 9(1) — minimal data collection principle	Only the minimum personal data necessary for the service is collected from or about children.	PbD assessment for services accessible to children. Data element justification required for each field.

Obligation	DPDP Act Provision	Company Application	Implementation Measure
Internal HR context — employees' dependent data	The dependents (children) of employees whose data is collected for benefits administration (insurance, emergency contacts) are children.	Dependent data collected for employment benefits must not be used for any purpose beyond the specific benefit purpose. No analytics or secondary processing of child dependent data.	HR system access controls restrict dependent data to benefits administration users only.

6. Data Classification Framework

6.1 Classification Categories — Personal, Sensitive, and Non-Personal

The data classification framework provides every employee with a clear, practical guide for determining how a specific piece of data should be handled. Classification is not an academic exercise — it is the foundation of the operational data handling standards in Segment 2. Every employee who creates, receives, or handles data in the course of their work at Arjun Technologies has a responsibility to classify it correctly and to apply the handling standards appropriate to its classification.

Classification	Definition	Examples	Handling Standard
PERSONAL DATA	Any data about an identifiable natural person — direct identifiers or data that can identify a person in combination with other data.	Name, email address, phone number, employee ID, photograph, IP address, location data, cookie identifiers.	Apply the full data privacy framework of this policy. Lawful basis required. Data subject rights apply. Breach notification obligations apply.
SENSITIVE PERSONAL DATA (SPDI under IT Rules 2011)	Specific categories defined in the IT (SPDI) Rules 2011: passwords, financial information, health data, sexual orientation, biometric data, medical records.	Bank account details, health conditions, fingerprint data, medical certificates, sexual orientation.	Enhanced protection: written consent required for collection, use, and disclosure under the IT Rules 2011. Company handles these categories under the highest protection standard. Access on strict need-to-know basis. Encrypted at rest and in transit.
PERSONAL DATA — SPECIAL CATEGORIES (anticipated under DPDP Act Rules)	Categories likely to attract enhanced protection under DPDP Act Rules — expected to include health, religious/political beliefs, caste, sexual orientation, and genetic/biometric data.	Religious or caste affiliation noted in HR records. Genetic testing results. Detailed biometric profiles.	Company applies the SPDI standard to all data in this category pending the publication of the DPDP Act Rules. DPO informed of all processing of this data. DPIA mandatory.
NON-PERSONAL DATA	Data that does not relate to an identified or identifiable natural person, or personal data that has been anonymised such that re-identification is not possible.	Aggregate statistics. Anonymised analytics. Technical system logs that do not contain user identifiers.	Standard information security controls per IT Security Policy. Data privacy obligations do not apply where genuine anonymisation is confirmed. Legal team and DPO assess anonymisation claims.
COMPANY CONFIDENTIAL (not personal data)	Business information that is not personal data but that requires protection for commercial reasons — trade secrets, client pricing, strategic plans.	Source code, proprietary algorithms, client contract terms, financial forecasts.	Information classification scheme per IT Security Policy and Code of Conduct Section 7.3. Not subject to DPDP Act but subject to confidentiality obligations.

6.2 The Information Classification Scheme — Company Labels and Handling

The company's information classification scheme assigns one of four labels to every piece of information the company handles. The scheme applies to both personal data (governed by this policy) and non-personal confidential information (governed by the IT Security Policy and Code of Conduct). The label on a document, dataset, or communication determines the handling requirements that apply to it.

Classification Label	Definition	Examples	Minimum Handling Requirements
PUBLIC	Information approved for public disclosure. No harm from general release.	Company website content. Published annual report. Public press releases. Published technical blog posts.	Standard website and communication channels. No special handling required beyond accuracy.

Classification Label	Definition	Examples	Minimum Handling Requirements
INTERNAL USE ONLY	Information intended for internal audiences only. Some harm from external disclosure but not catastrophic.	This policy document. Internal procedure guides. General company communications. Non-sensitive project documentation.	Not to be shared externally without authorisation. Standard access controls. No special technical encryption required beyond standard IT security.
CONFIDENTIAL	Information where unauthorised disclosure would cause significant harm — commercial, operational, reputational, or privacy-related.	Employee personal data. Client contact data. Commercially sensitive project details. Unpublished financial data. Client system documentation.	Restricted to individuals with a specific need to access. Encrypted in transit and at rest for electronic transmission. Password protected for file sharing. Not discussed in public or open areas. Covered by NDA for external disclosure.
RESTRICTED	The most sensitive information — where unauthorised disclosure would cause severe harm. Includes all special category personal data, Sensitive Personal Data under IT Rules, highly sensitive commercial data, and security-critical technical information.	Employee health records. Salary band data. Security architecture diagrams. Encryption keys. Merger and acquisition information. Data that is SPDI under IT Rules 2011.	Access on strict need-to-know basis. Mandatory encryption at rest and in transit. No transmission via personal email. No sharing without DPO notification for personal data. Physical documents in locked storage. Full audit log required.

6.3 Special Category Personal Data — Enhanced Protection Requirements

Special category personal data — the categories of personal data whose processing carries heightened risk of harm to the Data Principal — is automatically classified as RESTRICTED and is subject to the enhanced handling requirements described above plus the additional obligations in this section. The company applies the IT Rules 2011 SPDI framework to all data in this category, and will extend the DPDP Act Rules enhanced category protections from the moment those Rules are published and in force.

Special Category	Primary Legal Basis (IT Rules / DPDP Act)	Company Processing Context	Access Controls	Specific Additional Obligation
Health and medical data	IT SPDI Rules — express written consent for collection. DPDP Act — enhanced protection anticipated in Rules.	Employee sick leave records and medical certificates. Occupational health reports. Health insurance claims. Fitness-to-work assessments.	HRBP only — line managers do not have access to health data fields. Medical certificates not accessible to line managers in HRMS.	DPO notified of all new health data processing activities. DPIA mandatory for new health data systems. No health data in AI tools without DPO approval.
Financial account information	IT SPDI Rules — as sensitive personal data.	Employee bank account details for payroll. Employee salary and tax data.	Finance payroll team and HRBP only. Salary data not accessible to managers in HRMS (only performance ratings visible to managers, not salary figures).	Payroll data encrypted at rest. Bank details entered only once — not retrievable in plain text after initial entry except by Finance under controlled access.

Special Category	Primary Legal Basis (IT Rules / DPDP Act)	Company Processing Context	Access Controls	Specific Additional Obligation
Biometric data	IT SPDI Rules — as sensitive personal data. DPDP Act — likely enhanced category.	Building access biometric systems (where in use). Fingerprint attendance systems (where deployed).	IT Security team and Facilities only. No employee can access another employee's biometric data.	Biometric data not used for any purpose beyond the specific security/attendance purpose for which it was collected. Not shared with any third party. Retention period: deleted on employment end.
Sexual orientation and gender identity	IT SPDI Rules — as sensitive personal data.	HR diversity monitoring data (where collected with explicit consent as part of a voluntary diversity survey).	HRBP and HR Operations. Not in line manager view.	Diversity monitoring data may only be collected on a fully voluntary, opt-in basis with specific, informed consent. Not used for any employment decision.
Religious and political beliefs; caste	Not currently in IT SPDI Rules but anticipated in DPDP Act special categories.	Not proactively collected by the company. May be disclosed voluntarily (e.g. for religious observance leave, religious dietary requirements at events).	HRBP only. Not accessible to line managers.	Not to be collected proactively. Where voluntarily disclosed for a specific purpose: processed only for that purpose. No inference or profiling from this data.
Genetic data	IT SPDI Rules — as part of biometric data. DPDP Act — likely explicit enhanced category.	Not currently collected or processed by the company.	Not applicable — not processed.	Any future processing of genetic data requires DPO approval and mandatory DPIA before collection begins.

6.4 Non-Personal Data — Distinction and Governance

Non-personal data — data that does not relate to an identified or identifiable natural person — is increasingly important in the company's analytics, AI development, and client data services work. The DPDP Act and IT Act data privacy obligations do not apply to genuinely non-personal data. However, the boundary between personal and non-personal data is not always clear, and data that appears non-personal may in fact be personal data where it can reasonably be combined with other data to identify an individual. The company's approach to this boundary is governed by three rules: the de-identification quality standard, the combination risk assessment, and the re-identification prohibition.

The de-identification quality standard requires that any claim that personal data has been anonymised or de-identified must be supported by a documented assessment confirming that re-identification is not possible given the available data and reasonable inference techniques. Pseudonymisation — replacing direct identifiers with codes or pseudonyms — does not produce non-personal data if the key that connects the pseudonym to the individual is retained. Pseudonymised data remains personal data and is subject to all data privacy obligations. Only genuine anonymisation — where re-identification is not possible even with the original data available — produces non-personal data for the purposes of the DPDP Act.

7. Data Subject Rights Under the DPDP Act

7.1 Overview of Data Principal Rights

The Digital Personal Data Protection Act 2023 gives Data Principals — the individuals whose personal data is processed — a set of enforceable rights against Data Fiduciaries. These rights are personal: they belong to each individual Data Principal in respect of their own personal data. They are enforceable: a Data Principal who believes their rights have been denied can escalate to the Data Protection Board of India after exhausting the Data Fiduciary's own grievance process. And they are consequential: failure to meet rights request obligations can result in penalties under the Act.

Right	DPDP Act Provision	What It Enables	Company Response Obligation
Right of Access	Section 11(a) and 11(b)	The Data Principal may request: (a) a summary of personal data being processed; (b) the identities of all Data Fiduciaries and Data Processors with whom their data has been shared.	Provide a complete, accurate summary of personal data held and all sharing relationships within the prescribed response timeline.
Right of Correction	Section 12(a)	The Data Principal may request correction of inaccurate or misleading personal data and completion of incomplete personal data.	Correct confirmed inaccuracies within the response timeline. Where the Data Fiduciary disputes the correction, maintain the Data Principal's version alongside the Data Fiduciary's version, flagged as disputed.
Right of Updating	Section 12(a) — extension of correction	The Data Principal may request updating of personal data that is no longer current.	Update confirmed outdated data within the response timeline.
Right of Erasure	Section 12(b)	The Data Principal may request erasure of personal data where the purpose for which it was collected has been fulfilled and retention is no longer necessary under law or contract.	Erase personal data where the purpose has been fulfilled and no legal retention obligation requires continued retention. Erasure of employee data is typically deferred until after the employment record retention period.
Right of Grievance Redressal	Section 13	The Data Principal may contact the DPO with a complaint about any processing activity and receive a response. If unsatisfied, may escalate to the DPBI.	Acknowledge receipt of grievances within the prescribed period. Investigate and respond fully. Provide details of DPBI escalation right.
Right to Nominate	Section 14	The Data Principal may nominate another individual to exercise their rights in the event of their death or incapacity.	Maintain nomination records where provided. Process requests from confirmed nominees as if from the Data Principal themselves.

7.2 Right of Access — Information and Summary of Processing

When a Data Principal exercises their right of access, the company must provide two categories of information: first, a summary of the personal data held about the Data Principal — what categories of data are held, for what purpose, and for how long; and second, the identities of all Data Fiduciaries and Data Processors with whom the Data Principal's personal data has been shared. The response must be clear, plain-language, and comprehensive. It is not sufficient to point the Data Principal to the company's published privacy policy and invite them to read it — the access response must be specific to the Data Principal's actual data.

For employee access requests — which are the most common category of access request the company receives — the HRBP co-ordinates the response. The HRBP pulls the relevant data from HRMS and all other systems in which the employee personal data is held (payroll system, leave management, performance management, email server if subject to legal hold) and compiles the access response. The DPO reviews the response before it is sent. For non-employee access requests (client contacts, website visitors), the Legal team co-ordinates the response.

7.3 Right of Correction, Completion, and Updating

The right of correction allows a Data Principal to request that inaccurate personal data held about them is corrected. The company must correct confirmed inaccuracies promptly. Where the accuracy of the data is genuinely disputed — for example, where the company holds a performance assessment that the employee believes is factually inaccurate — the company must note the dispute in the record, investigate the factual question if the dispute raises a genuine issue of accuracy (not merely a disagreement about assessment judgement), and provide the Data Principal with the outcome of the investigation.

Correction of employee performance records requires particular care: the Performance Management Policy has its own appeal process for disputed performance assessments. A correction request that is in substance a performance assessment appeal should be directed through the PMP appeal process rather than the data privacy correction process. The DPO, HRBP, and VP-HR co-ordinate the categorisation of requests that could fall under either process.

7.4 Right of Erasure

The right of erasure entitles a Data Principal to request deletion of personal data where the processing purpose has been fulfilled and no legal obligation requires continued retention. This right is subject to important qualifications in the employment context: employee personal data is subject to statutory retention requirements under Indian tax law (Income Tax Act — 7 years for payroll records), employment law (state SE Acts — varying record-keeping requirements), and the company's employment contract obligations. An employee who requests erasure of their personnel record during their employment or within the statutory retention period cannot obtain full erasure, because the legal retention obligation overrides the right of erasure.

After the statutory retention period has expired — typically 7 years after the end of employment for most employment record categories — a former employee has a genuine right to request erasure of their personal data, and the company must fulfil that request in respect of all personal data for which the retention period has passed. The Data Retention Schedule in Segment 2 Appendix specifies the retention period for each personal data category and the date from which erasure requests become operable.

7.5 Right of Grievance Redressal

Every Data Principal has the right to contact the company's Data Protection Officer with a complaint about any aspect of the processing of their personal data. The company must acknowledge the complaint within 48 hours of receipt and provide a substantive response within 30 days. The DPO investigates each complaint with the relevant team (HR for employee data; Legal for client data; IT for security-related complaints) and provides a written response setting out the company's position, any action taken, and the Data Principal's right to escalate to the Data Protection Board of India if they remain unsatisfied. All grievances are logged in the DPO grievance register regardless of outcome.

7.6 Right to Nominate

A Data Principal may nominate any other individual to exercise their data privacy rights on their behalf in the event of their death or incapacity. The nomination must be in writing and submitted to the DPO through the designated process. The company maintains a nomination register and processes requests from confirmed nominees as if they were requests from the Data Principal themselves. For employee nominations, the HRBP retains the nomination in the employee's HRMS record alongside the emergency contact information.

7.7 Response Timelines and Process Standards

Rights Request Type	Acknowledgement Deadline	Substantive Response Deadline	Extension Available?	Escalation (if unresolved)
Right of Access	48 hours from receipt	30 days from receipt (expected under Rules — company standard)	Extensions may be permitted under Rules where the request is complex or numerous — Legal team assesses.	DPBI complaint after 30-day window lapses without response.
Right of Correction or Updating	48 hours	30 days for straightforward corrections. Up to 60 days where factual investigation required.	60-day extension for complex disputed corrections, with DPO notification to Data Principal.	DPBI complaint after deadline lapses.
Right of Erasure	48 hours	30 days for standard erasure where retention period has expired. Longer where retention obligations require assessment.	Up to 60 days where legal retention analysis is complex.	DPBI complaint after deadline. Legal team review for contested erasures.
Right of Grievance Redressal	48 hours (mandatory under Act)	30 days for full response. 48-hour emergency acknowledgement for breach-related grievances.	Extension available for complex investigations with DPO notification.	DPBI complaint after 30 days if unsatisfied. DPBI can impose penalties for failure to respond.
Right to Nominate	5 working days for confirmation of nomination registration.	N/A — nomination confirmation is itself the response.	Not applicable.	DPO to be contacted if confirmation not received within 5 days.

7.8 Data Principal Rights — Internal Handling Procedures

All Data Principal rights requests — access, correction, erasure, grievance, and nomination — must be routed through the DPO. Employees who receive a data privacy rights request directly (whether by email, by post, or by verbal request) must not attempt to fulfil it themselves — they must forward it to dpo@arjuntech.in immediately and acknowledge to the requestor that it has been forwarded and will be responded to within the applicable timeline. This centralised routing is essential to ensure that responses are accurate, consistent, and documented, and that the DPO maintains the complete picture of all rights requests received by the company.

Step	Action	Owner	Timeline	HRMS/System Action
1	Rights request received (any channel — email to any address, post, verbal, through website form).	Any employee who receives the request.	Same day.	Forward to dpo@arjuntech.in immediately. Do not attempt to fulfil independently.
2	DPO registers the request in the Rights Request Register. Sends acknowledgement to Data Principal confirming receipt and the response deadline.	DPO.	Within 48 hours of receipt.	DPO portal → New Request → Register → Acknowledge.
3	DPO assesses the nature of the request and routes to the relevant team for data collection and investigation.	DPO.	Within 3 working days.	DPO portal → Assign to team (HR / Legal / IT / other).
4	Relevant team collects the required information, drafts the response, and submits to DPO for review.	HRBP (employee requests), Legal team (client or other), IT (security incidents).	Within 20 working days.	HRBP/Legal documents response in DPO portal case record.

Step	Action	Owner	Timeline	HRMS/System Action
5	DPO reviews the draft response for accuracy, completeness, plain language, and legal compliance. Approves or returns for revision.	DPO.	Within 5 working days of receiving draft from team.	DPO portal → Review → Approve or Return.
6	Approved response sent to Data Principal. Case closed in Rights Request Register.	DPO.	Within 30 days of original receipt.	DPO portal → Send Response → Close Case. Data Principal receives response by email or their preferred channel.
7	If the Data Principal is not satisfied with the response: DPO attempts resolution. If unresolved: Data Principal informed of DPBI escalation right.	DPO.	Within 15 days of escalation receipt.	DPO portal → Escalation record. DPBI referral information provided to Data Principal.

Data Privacy in Practice — Common Scenarios and Guidance

The following scenarios address the data privacy situations most frequently encountered by employees and managers at Arjun Technologies. Each applies the provisions of this policy to specific fact patterns. For situations not covered here, consult the DPO at dpo@arjuntech.in before proceeding.

Scenario	Facts	Correct Action and Policy Basis
1 — Sharing employee data with a colleague	A manager asks for a list of all employees in another team including their salary grades and performance ratings, to assist with cross-team project planning.	Salary data and performance ratings are CONFIDENTIAL/RESTRICTED personal data. They may be shared only on a genuine need-to-know basis. Cross-team project planning does not create a need to know individual salary grades. The manager should be provided with role band information (not salary) and aggregate performance standing (not individual ratings) if genuinely needed for planning. Share only what is necessary for the stated purpose. (Sections 6.2 and 4.1 — purpose limitation and data minimisation.)
2 — Client data in an AI tool	A consultant is drafting a client deliverable and wants to paste a client data extract containing customer names, account numbers, and transaction data into a generative AI tool to summarise it.	This is prohibited. Client data is CONFIDENTIAL and customer personal data is CONFIDENTIAL/RESTRICTED. Entering personal data or confidential client data into an AI tool that processes data outside company-managed infrastructure violates the AI ethics provisions of the Code of Conduct Section 10.3 and the data security obligations in this policy. Use only the approved AI tools on the Approved Tools Register (IT-SEC-POL-006) for this purpose. (Sections 4.1, 6.2, and Code of Conduct Section 10.3.)
3 — Employee access request	A current employee emails the HR Business Partner asking to see all the personal data the company holds about them, including performance reviews, disciplinary records, and salary history.	This is a Data Principal rights request under Section 11 of the DPDP Act. The HRBP must not attempt to fulfil it independently. Forward to dpo@arjuntech.in immediately. The DPO registers the request, acknowledges receipt within 48 hours, and co-ordinates with the HRBP to compile the access response within 30 days. The employee is entitled to a summary of all personal data held, including performance records (the content, not just the category), salary history, and disciplinary records. (Section 7.8.)
4 — Medical certificate handed to line manager	An employee returning from a 10-day sick leave hands their medical certificate (which shows the specific diagnosis) directly to their line manager.	The line manager should immediately forward the certificate to the HRBP without reading the diagnosis detail, and should not retain a copy. Medical certificates contain RESTRICTED health data. Line managers are not authorised to view or retain the content of medical certificates. The HRBP receives, records, and stores the certificate under appropriate access controls. If the line manager has already read the diagnosis, they must treat that information as strictly confidential and not share, discuss, or act on it in any employment decision context. (Sections 6.3 and Leave Policy Segment 1, Section 3.9.)
5 — Client asking to audit company data practices	A major financial services client requests a formal audit of the company data privacy practices as part of their vendor assurance programme, including access to the Data Protection Register.	The client has a legitimate interest in the company data privacy standards given the sensitive data processed in the engagement. The Legal team manages the audit response. Selected entries from the Data Protection Register relevant to the client engagement may be shared under a confidentiality agreement. The full register is not disclosed. The DPO participates in the audit meeting. The Privacy Governance structure (Section 4.4) and the the ISO 27001 certification are presented as evidence of the governance framework. (Section 4.5 and client DPA audit rights.)

Scenario	Facts	Correct Action and Policy Basis
6 — Receiving personal data not requested	An employee receives a file from a client containing personal data of the client customers that was not requested and is not within the scope of the engagement.	Notify the client contact and the HRBP immediately. Do not process, analyse, share, or store the data. Return it to the client with a request for clarification of the purpose. If the client insists on transferring the data without a clear purpose, escalate to the Legal team. Unsolicited personal data creates processing obligations the company cannot satisfy without a lawful basis. Receiving it without a clear purpose and DPA coverage creates regulatory risk. (Section 5 — lawful basis requirement. Section 4.1 — purpose limitation.)
7 — A data breach suspected	An employee notices that a colleague email account account appears to have been compromised — the colleague is receiving bounce notifications from emails they did not send, and some of the emails contain client contact data.	Report to IT Security (security@arjuntech.in or IT helpdesk extension 1000) and the DPO (dpo@arjuntech.in) immediately — same day, within hours of suspecting the breach. Do not wait to investigate personally. Do not discuss the incident with colleagues beyond those who need to know. The IT Security team contains the breach, the DPO assesses notification obligations to the DPBI and affected Data Principals, and the breach is logged in the breach register. Time is critical — notification obligations under the DPDP Act Rules are expected to require notification within 72 hours of the Data Fiduciary becoming aware. (Segment 2, Breach Management section.)

Data Privacy Quick Reference Card — Every Employee

This reference card summarises the most important data privacy obligations for every employee. It does not replace the full policy — it provides the minimum knowledge every employee must have. For full provisions, see the relevant section.

Question	Answer	Policy Section
Can I share an employee personal details with a colleague who asks?	Only if they have a genuine need to know for a specific work purpose. Never share salary, health, or disciplinary data without HRBP confirmation that the recipient is authorised.	Section 4.1, 6.2
Can I put client data into an AI tool like ChatGPT?	No. Client data and personal data must not be entered into any AI tool that processes data outside company-managed infrastructure. Use only tools on the IT-approved list.	Section 6.2; CoC Section 10.3
Someone has emailed me asking for their personal data. What do I do?	Forward to dpo@arjuntech.in immediately. Acknowledge to the sender that it has been forwarded. Do not fulfil the request yourself.	Section 7.8
I think a data breach has occurred. What do I do?	Report immediately to IT Security (security@arjuntech.in / ext 1000) and DPO (dpo@arjuntech.in). Do not investigate alone. Do not wait.	Section 4.1; Segment 2
Can I keep a spreadsheet of employee or client personal data on my personal laptop?	No. Personal data must be stored only on company-managed devices and systems. Personal laptops, personal email, and personal cloud storage are prohibited.	Section 6.2; IT Security Policy
What is "sensitive" personal data and do I need to treat it differently?	Health, financial account details, biometric data, and similar categories are RESTRICTED. Access on strict need-to-know only. Encrypted in transit and at rest. Contact HRBP or DPO before handling.	Section 6.1, 6.3
When do I need consent to process their data?	For processing that is not covered by a legitimate use basis (employment, legal obligation, contract), you need specific, informed, voluntary consent. Contact the DPO before starting any new data collection.	Section 5.1, 5.2
What is the DPDP Act and why does it matter to me?	The Digital Personal Data Protection Act 2023 is India comprehensive data privacy law. It gives individuals rights over their data and creates enforceable obligations for organisations. Violations can result in penalties up to Rs 250 crore.	Section 3.1
How do I report a data privacy concern anonymously?	Use the Whistleblower hotline at ethics@arjuntech.in (24/7, anonymous). For non-anonymous concerns: dpo@arjuntech.in.	Section 4.3
I received personal data I was not expecting. What do I do?	Notify the DPO at dpo@arjuntech.in immediately. Do not process or store the data until the DPO confirms the lawful basis and handling instructions.	Section 5

Mandatory Data Privacy Training Requirements

The following training modules are mandatory for all employees and must be completed within the timelines below. Completion is tracked in HRMS. Non-completion results in restricted system access for data-handling systems.

Module	Audience	Completion Deadline	Frequency	Consequence of Non-Completion
DPDP Act 2023 Foundation Awareness	All employees	31 October 2024 (first year). Thereafter: 30 September annually.	Annual	Access to systems containing personal data restricted until complete.
Data Privacy for HR Professionals	All HRBP, HR Operations, and Payroll team members	31 May 2024 (first cohort). Annually thereafter.	Annual	HRBP system permissions reviewed pending completion.

Module	Audience	Completion Deadline	Frequency	Consequence of Non-Completion
Data Privacy for Developers and Engineers	All software engineers, data engineers, ML engineers, and IT security team	31 July 2024 (first cohort). Annually thereafter.	Annual	Production system access reviewed pending completion.
Data Privacy for Client-Facing Roles	All client engagement managers, account managers, and consulting staff	31 July 2024. Annually thereafter.	Annual	Client system access reviewed pending completion.
Data Breach Identification and Reporting	All employees	31 October 2024. Annually thereafter.	Annual	Part of the combined DPDP Act awareness module — same deadline.
DPO and Legal Team Advanced Data Privacy Certification	DPO, General Counsel, and Legal team members	External certification (CIPP/A, FIP, or equivalent) — rolling as team members join.	Initial certification + CPD	Not applicable — role-specific professional certification.

DPDP Act 2023 — Penalty Reference and Enforcement Framework

The following table provides a complete reference to the penalty provisions under the Digital Personal Data Protection Act 2023. Every manager and employee with data handling responsibilities should understand the financial consequences of non-compliance. Penalties are per breach, not per year, and may be cumulative where multiple violations occur in a single incident.

Violation	Maximum Penalty	Schedule Item	Primary Mitigation
Failure to implement reasonable security safeguards preventing personal data breach	Rs 200 crore	Item 1	ISO 27001 certification. IT Security Policy controls. Regular security audits.
Failure to notify DPBI and affected Data Principals of a breach	Rs 200 crore	Item 2	Operational breach notification procedures (Segment 2). Timely internal breach reporting.
Non-fulfilment of obligations relating to children data	Rs 200 crore	Item 3	Privacy by Design assessments for consumer-facing products. Age verification mechanisms.
Non-fulfilment of Significant Data Fiduciary obligations	Rs 150 crore	Item 4	Proactive SDF compliance: DPO appointed, data auditor engaged, DPIAs conducted.
Failure to fulfil Data Principal rights requests within prescribed timelines	Rs 50 crore	Item 7	Operational rights request process (Section 7.8). DPO oversight of all requests.
Non-compliance with Act or Rules not covered by specific items	Rs 50 crore	Item 8	Overall policy compliance programme. Annual audit. DPDP training completion.
Non-compliance with voluntary undertaking to DPBI	Rs 50 crore	Item 9	General Counsel manages all DPBI interactions. No voluntary undertakings without Board approval.

The DPBI has discretion over the quantum of penalty within the specified maximum. A company with a well-documented, genuinely implemented data privacy programme that reports breaches promptly and cooperates with the DPBI is in a significantly stronger position than one with only a nominal compliance posture. This policy and the company data privacy programme are the primary evidence of genuine compliance.

Segment 1 Compliance Certification and Approval

Certification Area	Status	Responsible Party	Next Review
DPDP Act 2023 — full incorporation into policy	Complete. Company treating Act as operationally effective pending commencement notification. Monitoring notification schedule.	General Counsel	Immediate on notification. January 2025 annual.
IT Act 2000 and SPDI Rules 2011 — continued applicability verified	Confirmed current. SPDI provisions in Section 6.3.	General Counsel	January 2025
ISO 27001 alignment — technical security measures	Policy obligations consistent with ISO 27001. Certification current. Renewal due November 2024.	Head of IT / CISO	September 2024 pre-renewal audit
GDPR/UK GDPR — EU/UK client engagement alignment	EU SCC framework in place. Standard DPA reviewed against GDPR processor requirements.	General Counsel + External Counsel	January 2025
Cross-document consistency (CoC, IT Security Policy, HRMS Policies)	Verified April 2024. No inconsistencies.	HRBP Operations + Legal	January 2025
DPO appointment and grievance mechanism	DPO constituted from 01 April 2024. Contact details published. Grievance operational.	General Counsel	Annual

Role	Name	Signature	Date
Chief Executive Officer	Mr. Rajesh Arjun		01 April 2024
General Counsel and Document Owner	Mr. Sandeep Iyer		01 April 2024
Data Protection Officer	Designated from Legal Team		01 April 2024
VP Human Resources	Ms. Priya Menon		01 April 2024
Head of IT / CISO	Mr. Kiran Bhat		01 April 2024

Segment 1 Summary and Continuation to Segment 2

This completes Segment 1 of the Arjun Technologies Pvt. Ltd. Data Privacy Policy and Procedures Framework, Version 2.1. Segment 1 has established the complete foundational framework. The General Counsel's message set the context for the DPDP Act 2023 and the personal responsibility of every employee. Section 2 defined the purpose, comprehensive scope across all seven Data Principal categories, the hierarchy of related documents, and individual employee responsibility. Section 3 established the full statutory framework — the DPDP Act 2023 with an eight-element key provisions table, the nine defined terms with plain-language explanations, the continued applicability of the IT Act 2000 and SPDI Rules 2011 with a six-row provisions table, sector-specific regulations across seven industry verticals, and the international framework context for EU/UK client engagements. Section 4 addressed the company's Data Fiduciary obligations — the accountability principle with a six-obligation table, the Significant Data Fiduciary assessment and proactive compliance position, the DPO role with full responsibilities and authority definitions, the privacy governance structure with seven-level accountability assignments, and the Data Protection Register structure with a complete field specification. Section 5 covered all lawful bases for processing — the five-element consent validity framework, the six legitimate use categories, deemed consent scope and limitations, the Consent Manager framework, and the enhanced children's data protections with a five-obligation table. Section 6 delivered the data classification framework — the five-category classification scheme, the four-label information classification system with handling requirements, the special category personal data enhanced obligations across six categories, and the non-personal data distinction with de-identification standards. Section 7 established the complete Data Principal rights framework — the six rights under the DPDP Act with obligations, and the seven-step internal rights request handling procedure with a response timeline table.

Segment	Sections Covered	Key Topics	Pages	Status
Segment 1 — This Document	1–7	Purpose and Scope · DPDP Act 2023 Framework · Statutory Basis · Data Fiduciary Obligations · DPO Role · Consent Framework · Lawful Bases · Data Classification · Data Principal Rights	1–50	Published April 2024
Segment 2	8–13	Operational Data Handling Standards · Data Handling by Context (HR, Client, Marketing, IT) · Data Breach Management · Data Processor Management · Employee Monitoring · Data Retention and Deletion	51–100	Published April 2024
Segment 3	14–18 + Appendices A–H	Cross-Border Data Transfers · Sector-Specific Obligations · Privacy by Design · Enforcement and Penalties · Governance Programme · All Appendices	101–150	Published April 2024

All three segments are available on the HRMS portal under Policies and Documents. For data privacy queries and advice: legal@arjuntech.in or dpo@arjuntech.in. For Data Principal rights requests: dpo@arjuntech.in. For anonymous reporting of data privacy concerns: ethics@arjuntech.in (24/7). Document reference: LEGAL-POL-004-v2.1. Owner: Mr. Sandeep Iyer, General Counsel. Approved: Mr. Rajesh Arjun, CEO. Effective: 01 April 2024.

Data Inventory — Personal Data Assets by Business Function

The following table provides a high-level inventory of the principal personal data assets held by each business function at Arjun Technologies. It is designed as a quick reference for managers assessing their data privacy obligations within their function. Full processing activity detail is in the Data Protection Register maintained by the Legal team.

Business Function	Principal Personal Data Assets	Classification	Primary Lawful Basis	Custodian
Human Resources	Employee names, addresses, PAN, bank details, salary, leave records, performance assessments, disciplinary records, health data (sick leave/medical certificates), emergency contacts, next-of-kin.	CONFIDENTIAL / RESTRICTED (health and salary)	Legitimate use — employment. Legal obligation (PF, tax, SE Acts).	VP-HR / HRBP Operations
Finance and Payroll	Employee payroll data, tax declarations, bank account details, expense claim data, supplier contact data, invoice data with personal identifiers.	RESTRICTED (salary, bank details)	Legal obligation (TDS, PF). Contract (employment, supplier).	CFO / Finance Controller
Recruitment and Talent Acquisition	Candidate CVs, interview notes, reference check data, background verification results, offer letters, rejected candidate data.	CONFIDENTIAL	Consent (for speculative applications). Contract (active recruitment). Legitimate use (statutory BGV requirements).	VP-HR / TA Lead
Client Relationship Management	Client contact names, email addresses, phone numbers, designations, meeting notes, communication history, contract data containing personal details.	CONFIDENTIAL	Legitimate use — contract performance. Consent for marketing communications.	SVPs / Account Managers
Client Delivery Engagements	End-user personal data of client customers/employees processed within systems built or operated by Arjun Technologies. Data categories vary by engagement.	RESTRICTED (as processor of client data)	Data Processing Agreement with client (processor basis). Client is Data Fiduciary.	Engagement Manager / DPO
IT and Security	Employee device usage logs, access logs, email metadata (for security monitoring where permitted), building access records, IP addresses, authentication data.	CONFIDENTIAL	Legitimate use — security and fraud prevention. IT Security Policy (employee monitoring provisions).	Head of IT / CISO
Marketing and Communications	Contact details of external professionals who have opted in to marketing communications, event attendee data, website visitor analytics.	CONFIDENTIAL (contact data). Internal Use Only (anonymised analytics).	Consent (marketing). Legitimate use (event administration).	Head of Marketing
Legal and Compliance	Data subject rights request records, breach register, legal hold data (employee and client), regulatory correspondence, DPA register.	CONFIDENTIAL / RESTRICTED	Legal obligation. Legitimate use — legal proceedings.	General Counsel / DPO

LEGAL-POL-004-v2.1 | Data Privacy Policy — Segment 1 of 3 | Effective 01 April 2024 | Owner: Mr. Sandeep Iyer, General Counsel | DPO: dpo@arjuntech.in | Approved: Mr. Rajesh Arjun, CEO | For data privacy queries: legal@arjuntech.in | For anonymous concerns: ethics@arjuntech.in

Arjun Technologies Pvt. Ltd.

Bengaluru, Karnataka — 560 001

CIN: U72200KA2008PTC044521 | www.arjuntech.in

DATA PRIVACY POLICY AND PROCEDURES FRAMEWORK

Segment 2 of 3 — Operational Data Handling Standards · Data Handling by Context · Data Breach Management · Data Processor Management · Employee Monitoring · Data Retention

Version	2.1	**Effective Date**	01 April 2024
Review Date	31 March 2025	**Classification**	Internal Use Only
Approved By	Mr. Rajesh Arjun	**Document Owner**	Mr. Sandeep Iyer
Legal Author	Mr. Sandeep Iyer	**Department**	Legal & Compliance
Doc Reference	LEGAL-POL-004-v2.1	**Applies To**	All Employees, Contractors, and Data Processors
Segment	2 of 3 (Pages 51–100)	**Total Segments**	3

This is Segment 2 of the Arjun Technologies Pvt. Ltd. Data Privacy Policy and Procedures Framework, Version 2.1. It provides the operational standards that translate the foundational principles in Segment 1 into specific, actionable obligations for every day professional work. Section 8 establishes the general operational data handling standards — the handling rules by data state (in transit, at rest, in use) and by communication medium. Section 9 provides context-specific handling standards for the four principal data processing contexts: HR and employment data, client and engagement data, marketing and external communications, and IT systems and infrastructure data. Section 10 sets out the complete personal data breach management framework — detection, assessment, containment, notification, and review. Section 11 governs the management of third-party data processors — due diligence, contractual requirements, and ongoing oversight. Section 12 establishes the employee monitoring framework — the lawful bases and limits of workplace monitoring. Section 13 provides the data retention and deletion framework with complete retention schedules. Read alongside Segment 1 (foundational framework). For queries: dpo@arjuntech.in.

Table of Contents — Segment 2

SEGMENT 2 — This Document (Pages 51–100)

Section 8 — Operational Data Handling Standards

8.1 The Data Handling Obligations — A Practical Framework
8.2 Data in Transit — Secure Transmission Standards
8.3 Data at Rest — Storage, Encryption, and Access Control
8.4 Data in Use — Screen, Conversation, and Working Environment Standards
8.5 Data on Portable Media and Remote Devices
8.6 Printing, Physical Documents, and Secure Disposal

Section 9 — Data Handling by Context — Four Principal Processing Environments

9.1 HR and Employment Data — Specific Handling Standards
9.2 Client and Engagement Data — Specific Handling Standards
9.3 Marketing, Recruitment, and External Communications Data
9.4 IT Systems, Infrastructure, and Operational Data

Section 10 — Personal Data Breach Management

10.1 What Constitutes a Personal Data Breach
10.2 Breach Detection — Signals, Sources, and Employee Reporting Obligations
10.3 Breach Assessment — Severity Classification and Triage
10.4 Breach Containment — Immediate Response Actions
10.5 Breach Notification — DPBI and Data Principal Obligations
10.6 Post-Breach Review and Remediation
10.7 The Breach Register and Regulatory Reporting Record

Section 11 — Third-Party Data Processor Management

11.1 Identifying and Classifying Data Processors
11.2 Data Processor Due Diligence Requirements
11.3 Data Processing Agreement — Mandatory Provisions
11.4 Ongoing Processor Oversight — Audit Rights and Monitoring
11.5 Sub-Processing — Authorisation and Flow-Down Obligations

Section 12 — Employee Monitoring — Lawful Bases and Limits

12.1 The Principles Governing Workplace Monitoring
12.2 IT Systems and Network Monitoring
12.3 Building Access and Physical Security Systems
12.4 Productivity and Performance Monitoring in Hybrid Work
12.5 Communications Monitoring — Email, Messaging, and Calls

Section 13 — Data Retention and Deletion Framework

13.1 The Retention Principles — Why Keeping Data Costs More Than Deleting It
13.2 The Data Retention Schedule — All Principal Categories
13.3 Deletion Procedures — Technical and Administrative Standards
13.4 Legal Holds — When Deletion Must Be Suspended
13.5 Retention Compliance — Annual Deletion Audit

SEGMENT 3 (Pages 101–150)

14–18 Cross-Border Transfers · Sector Obligations · Privacy by Design · Enforcement · Appendices A–H

8. Operational Data Handling Standards

8.1 The Data Handling Obligations — A Practical Framework

The foundational framework in Segment 1 — the statutory basis, the lawful grounds for processing, the data classification scheme — is the 'why' and 'what' of data privacy at Arjun Technologies. This section is the 'how': the specific, practical standards that govern how personal data is handled in the course of everyday professional work. Every standard in this section is derived from the classification scheme in Segment 1, Section 6 — the appropriate handling standard for any piece of personal data is determined primarily by its classification. CONFIDENTIAL personal data requires one level of handling care; RESTRICTED personal data (which includes all special category personal data) requires a higher level still.

The data handling standards apply in three data states — data in transit (being transmitted between systems, individuals, or organisations), data at rest (stored in a system, database, file, or physical record), and data in use (being actively accessed, viewed, or processed by an individual). Each data state presents different risk profiles and requires different protective measures. An employee who understands and consistently applies the standards for each data state will, in the overwhelming majority of situations, be handling personal data in accordance with this policy without needing to consult the policy document for each individual handling decision.

8.2 Data in Transit — Secure Transmission Standards

Data in transit is the most vulnerable data state — data moving between systems, between individuals, or between the company and external parties is exposed to interception, misdirection, and inadvertent disclosure in ways that data held securely at rest is not. The standards below apply to all transmission of personal data, regardless of the communication channel used.

Channel / Method	INTERNAL USE ONLY Data	CONFIDENTIAL Personal Data	RESTRICTED Personal Data	Prohibited in All Cases
Company email (internal)	Permitted. Standard email channel is adequate for internal-use-only data.	Permitted where recipient is authorised. Do not CC non-essential recipients. No use of auto-complete for recipient selection — verify address before sending.	Permitted only to authorised HRBP, Legal, Finance, or IT Security roles with a specific need. Encryption in transit is applied automatically by company email servers.	Sending to personal email. Blind copying external parties without authorisation.
Company email (external — to clients, partners, or third parties)	Permitted where the external recipient is an authorised business contact.	Permitted where: recipient is authorised under a DPA or NDA; the transmission is necessary for the stated business purpose; no unnecessary data is included. Use secure attachment handling (password protect files containing personal data where client systems do not provide encryption).	Requires DPO notification before first transmission of RESTRICTED data to an external party. Encryption mandatory — use company-approved secure file sharing platform, not email attachments for large or sensitive datasets.	Sending to unverified external addresses. Using personal email accounts for any work data. Sending bulk personal data extracts without Legal team approval.
Messaging platforms (Teams, Slack)	Permitted for work communication.	Sensitive details should not be transmitted through messaging platforms except in private/encrypted channels. Prefer email for anything requiring a documented record.	Not permitted via messaging platforms. Use secure email or approved secure file sharing only.	Sending personal data via WhatsApp personal accounts, SMS, or any non-company messaging platform.

Channel / Method	INTERNAL USE ONLY Data	CONFIDENTIAL Personal Data	RESTRICTED Personal Data	Prohibited in All Cases
Physical mail and courier	Not typically used for digital data. Applicable for physical documents.	Permitted for physical documents containing confidential personal data — use sealed envelopes, recorded delivery, and addressee-only delivery.	Registered/tracked mail with addressee-only delivery. Never leave physical RESTRICTED documents on desks or in open mail trays.	Sending physical documents containing sensitive personal data by unrecorded post.
File sharing (SharePoint, OneDrive, approved platforms)	Permitted using company-managed platforms.	Set folder/file permissions to limit access to authorised individuals. Do not use general department folders for confidential personal data.	Create restricted-access folders with individually named access permissions. DPO approval for sharing RESTRICTED data with external parties via shared platforms.	Using personal cloud storage (personal Google Drive, Dropbox, iCloud) for any work personal data.
VPN-encrypted remote access	Required for accessing any internal system from outside the company network.	Company systems must be accessed via VPN when working outside the office. HRMS, SAP, and all internal systems require VPN.	VPN is mandatory. MFA is mandatory. No access to RESTRICTED data from unsecured networks even with VPN unless on a company-managed device.	Accessing internal systems without VPN from public networks.

8.3 Data at Rest — Storage, Encryption, and Access Control

Personal data at rest — stored in databases, file systems, cloud storage, physical records, and any other persistent storage medium — must be protected against unauthorised access, accidental exposure, and loss. The primary protective measures are access control (limiting who can access stored personal data to those with a genuine need), encryption (making stored data unreadable to those who access storage media without authorisation), and secure disposal (ensuring that personal data is properly destroyed when it is no longer required to be retained).

Storage Location	Classification Permitted	Encryption Standard	Access Control Standard	Backup and Recovery
HRMS (personal data of employees)	CONFIDENTIAL and RESTRICTED employee personal data.	Encrypted at rest using AES-256. Data in transit between HRMS and user browsers is TLS 1.2+ encrypted.	Role-based access control — employees access their own data; HRBPs access their business unit; Finance accesses payroll fields; IT Security and DPO have audit access. Line managers cannot access salary, health, or disciplinary data fields.	Daily automated backup to a geographically separated location. RPO: 4 hours. RTO: 8 hours.
SAP / ERP (financial personal data)	CONFIDENTIAL and RESTRICTED financial personal data (bank details, salary, tax records).	AES-256 at rest. TLS 1.2+ in transit.	Finance team with field-level access controls. Payroll accessible to payroll operators only. Salary data not accessible to HR Business Partners via ERP (HR compensation visible in HRMS only).	Daily backup. Financial data specifically subject to 7-year retention under tax law.
SharePoint / OneDrive (company file storage)	INTERNAL USE ONLY and CONFIDENTIAL. RESTRICTED data requires DPO-approved restricted-access workspace.	Encrypted at rest by Microsoft. Additional file-level encryption required for RESTRICTED data.	Department-level access for INTERNAL data. Named individual access for CONFIDENTIAL personal data folders. DPO approval for RESTRICTED data storage on SharePoint.	Microsoft-managed backup with 180-day version history.

Storage Location	Classification Permitted	Encryption Standard	Access Control Standard	Backup and Recovery
Employee endpoint devices (laptops, mobiles)	INTERNAL USE ONLY for temporary working files. CONFIDENTIAL and RESTRICTED data must not be stored locally on endpoint devices beyond the duration of the working session.	Full-disk encryption mandatory on all company-managed devices (BitLocker for Windows; FileVault for macOS; MDM-enforced encryption for mobiles).	MDM-enrolled devices only. Lost/stolen device remote wipe capability through MDM. MFA required for device unlock.	Cloud-synced working files. No local-only storage of personal data except encrypted temporary working files deleted at session end.
Physical records (paper documents, physical media)	All classifications — physical records are governed by the same classification scheme as digital records.	No digital encryption applicable. Physical security required: locked cabinets for CONFIDENTIAL; locked and logged access for RESTRICTED.	CONFIDENTIAL physical records in locked drawers or cabinets when not in active use. RESTRICTED physical records in locked, access-logged secure storage. Clean desk policy applies.	Offsite secure storage for archived physical records with retention period. Secure destruction at end of retention period.
Third-party cloud services (client systems, SaaS tools on approved list)	As permitted by the Data Processor due diligence and DPA in place for the service.	Encryption standards confirmed in data processor due diligence. Minimum AES-256 at rest required for any service holding CONFIDENTIAL or RESTRICTED data.	Access control confirmed in DPA. Company retains ability to audit and manage access. Data segregation from other customers confirmed.	Backup and recovery terms confirmed in DPA. SLA and RTO/RPO for personal data availability.

8.4 Data in Use — Screen, Conversation, and Working Environment Standards

Personal data in use — being actively accessed, displayed on a screen, discussed in a conversation, or worked on in a document — is vulnerable to incidental or inadvertent exposure to unauthorised individuals. The open-plan, hybrid, and client-facing nature of much of the company's work creates specific risks in this data state that must be actively managed.

Situation	Required Conduct	Prohibited Conduct
Working on personal data at a shared office desk	Use a privacy screen where the data is CONFIDENTIAL or RESTRICTED and others could read it from nearby desks. Lock screen immediately when leaving the desk even briefly (Win+L / Cmd+Ctrl+Q).	Leaving personal data visible on an unattended screen. Working on RESTRICTED data (salary, health records) in an open-plan area without a privacy screen.
Working on personal data in a coffee shop, co-working space, or public location	CONFIDENTIAL personal data may only be worked on from public locations on a company-managed device with a VPN. Use a privacy screen. Do not display names, salaries, or other identifiable information on a screen visible to others.	Working on RESTRICTED personal data in any public location. RESTRICTED data may only be accessed from the office, a client site with appropriate security, or a private residence with a locked working area.
Discussing personal data in a meeting or call	Use a private meeting room for any meeting involving discussion of CONFIDENTIAL or RESTRICTED personal data. On video calls: check who can hear before discussing personal data. Do not name individuals when a general reference would serve the purpose.	Discussing salary grades, health conditions, disciplinary matters, or other personal data in an open-plan area, a shared meeting room with a glass wall visible to passing colleagues, or on a speakerphone in a shared space.

Situation	Required Conduct	Prohibited Conduct
Presenting data in meetings (slides, shared screen)	Remove or redact personal identifiers from presentation materials unless the specific individuals are the subject of the meeting. Use anonymised or aggregated data for analytical presentations where individual identification is not necessary.	Projecting screens showing full employee lists with salary data, performance ratings, or other personal data in a meeting room where the attendees do not all have authorisation to view that data.
Working on personal data during a commute	INTERNAL USE ONLY data may be worked on during a commute on a company device with a screen lock ready. CONFIDENTIAL data: only if using a privacy screen and in a private seating area.	Working on CONFIDENTIAL or RESTRICTED personal data on a train or bus in close proximity to other passengers without a privacy screen.

8.5 Data on Portable Media and Remote Devices

Portable media — USB drives, external hard drives, SD cards, and other removable storage — is one of the highest-risk vectors for personal data loss and breach. A single USB drive lost in a taxi or left in a cafe can contain thousands of individuals personal data. The company's approach to portable media is restrictive: personal data should not be stored on portable media at all in normal operations, because the approved company systems (HRMS, SharePoint, OneDrive, SAP) provide secure, access-controlled, and backed-up storage that removes the need to move personal data to portable media. Where there is a genuine operational need that cannot be met by the standard systems, the DPO must approve the use and the media must be encrypted.

Portable Media Type	Permitted Use	Required Conditions	Prohibited Use
USB flash drives	Approved encrypted USB drives only. For temporary transfer of non-personal data or personal data with DPO approval.	Company-issued encrypted USB only. Personal USB drives prohibited. Data deleted from USB immediately after transfer is complete.	Storing personal data on personal USB drives. Leaving USB drives containing personal data unattended or unsecured.
External hard drives	Approved encrypted external drives for specific backup or large-file transfer needs. DPO approval required for any personal data storage.	Encrypted device. Stored securely — not in a bag or car. Deleted or returned to IT after use.	Using personal external hard drives for work data. Retaining external drives with personal data beyond the specific approved purpose.
Personal mobile phones and tablets	Personal devices must not be used to access, store, or process CONFIDENTIAL or RESTRICTED personal data. INTERNAL USE ONLY data may be accessed on a personal device via the HRMS mobile app only (which does not download data to the device).	HRMS mobile app is MDM-enrolled and does not store data locally. Access via app only — no screenshots of personal data on personal devices.	Photographing screens showing personal data with a personal phone. Accessing HRMS on a personal device outside the approved app.
Printed documents taken off-site	Physical documents containing personal data should not be taken outside the office except where strictly necessary for a specific client or operational purpose.	Documents taken off-site must be in a sealed envelope or folder. Returned or securely destroyed immediately after use. Never left in a car, public transport, or unattended bag.	Taking printed employee lists, salary data, or medical records off-site without a specific operational need and manager authorisation.

8.6 Printing, Physical Documents, and Secure Disposal

The company operates a print-minimal culture — personal data should be kept in digital form wherever possible, because physical documents are harder to track, harder to access-control, and harder to securely delete than digital records. Where printing is genuinely necessary for a specific operational purpose, the following standards apply. Physical documents containing personal data must be collected from the printer immediately — not left in the output

tray to be collected by anyone who passes. The secure print release functionality available on all company printers (requiring the user to authenticate at the printer before the document is released) must be used for any document containing CONFIDENTIAL or RESTRICTED personal data.

Secure disposal of physical documents containing personal data is mandatory at the end of the document's useful life. The company provides confidential waste bins and cross-cut shredders in all office locations for this purpose. Documents containing CONFIDENTIAL personal data must be disposed of via the confidential waste service — not in general waste bins or recycling. Documents containing RESTRICTED personal data must be cross-cut shredded in the office rather than placed in the confidential waste service. The facilities management team at each office location manages the confidential waste collection contract and can confirm the collection schedule and the approved disposal partner.

9. Data Handling by Context — Four Principal Processing Environments

9.1 HR and Employment Data — Specific Handling Standards

Employment data is the most consistently sensitive category of personal data that the majority of employees interact with, because it includes salary details, performance assessments, health information, disciplinary records, and other information whose inappropriate disclosure could cause real harm to colleagues. The standards below apply to all employees who access or handle employment data in the course of their work — which primarily means HR Business Partners, the Finance and payroll team, and managers accessing performance data in HRMS.

Employment Data Category	Who May Access	Permitted Uses	Strictly Prohibited
Salary and compensation (individual level)	Finance payroll team. VP-HR. HRBP (salary band range — not individual salary). CFO. CEO.	Payroll processing. Statutory deductions. Individual salary reviews with appropriate authorisation. Compensation benchmarking (anonymised and aggregated for salary surveys).	Line managers accessing individual direct reports' salary figures. Sharing salary information between colleagues. Including individual salary data in meeting materials visible to non-authorised attendees.
Performance ratings and assessment records	HRBP. Line manager (own team). BU Head (own unit). VP-HR. CEO for Band 7+.	Performance management process per the PMP. Calibration sessions (current year ratings). Talent review (current year + prior year). Promotion decisions.	Sharing an individual's performance rating with colleagues who are not their manager or HRBP. Including named performance ratings in presentations visible to non-authorised individuals.
Health and medical data (sick leave records, medical certificates, OH reports)	HRBP only. DPO for privacy incidents. VP-HR for significant cases. Legal for employment tribunal matters.	Leave management. Reasonable adjustment assessment. Long-term sick leave management. Occupational health referrals.	Line manager access to medical certificate content. Discussing health conditions in team meetings. Including health information in performance documents.
Disciplinary records (active and historical)	HRBP. Line manager (own team, for active matters). Legal team. VP-HR.	Active disciplinary process. Background check within the company. Reference for internal promotion where relevant and legally permissible.	Sharing disciplinary history with colleagues outside the process. Including disciplinary information in general performance documentation.
Recruitment and candidate data	TA team. Hiring manager (for candidates for their specific role). HRBP. DPO.	Recruitment process for the specific role. Pre-employment checks. Candidate communication.	Sharing candidate CVs or interview assessments with colleagues not involved in the hiring decision. Retaining rejected candidate data beyond the permitted retention period without candidate consent for a future role.
Emergency contact and next-of-kin data	HRBP. Facilities (for building safety). Line manager (for genuine emergencies).	Emergency notification only. Building safety. Payroll (next-of-kin for death-in-service purposes).	Using emergency contact information for any purpose other than an actual emergency. Sharing next-of-kin contact details with third parties without authorisation.

9.2 Client and Engagement Data — Specific Handling Standards

Client engagement data encompasses two distinct categories of personal data: the personal data of the client's own employees and representatives (contact details, meeting notes, account information held in the CRM); and the personal data of the the client end-users or customers processed within the systems the company builds or operates on the client's behalf. The handling standards for these two categories are materially different because the company's role is different: for client contact data, the company is a Data Fiduciary processing for its own CRM purposes; for end-user data within client systems, the company is a Data Processor operating under the client's instructions and the terms of the DPA.

Situation	Standard — Company as Data Fiduciary (Client Contact Data)	Standard — Company as Data Processor (End-User Personal Data within Client Systems)
Accessing personal data	CRM access restricted to account team and management. HRBP for any HR-related client contact data. Principle of minimum necessary access.	Access to end-user personal data restricted to the specific team members whose work on the engagement requires it. Access provisioned per the project access matrix. No access beyond the minimum necessary for the specific task.
Using personal data outside the engagement context	Client contact data may be used for relationship management, communication, and reporting to the client. May not be used for marketing without separate consent.	End-user data processed within client systems may not be used for any purpose other than the specific services contracted with the client. No use of client end-user data for company analytics, AI training, benchmarking, or any other company purpose.
Sharing personal data with colleagues	Client contact data shared on need-to-know basis within the account team. Not shared outside the account team without account manager approval.	End-user data not shared outside the specific project team. Not shared with other business units or client teams without explicit client instruction and DPA coverage.
Storing personal data at engagement end	Client contact data in CRM retained per the CRM data retention schedule. Former client contacts: retained for 3 years post-relationship then deleted unless ongoing reason.	End-user data in client systems: deleted or returned to the client at engagement end as specified in the DPA. Company retains no copy of client end-user personal data after engagement end, except where required by a specific legal hold.
Breach or security incident affecting client data	Report to DPO immediately as for any breach. DPO assesses company notification obligations AND advises on notification to the client (who is the Data Fiduciary for end-user data) so they can assess their own DPDP Act notification obligations.	Report to DPO immediately. DPO notifies client (as Data Fiduciary) per the DPA notification timeline. DPO assesses whether the company has any direct DPBI notification obligations as a processor. Support client's notification process.

9.3 Marketing, Recruitment, and External Communications Data

Marketing and external communications generate personal data — contact details of prospects, website visitor data, event attendees, and the recipients of the company's thought leadership and business development communications. This personal data is processed primarily on a consent basis, which means the consent framework standards in Segment 1, Section 5.1 must be rigorously applied. Any marketing communication sent to an individual who has not given valid consent — or who has withdrawn consent — is an unlawful processing act under the DPDP Act and a potential violation of the Telecom Regulatory Authority's unsolicited commercial communications regulations.

Processing Activity	Lawful Basis	Consent Mechanism	Opt-Out / Withdrawal	Retention
Marketing email to external contacts who opted in through website or event registration	Consent — specific, informed, freely given via the website opt-in form or event registration consent checkbox.	Distinct checkbox on the website contact form or event registration: "I would like to receive updates and insights from Arjun Technologies." Not pre-ticked.	Every marketing email must include a prominent, one-click unsubscribe link. Unsubscribes actioned within 5 working days. Unsubscribe list maintained in marketing platform.	Contact retained in marketing platform for 3 years from last interaction or until unsubscribe, whichever is earlier.
LinkedIn outreach to potential prospects or candidates	Deemed consent — contact details publicly available on LinkedIn, outreach for a relevant professional purpose (genuine role or service match).	No consent form — deemed consent applies. Message must be personalised, relevant, and single outreach only unless the individual responds positively.	Individual may request to not be contacted again. Remove from outreach list immediately on any negative or opt-out response.	Contact details not entered into CRM unless the individual responds positively and gives consent for further contact.

Processing Activity	Lawful Basis	Consent Mechanism	Opt-Out / Withdrawal	Retention
Recruitment database — candidate data	Consent for speculative retention beyond the specific role. Contract for active role recruitment.	Candidate consent for retention in the talent pool is obtained via the recruitment application form: "May we retain your details for future suitable roles?" Separate from consent to process for the specific role.	Candidate may withdraw consent for talent pool retention at any time. Data deleted within 30 days of withdrawal request.	Active candidate: retained for 2 years post-process. Talent pool: 2 years from consent date unless refreshed.
Website analytics (Google Analytics or equivalent)	Consent — via cookie consent banner. Analytics cookies are non-essential and require explicit consent.	Cookie consent banner on website: separate consent toggles for essential, functional, analytics, and marketing cookies. Analytics consent not pre-ticked.	Cookie preference centre accessible at any time from the website footer. Consent withdrawal takes effect immediately — analytics data no longer collected.	Anonymised analytics data: 26 months per standard analytics platform settings. Personal data elements (IP addresses) anonymised at collection.

9.4 IT Systems, Infrastructure, and Operational Data

IT operational data — access logs, system event logs, network traffic logs, authentication records, and similar technical records — contains personal data in the form of user identifiers, IP addresses, timestamps of individual actions, and other data elements that are linked to or can identify specific employees or system users. This data is processed primarily for the legitimate purposes of security monitoring, fraud prevention, system management, and incident investigation — the same purposes that underpin the employee monitoring provisions in Section 12. The handling standards for IT operational data reflect both the security purpose and the data privacy obligations that arise from the personal data it contains.

IT Data Type	Classification	Primary Purpose	Retention	Access	Data Privacy Obligation
User authentication logs (login/logout times, MFA events, failed access attempts)	CONFIDENTIAL	Security monitoring. Incident investigation. Access anomaly detection.	90 days rolling. Extended to 12 months for accounts under active security investigation.	IT Security team. DPO for privacy-related investigations.	Used only for security and fraud prevention purposes. Not used for general performance monitoring or productivity assessment unless a specific security incident investigation requires it.
Email metadata logs (sender, recipient, subject line, size — not content)	CONFIDENTIAL	Email security scanning. Data loss prevention. Compliance monitoring.	90 days rolling for metadata. Content not logged in standard operation (see Section 12.5 for content monitoring conditions).	IT Security team. Legal team for litigation/regulatory matters under Legal Hold.	Subject line information is personal data where it identifies individuals or contains personal information. Accessed only for security, compliance, or legal purposes.
Network traffic logs (IP connections, bandwidth, site categories)	CONFIDENTIAL	Security monitoring. Bandwidth management. Blocking of prohibited content categories.	30 days rolling.	IT Security team only.	Aggregate network data used for capacity planning. Individual-level data accessed only for security investigation with manager and HRBP notification.

IT Data Type	Classification	Primary Purpose	Retention	Access	Data Privacy Obligation
Building access records (entry/exit timestamps by access card)	CONFIDENTIAL	Physical security. Health and safety (emergency headcount). Attendance verification where required.	90 days rolling. Retained for 12 months for any location where a security incident is under investigation.	Facilities management and IT Security. HR for attendance dispute resolution. Legal for investigations.	Not used as primary attendance management tool. HR uses HRMS attendance module. Building access data accessed for HR purposes only where HRMS record is in dispute.
System audit trails (who accessed what data, when, and from where)	RESTRICTED for audit trails relating to RESTRICTED data systems (HRMS health data fields, SAP salary data).	Accountability and compliance for access to sensitive personal data. Breach investigation.	12 months minimum for RESTRICTED data system audit trails. 7 years for financial system audit trails (statutory).	DPO. IT Security. Legal team. External auditors under audit rights.	Access logs for RESTRICTED data systems reviewed monthly by DPO for anomalous access patterns. Anomalies investigated.

10. Personal Data Breach Management

10.1 What Constitutes a Personal Data Breach

A personal data breach is any incident that results in the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data. The definition is deliberately broad — it encompasses not only deliberate attacks and hacking incidents, but also the everyday accidents that are statistically more common and account for a large proportion of all reported breaches: an email sent to the wrong recipient, a laptop left on public transport, an incorrectly configured cloud storage bucket, a USB drive dropped in a car park, or a printed salary schedule left on a desk.

The critical insight that shapes the company's approach to breach management is that the obligation to investigate and potentially notify is triggered not by confirmation that a breach has occurred, but by awareness that a breach may have occurred. An employee who suspects that personal data may have been inadvertently disclosed has the same reporting obligation as one who knows it has been — the assessment of whether a reportable breach has occurred is the DPO's task, not the discovering employee's. Every minute of delay between a potential breach being discovered and the DPO being notified reduces the time available to contain, assess, and notify within the regulatory timelines.

Incident Type	Is This a Personal Data Breach?	Severity Indicator	Report To
Email with employee salary data sent to the wrong internal recipient	Yes — unauthorised disclosure within the company. Classification: RESTRICTED data breach.	Medium — unauthorised internal disclosure. Recipient should not have had access.	IT Security + DPO immediately.
Email with employee personal data sent to an external email address (wrong person)	Yes — unauthorised external disclosure. Potentially High severity.	High — external party now has employee personal data without any lawful basis.	DPO immediately. DPBI notification assessment required.
Company laptop containing client system access credentials lost or stolen	Yes — potential unauthorised access to client systems and personal data.	High — access credentials at risk. Client personal data potentially accessible.	DPO + IT Security + Line Manager immediately. Client notification assessment begins.
HRMS system misconfiguration briefly allowed employees to view colleagues' salary data	Yes — unauthorised internal access to RESTRICTED personal data.	High — RESTRICTED data accessed without authorisation.	IT Security + DPO immediately. DPBI notification assessment. Affected employees may need to be notified.
A phishing email obtained an employee login, and the compromised account sent emails to 10 contacts before IT contained it	Yes — unauthorised account access and potential data access.	High — scope of data accessed by attacker requires investigation before classification is final.	IT Security + DPO within 1 hour of detection.
An employee accidentally deletes a client data export file (no backup)	Potentially yes — accidental destruction of personal data.	Depends on backup availability. If data is unrecoverable: High (data loss).	IT Security + DPO within same day.
A former contractor's access credentials are not revoked on departure	Near-breach / risk — not a breach yet if not accessed.	Medium risk — potential for unauthorised access if the former contractor uses residual credentials.	IT Security to revoke immediately. DPO notified if there is evidence of access after the departure date.

10.2 Breach Detection — Signals, Sources, and Employee Reporting Obligations

Data breaches are detected through multiple channels. Automated detection through IT security monitoring systems — SIEM alerts, DLP tools, access anomaly detection, email content scanning — catches a significant proportion of technically complex incidents. But many of the most common breach types — misdirected emails, lost physical documents, inadvertent verbal disclosures — can only be detected by the employees who are party to them. The company's breach detection capability is therefore only as good as its reporting culture — which requires that employees report suspected breaches immediately, without fear that reporting will result in personal consequences where the breach was an honest mistake made in good faith.

The company's position is explicit and non-negotiable: an employee who reports a suspected data breach in good faith will not be subject to disciplinary consequences solely as a result of the report, even if the breach resulted from an error on their part. A genuine mistake that is reported immediately is a security event to be managed. A genuine mistake that is concealed is a compliance failure and a Code of Conduct integrity violation that may result in disciplinary action for the concealment — not the original mistake. Every employee must understand this distinction clearly.

10.3 Breach Assessment — Severity Classification and Triage

Severity Level	Definition and Criteria	Examples	Response Timeline	DPBI Notification Likely?
CRITICAL	Large-scale breach of RESTRICTED personal data. Sensitive data of 100+ individuals compromised. Likely significant harm. Suspected malicious external actor.	Ransomware attack on HRMS. Mass exfiltration of client end-user personal data. Medical records of employees exfiltrated.	Immediate CEO, Board, and Legal team notification. DPO leads response within 1 hour. DPBI notification expected.	Yes — notification to DPBI within 72 hours of confirmation. Likely affected individual notification also required.
HIGH	Breach of RESTRICTED data (any scale) or CONFIDENTIAL data affecting 50+ individuals. External disclosure of sensitive personal data. Significant potential for harm.	Laptop containing employee salary spreadsheet lost. Client customer personal data accidentally shared externally. Access credentials compromised.	DPO notified within 4 hours. Full assessment within 24 hours. Legal team involved. Client notification (if client data affected) initiated.	Yes for RESTRICTED data or large-scale CONFIDENTIAL breach. Legal team confirms per specific facts.
MEDIUM	Breach of CONFIDENTIAL personal data affecting fewer than 50 individuals. Internal disclosure without authorisation. Limited external exposure.	Email with employee performance data sent to wrong internal recipient. Physical HR documents left in an unsecured area. Small-scale misdirected email with non-sensitive personal data.	DPO notified within 24 hours. Assessment within 48 hours. IT Security implements containment. Line manager and HRBP informed.	Unlikely for typical medium-severity incidents. DPO assesses case by case.
LOW	Minor incident. INTERNAL USE ONLY data inadvertently disclosed internally. No sensitive personal data involved. Negligible harm potential.	Internal email with general project information sent to a slightly wider distribution than intended. System log containing non-sensitive metadata briefly accessible to wrong team.	IT Security notified within 48 hours. DPO informed at weekly briefing. Operational resolution by IT Security.	No — below the notification threshold.

10.4 Breach Containment — Immediate Response Actions

Containment is the immediate priority in the first hours following breach detection — before notification, before investigation, before any public communication. Containment limits the ongoing exposure of personal data and reduces the ultimate scale and harm of the incident. The specific containment actions depend on the nature of the breach, but the following table sets out the standard immediate response actions for the most common breach types.

Breach Type	Immediate Containment Actions	Owner	Timeline
Misdirected email (sent to wrong person)	Contact the unintended recipient immediately. Request deletion of the email without reading further. Obtain confirmation of deletion in writing. If external recipient does not confirm deletion: escalate to DPO for further action.	Discovering employee (contacts recipient). DPO (if external recipient or if deletion not confirmed).	Within 1 hour of discovery.
Lost or stolen device	Remote wipe through MDM immediately. Revoke any active sessions from the lost device. Change all passwords for accounts accessible from the device. Assess what personal data was stored on the device (if any, despite policy).	IT Security (remote wipe and session revocation). Discovering employee (reports to IT Security).	Within 2 hours of discovery or device reported as lost/stolen.
Compromised user credentials (password breach or phishing)	Immediately disable the compromised account. Force password reset. Revoke all active sessions. Review access logs from the compromised account for signs of data access or exfiltration.	IT Security team (account disabling and log review). Affected employee (password reset).	Within 1 hour of detection.
Unauthorised system access (external attacker)	Isolate affected systems from the network where technically feasible without destroying evidence. Preserve logs. Engage IT Security incident response. Consider engaging external incident response firm.	IT Security team. DPO. CEO (for CRITICAL incidents). External IR firm if required.	Immediately on detection. CEO informed within 2 hours of CRITICAL designation.
Physical document loss or theft	Identify the scope of the physical document (what personal data, whose data). Assess whether the document is recoverable. Notify building security or the police if the loss is in a public location.	Discovering employee (reports to DPO and line manager). DPO (assesses notification need). Building security/police if applicable.	Within same day of discovery.

10.5 Breach Notification — DPBI and Data Principal Obligations

The DPDP Act 2023 establishes mandatory breach notification obligations for Data Fiduciaries. The specific notification timelines will be prescribed in the DPDP Rules (expected to follow the international standard of 72 hours for regulatory notification). The company operates on the basis that it must be able to meet the 72-hour timeline — which means the DPO must be informed within hours of a potential breach being discovered, not days. Notification to the Data Protection Board of India is required when the breach is likely to result in significant harm to Data Principals. The DPO makes this assessment based on the breach severity classification, the nature of the personal data involved, and the specific circumstances of the incident.

Notification Recipient	Trigger	Content Required	Timeline (Company Standard)	Owner
Data Protection Board of India (DPBI)	Breach likely to result in significant harm to Data Principals. CRITICAL and HIGH severity breaches involving RESTRICTED data should be presumed to meet this threshold unless the DPO determines otherwise.	Nature of breach. Categories and approximate number of Data Principals affected. Likely consequences of the breach. Measures taken or proposed to address the breach. Contact details of the DPO.	Within 72 hours of the Data Fiduciary becoming aware of the breach. Initial notification may be incomplete if full facts are not available — followed up with complete notification.	DPO. General Counsel approves notification content. CEO informed before notification is sent for CRITICAL and HIGH breaches.

Notification Recipient	Trigger	Content Required	Timeline (Company Standard)	Owner
Affected Data Principals	Required where the breach is likely to result in significant harm to the specific individuals affected. DPO determines per incident.	Description of the breach in plain language. Categories of personal data involved. Likely consequences for the individual. Steps taken to address the breach. Contact details of DPO for further information.	As soon as reasonably practicable after DPBI notification — the Rules will specify the timeline. Company standard: within 72 hours of DPBI notification for large-scale individual notification.	DPO drafts communication. Legal team reviews. CEO approves for CRITICAL incidents.
Client (where client end-user data is involved — company as Data Processor)	Mandatory notification to the client (as Data Fiduciary) per the DPA terms. The client then assesses their own DPBI notification obligation.	Breach description. Data categories and scale. Containment actions. Company investigation status. Contact details of DPO.	DPA typically requires 24–48 hour notification to the client. Company standard: notify client within 24 hours of confirming a breach has occurred.	DPO. Account manager co-ordinates client communication with DPO.
CEO and Board	For CRITICAL and HIGH severity breaches. Board informed at next scheduled meeting unless severity warrants immediate Board notification.	Summary of breach, containment status, notification status, regulatory risk, reputational risk, and remediation plan.	CEO: within 4 hours of CRITICAL, 24 hours of HIGH. Board: within 72 hours of CRITICAL; next scheduled meeting for HIGH.	DPO and General Counsel brief CEO. CEO decides on Board notification timing.

10.6 Post-Breach Review and Remediation

Every breach at MEDIUM severity or above triggers a mandatory post-breach review conducted by the DPO in co-ordination with IT Security, the HRBP (where employee data is involved), the Legal team, and the relevant business unit. The review has two objectives: first, to understand the root cause of the breach and ensure that the specific vulnerability or behaviour that caused it has been addressed; and second, to identify whether the breach reveals a systemic gap in the company's data privacy controls that requires a broader remediation response beyond the specific incident.

The post-breach review is completed within 30 days of the breach being contained. Its output is a Breach Review Report that documents the timeline of the incident, the root cause analysis, the immediate containment and notification actions taken, and a Remediation Action Plan with specific actions, owners, and deadlines. The Remediation Action Plan is tracked by the DPO until all actions are closed. HIGH and CRITICAL breach review reports are presented to the Audit Committee at the next scheduled meeting after the breach.

10.7 The Breach Register and Regulatory Reporting Record

The DPO maintains a Breach Register that records every breach and suspected breach reported to the DPO, regardless of severity and regardless of whether the incident ultimately meets the threshold for external notification. The Breach Register is a confidential internal record — it is not publicly disclosed, but it is available for inspection by the Audit Committee, external auditors with appropriate authorisation, and regulators with legitimate inquiry rights. It is the company's primary evidence of its breach detection and response programme and is a critical document in any DPBI investigation.

11. Third-Party Data Processor Management

11.1 Identifying and Classifying Data Processors

A Data Processor is any third party — vendor, supplier, contractor, or service provider — that processes personal data on behalf of and under the instructions of Arjun Technologies in its capacity as a Data Fiduciary. The distinction between a Data Processor and a Data Controller/Fiduciary is the degree of independence in determining the purpose and means of processing: a processor acts only on instruction; a controller/fiduciary determines the purpose independently. Where the company shares personal data with a third party who processes it for their own independent purposes, that third party is not a processor — they are a joint controller or an independent controller, and the appropriate legal mechanism is a data sharing agreement, not a data processing agreement.

Third-Party Category	Role Classification	Examples	Legal Mechanism Required
Cloud infrastructure and SaaS providers who process data only on company instructions	Data Processor	AWS, Microsoft Azure (HRMS hosting), SAP (payroll processing), Salesforce (CRM).	Data Processing Agreement (DPA) per Section 11.3 standards.
Background verification partner (processes candidate and employee personal data per company instructions)	Data Processor	BGV provider engaged per the Onboarding SOP.	DPA. BGV consent form signed by the data subject (candidate/employee) is required.
Occupational health provider (processes employee health data per company referral)	Partially independent processor/controller — the OH provider has independent clinical responsibilities alongside the company referral purpose.	External OH firm engaged for fitness-to-work assessments.	Data sharing agreement + DPA hybrid. Legal team confirms per engagement.
Reference check providers (verify employment history on behalf of the company)	Data Processor	Third-party reference verification services.	DPA. Reference check consent from the candidate.
Analytics and BI tools (process anonymised or pseudonymised data per company instructions)	Data Processor if personal data involved. Independent if genuinely anonymised.	Tableau, Power BI, data analytics platforms processing employee or client analytics data.	DPA for any processing involving personal data. Anonymisation quality assessment by DPO for tools processing claimed anonymised data.
Marketing email platform (processes marketing contact list per company instructions)	Data Processor	Mailchimp, HubSpot, or equivalent.	DPA. Company retains control of the contact list and unsubscribe list. Processor cannot use the data for its own marketing.
Law firms and external counsel (process company data in legal matters)	Generally Data Controller for their own professional purposes. Data Processor for specific document review tasks.	External counsel engaged for employment tribunal matter or regulatory investigation.	Engagement letter with data confidentiality terms. DPA for specific document review engagements.

11.2 Data Processor Due Diligence Requirements

Before engaging any new data processor — or renewing an existing processor engagement where the scope of personal data processing has materially changed — the DPO must complete a Data Processor Due Diligence Assessment. This assessment is not a box-ticking exercise: it is a genuine evaluation of whether the proposed

processor provides sufficient guarantees about the technical and organisational security measures they will apply to personal data, and whether the company can in good faith rely on those measures to meet its own Data Fiduciary obligations.

Due Diligence Element	Assessment Standard	Minimum Acceptable	DPO Action if Standard Not Met
Information security certification	ISO 27001, SOC 2 Type II, or equivalent internationally recognised security certification.	For processors handling RESTRICTED personal data: ISO 27001 or SOC 2 Type II required. For CONFIDENTIAL data: certification strongly preferred.	Decline the engagement for RESTRICTED data without certification. Escalate to General Counsel for risk acceptance where CONFIDENTIAL data processor certification is absent.
Data processing agreement willingness	Processor must be willing to execute a DPA meeting the requirements in Section 11.3.	Full DPA execution is mandatory before any personal data is shared. Processors unwilling to execute a DPA cannot be engaged for any personal data processing.	Do not engage. No personal data sharing without a signed DPA.
Sub-processor disclosure	Processor must disclose all sub-processors who will process the personal data.	Full sub-processor list provided. Written consent mechanism for new sub-processors.	Require contractual commitment to notify of sub-processor changes. DPO reviews sub-processor list for adequacy.
Data location and cross-border transfer	Where the personal data will be stored and processed. Whether any cross-border transfer is involved.	India-hosted storage strongly preferred for RESTRICTED personal data. Cross-border transfers require DPO assessment against DPDP Act transfer provisions.	Decline or seek DPO-approved transfer mechanism for any cross-border transfer of RESTRICTED data until approved country list is published.
Breach notification capability	Processor must have a breach detection and notification programme capable of notifying the company within the DPA timeline.	Contractual commitment to notify within 24 hours of detection. Evidence of breach notification procedure.	No engagement without contractual breach notification obligation. Reject processors with no breach notification programme.
Access control and data minimisation	Processor limits access to the personal data to those of its personnel who require access for the processing purpose.	Evidence of role-based access controls. Principle of least privilege demonstrated.	Require contractual commitment to access control standards. DPO may conduct on-site audit for CRITICAL personal data processors.

11.3 Data Processing Agreement — Mandatory Provisions

Every data processor must execute a Data Processing Agreement before any personal data is shared. The company's standard DPA template (LEGAL-DPA-001-v3.1) contains the mandatory provisions listed below and has been reviewed for compliance with both the DPDP Act 2023 and GDPR processor requirements (for EU/UK client engagement contexts). Where a processor insists on using their own DPA template, the Legal team reviews it against the mandatory provisions below before agreeing to use it. A processor DPA that omits any mandatory provision must be supplemented with an addendum before execution.

DPA Provision	Mandatory Content	Basis in DPDP Act / GDPR
Processing instructions	The processor may only process the personal data as specifically instructed by the company. Any processing outside those instructions requires written authorisation from the company DPO.	DPDP Act processor obligations. GDPR Article 28(3)(a).
Confidentiality	Processor personnel with access to personal data are bound by confidentiality obligations.	GDPR Article 28(3)(b). DPDP Act security obligations.
Security measures	Processor must implement appropriate technical and organisational security measures. Minimum standard: encryption at rest and in transit, access controls, MFA for privileged access.	DPDP Act Section 8(5). GDPR Article 32.

DPA Provision	Mandatory Content	Basis in DPDP Act / GDPR
Sub-processing restrictions	Processor may not engage sub-processors without prior written consent. Sub-processors must be bound by the same DPA obligations.	GDPR Article 28(2) and (4). DPDP Act flow-down obligations.
Data subject rights assistance	Processor must assist the company in fulfilling Data Principal rights requests — providing data for access requests, enabling deletion for erasure requests.	GDPR Article 28(3)(e). DPDP Act Data Principal rights.
Breach notification	Processor must notify the company within 24 hours of becoming aware of any actual or suspected personal data breach involving company personal data.	GDPR Article 33(2). DPDP Act breach notification obligations.
Audit rights	The company has the right to audit the processor's compliance with the DPA, either directly or through an independent auditor, on reasonable notice.	GDPR Article 28(3)(h). DPDP Act accountability principle.
Return or deletion at engagement end	At the end of the processing relationship, the processor must return or delete all personal data and certify deletion in writing.	GDPR Article 28(3)(g). DPDP Act storage limitation.
Liability and indemnification	Processor is liable for damage caused by processing that is not in accordance with the DPA. Indemnification provisions for company liability arising from processor breach.	GDPR Article 82. DPDP Act liability provisions.

11.4 Ongoing Processor Oversight and 11.5 Sub-Processing

Executing a DPA does not conclude the company's processor management obligations — it creates a continuing oversight relationship. The DPO maintains a Processor Register listing all active data processors, the personal data categories they process, the DPA reference, the due diligence date, and the next review date. For processors handling RESTRICTED personal data, the review cycle is annual; for processors handling CONFIDENTIAL personal data, the review cycle is every two years. Review activities include: confirming that the certification remains current; reviewing any material changes to the processor's service scope or data handling; reviewing any breach or security incident notifications received from the processor; and confirming that the DPA remains appropriate for the current processing activities.

Sub-processing — the engagement by a processor of another processor to perform specific processing tasks — must be disclosed to the company in advance. The company's DPA requires processors to obtain written consent before engaging a new sub-processor. On receipt of a sub-processor notification, the DPO has 10 working days to approve or object. The grounds for objection are limited to legitimate data protection concerns about the proposed sub-processor — the company cannot arbitrarily withhold consent without a data privacy reason. All approved sub-processors are listed in the company's Processor Register as sub-processors of the primary processor.

12. Employee Monitoring — Lawful Bases and Limits

12.1 The Principles Governing Workplace Monitoring

Workplace monitoring — the systematic collection and analysis of data about employees' work activities — is a sensitive area that requires careful balancing of the company's legitimate operational interests (security, fraud prevention, performance management, client data protection) against employees' rights to privacy and dignity in the workplace. The DPDP Act 2023 and the established position of the European data protection authorities (which the company follows as international best practice for employment data) establish clear principles that govern when and how workplace monitoring is permissible.

The four governing principles are: necessity (monitoring must be necessary for a specific, legitimate purpose — not deployed simply because it is technically possible); proportionality (the intrusion into employee privacy must be proportionate to the benefit obtained — blanket monitoring of all employee activity is not proportionate where targeted monitoring would achieve the same security objective); transparency (employees must be informed, through this policy and the Employee Privacy Notice, what monitoring is conducted, for what purpose, and what data is collected — no covert monitoring is conducted except where it is specifically authorised for a serious criminal investigation); and purpose limitation (data collected through monitoring may only be used for the stated monitoring purpose — not for performance assessment, productivity measurement, or HR management functions that have their own data collection processes).

12.2 IT Systems and Network Monitoring

The company monitors its IT systems and networks for security purposes — to detect and respond to cybersecurity incidents, data breaches, malware, and other threats to the company's systems and data. This monitoring is conducted on the lawful basis of legitimate use for security and fraud prevention, and it is disclosed in the IT Acceptable Use Policy (IT-SEC-POL-005) that all employees sign at joining. Security monitoring does not extend to reading the content of employees' work-related communications as a matter of routine — the level of access required for security monitoring is at the network traffic and metadata level, not the content level, in normal operation.

Monitoring Type	Purpose	Data Collected	Employees Informed?	Access to Data	Limits
Network traffic monitoring (aggregate and flagged)	Cybersecurity — detect malware, data exfiltration, prohibited content access.	Aggregate bandwidth and connection data. Flagged events (access to blocked domains, unusually large data transfers).	Yes — IT AUP. This policy.	IT Security team only.	Individual-level network data accessed only where an automated alert flags a specific concern. Not used for general productivity monitoring.
Email security scanning (inbound and outbound)	Anti-malware, anti-phishing, data loss prevention (DLP for personal data keywords in outbound emails).	Metadata for all emails. Content scanning results (DLP flags). Quarantined items.	Yes — IT AUP. This policy.	IT Security for DLP alerts. Legal team for legal hold matters.	DLP flags are reviewed by IT Security for genuine security/compliance violations. Not used to monitor individual productivity or communication style.

Monitoring Type	Purpose	Data Collected	Employees Informed?	Access to Data	Limits
Access log monitoring (HRMS, SAP, SharePoint — who accessed what, when)	Accountability for access to personal data systems. Breach investigation.	User ID, timestamp, system, action (read/write/delete).	Yes — this policy.	DPO (RESTRICTED system logs monthly). IT Security for security investigations. Legal for investigations.	Not used for general HR performance monitoring. Accessed only for security investigations or DPO privacy audits.
Building access records	Physical security. Emergency headcount. Access anomaly detection.	Card swipe times and locations within the building.	Yes — Facilities security briefing at joining. This policy.	Facilities management. IT Security. HR for attendance disputes only.	Not used as primary attendance management tool. HR attendance managed through HRMS.

12.3–12.5 Physical Security, Productivity Monitoring, and Communications

Building access systems record entry and exit events using the access cards issued to all employees. This data is held for 90 days as described in Section 9.4 and is used for physical security and safety purposes only. The company does not use building access data as a primary attendance management tool — attendance is managed through the HRMS leave and attendance module, which reflects the self-reported and manager-approved attendance record. Building access data is accessed for HR purposes only where there is a specific dispute about attendance that the HRMS record cannot resolve.

The company does not conduct productivity monitoring — the systematic tracking of individual employees' work activity levels, screen time, application usage, or keystrokes — as a routine management practice. The performance management framework is based on OKR achievement and competency assessment, not on activity surveillance. Managers are expected to manage performance through observation, conversation, and documented evidence — not through surveillance data. Where a specific, documented performance concern requires additional evidence, the manager discusses the concern with the HRBP and the DPO before any enhanced monitoring is considered.

Communications monitoring — the review of the content of employees' work emails, messages, and calls — is not conducted as a routine practice. The company reserves the right to access communications on its systems in three specific circumstances: where a genuine criminal investigation has been notified to the company by law enforcement and a Legal Hold has been imposed; where a formal disciplinary investigation requires access to specific communications as evidence (and only after HRBP and Legal team authorisation); and where a data loss prevention alert has flagged a specific outbound communication for review (limited to the flagged communication, not a general review of the individual's communications). In all three cases, the DPO is notified before any communications content is accessed, and the access is logged.

13. Data Retention and Deletion Framework

13.1 The Retention Principles — Why Keeping Data Costs More Than Deleting It

Many organisations default to retaining personal data indefinitely because storage is cheap and deletion requires effort. This approach is wrong under data privacy law and wrong as a matter of risk management. Every day that personal data is retained beyond the point at which it is needed creates ongoing privacy risk — the risk that it could be breached, misused, or improperly accessed. The DPDP Act's storage limitation principle requires that personal data be retained only for as long as it is necessary for the stated purpose. Purposeless retention of personal data is itself a violation of the Act — it is not simply a practice the company has chosen to avoid; it is a legal obligation.

The retention schedule below is the company's documented assessment of the minimum retention period necessary for each personal data category — the minimum period required by statute, contract, or legitimate operational need. Where no statutory minimum applies, the retention period is set by the company's assessment of how long the data could reasonably be needed for the purpose for which it was collected. At the end of the retention period, personal data is deleted in accordance with the deletion procedures in Section 13.3 — except where a Legal Hold is in force, as described in Section 13.4.

13.2 The Data Retention Schedule — All Principal Categories

Personal Data Category	Retention Period	Legal / Operational Basis	Deletion Method	Who Triggers Deletion
Employee personnel records (name, address, employment history, contract)	Employment duration + 7 years	Income Tax Act records. Potential statutory claims limitation periods.	HRMS automated archival at employment end. Deletion after 7-year period by HRBP Operations.	HRBP Operations (annual deletion audit).
Payroll records (salary, deductions, TDS, PF contributions)	Financial year of payment + 7 years	Income Tax Act (Section 209 — 7-year retention for accounts and records).	SAP archival at year 7+. Deletion scheduled by Finance team with IT.	Finance Controller (annual).
Sick leave records (dates, duration — not medical detail)	Employment duration + 7 years	Potential employment tribunal claims. Disability discrimination claims.	HRMS archival. Deletion with personnel records.	HRBP Operations.
Medical certificates and occupational health reports	Employment duration + 7 years (medical detail may be needed for disability claims)	RPwD Act disability claims. Insurance claims.	Secure deletion from HRBP records. Not retained in general HR files.	HRBP (restricted access store).
Performance assessments and ratings	Employment duration + 7 years	Unfair dismissal claims. Discrimination claims. Potential references.	HRMS archival. Deletion per standard records schedule.	HRBP Operations.
Disciplinary records (active)	Employment duration. Historical records: 7 years post-final outcome.	Employment tribunal claims.	HRMS archival. Deletion per standard schedule.	HRBP Operations.
Recruitment — successful candidates	See employee records above (record becomes part of personnel file on joining).	Employment relationship.	As for personnel records.	HRBP Operations.

Personal Data Category	Retention Period	Legal / Operational Basis	Deletion Method	Who Triggers Deletion
Recruitment — unsuccessful candidates (with consent to retain)	2 years from application date or last interaction, whichever is later.	Consent for future role consideration.	TA system automated deletion. Manual review at 2-year mark.	TA team (automated + annual audit).
Recruitment — unsuccessful candidates (no consent to retain)	6 months from rejection notification.	No continuing lawful basis after the specific role is filled.	TA system automated deletion.	TA team (automated).
Client CRM contact data (client representatives)	Duration of client relationship + 3 years.	Legitimate interest in maintaining relationship history. Potential contract disputes.	CRM automated archival. Manual deletion at 3-year post-relationship mark.	Account Management + Marketing Ops.
Client end-user personal data (as Data Processor)	As specified in the Data Processing Agreement — typically deleted or returned to client at engagement end.	DPA obligations. DPDP Act storage limitation.	Per DPA terms — deletion certified to client.	Engagement Manager + DPO.
Website visitor analytics (pseudonymised)	26 months from collection.	Standard analytics retention for trend analysis.	Analytics platform automated deletion.	IT / Marketing (platform settings).
Consent records (who consented, to what, when, and how)	Duration of processing relying on that consent + 5 years.	Evidence of lawful basis for processing. Regulatory audit.	DPO consent management system.	DPO (annual consent audit).
Breach records and incident logs	5 years from incident closure.	DPBI audit rights. Regulatory investigation. Litigation.	DPO breach register. Secure deletion at 5 years.	DPO (annual).
Data subject rights request records	5 years from request closure.	DPBI audit rights. Evidence of compliance.	DPO rights request register.	DPO (annual).

13.3 Deletion Procedures — Technical and Administrative Standards

Deletion of personal data must be genuinely irreversible — a deletion that can be easily recovered from a backup or a recycle bin is not a meaningful deletion for data privacy purposes. The deletion procedures below apply to each storage medium and must be followed when personal data reaches the end of its retention period.

Storage Medium	Deletion Method	Verification	Notes
HRMS and cloud databases	Secure deletion by HRMS Administrator using the HRMS data archival and deletion module. Database-level deletion — not soft-delete that leaves data recoverable.	DPO receives deletion certificate from HRMS Administrator. Annual audit confirms deletion records.	Backup copies are deleted on the standard backup rotation schedule. DPO confirms backup deletion timeline with IT for each deletion batch.

Storage Medium	Deletion Method	Verification	Notes
SAP / ERP financial records	Finance system archival and deletion per SAP data lifecycle management tools.	Finance Controller certifies deletion. IT confirms backup rotation.	7-year retention period means most annual payroll data is in an archival state. Deletion is from the archival store at the 7-year mark.
SharePoint and OneDrive	Permanent deletion by the document owner or IT Administrator. 93-day recycle bin period in SharePoint/OneDrive — DPO confirms permanent deletion after recycle bin expiry for sensitive data.	Document deletion record in IT audit log.	For RESTRICTED personal data: IT Administrator confirms permanent deletion (bypassing recycle bin) on request from DPO.
Email systems	Deletion of emails containing personal data at end of retention period. IT-managed email retention policy applies a rolling 3-year retention for standard business email with automated deletion.	IT confirms policy configuration. DPO reviews email retention policy annually.	Legal hold emails are excluded from automated deletion until the hold is lifted.
Physical documents	Cross-cut shredding for RESTRICTED documents. Confidential waste service for CONFIDENTIAL documents. Shredding certificate provided by contractor for outsourced document destruction.	Facilities management retains shredding certificates from the waste contractor.	Physical documents subject to a Legal Hold must not be shredded until the hold is released.
Endpointdevices (decommissioned laptops, phones)	Certified data erasure using NIST 800-88 or equivalent standard. IT team uses approved erasure tool and generates a certificate of erasure.	IT Security maintains decommissioning log with erasure certificate for each device.	Devices with solid-state storage and hardware encryption: cryptographic erasure (key destruction) meets the standard.

13.4 Legal Holds — When Deletion Must Be Suspended

A Legal Hold is an instruction issued by the Legal team to suspend the normal deletion schedule for personal data that is, or may be, relevant to pending or anticipated litigation, regulatory investigation, or other legal proceedings. A Legal Hold overrides the retention schedule — personal data subject to a Legal Hold must not be deleted until the hold is formally released by the General Counsel, even if the data has passed its normal retention expiry date. The Legal Hold instruction is specific and documented: it identifies the categories of data and systems covered, the individuals whose data is subject to the hold, and the reason for the hold. IT Security implements the hold through technical preservation measures (disabling automated deletion, creating a preserved copy if necessary) and the DPO records the hold in the Legal Hold Register.

13.5 Retention Compliance — Annual Deletion Audit

The DPO conducts an annual Deletion Audit in June, reviewing the retention schedule against the actual personal data held in all principal systems, confirming that data has been deleted at the correct point in the schedule, and identifying any categories of personal data that are being held beyond their retention period without a documented legal hold or specific legal reason. The audit produces a Deletion Audit Report that is presented to the Audit Committee as part of the annual data privacy governance report. The audit also confirms that all deletion records are complete and that the Data Protection Register retention schedule entries are current and accurate.

14. Data Protection Impact Assessments (DPIAs)

14.1 When a DPIA Is Required

A Data Protection Impact Assessment is a structured process for identifying and mitigating the privacy risks of a new or changed processing activity before the processing begins. The DPDP Act 2023 anticipates mandatory DPIAs for Significant Data Fiduciaries and for high-risk processing categories. The company conducts DPIAs as a matter of its privacy-by-design commitment for all processing activities that meet the threshold criteria below, regardless of whether the DPDP Act Rules have made them formally mandatory for the company at the time of this policy publication.

Trigger Category	Description	Examples	DPIA Required Before
Systematic processing of special category data at scale	Any new system or process that systematically collects, stores, or analyses sensitive personal data — health, biometric, financial account details — for more than 100 individuals.	New employee health monitoring platform. Biometric attendance system. Automated payroll analytics platform.	System procurement decision or development commencement.
Processing involving automated decision-making with significant effects	Any algorithm, AI model, or automated system that makes or substantively influences decisions about individuals without meaningful human review.	CV screening AI tool that ranks candidates. Automated credit scoring for clients. Algorithmic performance monitoring tool.	Deployment of the automated decision-making component.
Large-scale processing of children data	Any new processing activity involving personal data of individuals under 18 at any meaningful scale.	Consumer-facing product accessible to minors. Education technology engagement. Youth programme administration.	Product launch or programme commencement.
Systematic monitoring of individuals in public or semi-public spaces	CCTV, location tracking, or similar systematic monitoring.	Office building CCTV expansion. Employee location tracking for field workers.	System installation or activation.
Innovative use of new technology with privacy implications	First-time deployment of a technology whose privacy implications are not yet well understood.	First AI/ML deployment for a new use case. First use of a new biometric modality. First deployment of a new analytics methodology using personal data.	Technology deployment.
Client engagement involving sensitive end-user data categories	Client engagement where the company (as Data Processor) will process health, financial, or other sensitive personal data of the the client end-users.	Healthcare technology engagement. Financial services customer data platform. Insurance data analytics.	Engagement commencement. Project kickoff after DPA is in place.

14.2 The DPIA Process — Six Steps

The DPIA process follows a six-step methodology aligned with international best practice (ISO 29134 Privacy Impact Assessment) and the expected DPDP Act Rules requirements. The DPO facilitates every DPIA. The product manager, system architect, HRBP (for employee data), or engagement manager (for client engagements) leads the content development with the DPO's guidance. The Legal team reviews the final DPIA output.

Step	Activity	Output	Owner	Timeline
1 — Scope	Define the processing activity: what data, for what purpose, for how many individuals, for how long, by which systems and teams.	DPIA scope document — completed in the DPIA template (Segment 3 Appendix B).	Product/engagement lead + DPO.	Before DPIA commences — scope agreed within 3 working days of DPIA initiation.
2 — Necessity and Proportionality	Assess whether the processing is necessary for the stated purpose and whether the scope is proportionate. Is there a less privacy-invasive way to achieve the same objective?	Necessity and proportionality assessment section of DPIA template.	Product/engagement lead with DPO.	Within 5 working days of scoping.
3 — Risk Identification	Identify all privacy risks arising from the processing — risks to Data Principals (harm, discrimination, loss of control) and risks to the company (compliance, reputational, regulatory).	Risk register within DPIA template. Each risk rated by likelihood and impact.	DPO leads risk identification session.	Within 10 working days of scoping.
4 — Risk Mitigation	For each identified risk: identify the mitigating measure, assess the residual risk after mitigation, and assign an owner and implementation deadline for the mitigation.	Mitigation plan within DPIA template.	Product/engagement lead (mitigations). DPO (residual risk assessment).	Within 15 working days.
5 — Residual Risk Assessment	Assess whether the residual risks (after all mitigations are in place) are acceptable to proceed. If residual risk remains HIGH after all available mitigations: DPO must consult the General Counsel and potentially the DPBI (prior consultation).	Residual risk determination: Accept / Accept with conditions / Do not proceed.	DPO with General Counsel for HIGH residual risk.	Within 20 working days.
6 — Review and Sign-Off	DPO and General Counsel review and sign off the DPIA. Product/engagement lead confirms mitigations are implemented before go-live. DPIA stored in the DPIA Register.	Signed DPIA. DPIA Register updated. Implementation checklist confirmed at go-live.	DPO + General Counsel sign off. CEO awareness for HIGH residual risk DPIAs.	Before go-live — typically within 25 working days of initiation.

14.3 DPIA Register and Ongoing Review

The DPO maintains a DPIA Register listing all completed DPIAs — the processing activity assessed, the assessment date, the residual risk level, the sign-off status, and the next review date. A DPIA is not a one-time exercise: it must be reviewed whenever the processing activity changes materially, whenever a significant new risk is identified in the processing environment, and on a scheduled basis — at least every 3 years for standard DPIAs, and annually for HIGH residual risk DPIAs. The DPIA Register is reviewed by the Audit Committee annually as part of the data privacy governance report.

15. Privacy by Design and Privacy by Default

15.1 Privacy by Design — The Seven Foundational Principles

Privacy by Design is the principle that privacy protections should be embedded into the design and architecture of systems, products, and processes from the outset — not added as an afterthought, a bolt-on, or a legal compliance layer after the technical decisions have been made. The DPDP Act 2023 requires Data Fiduciaries to implement privacy by design as part of their accountability obligations. The company has adopted the seven foundational principles of Privacy by Design developed by Dr. Ann Cavoukian as the operational framework for this requirement.

PbD Principle	Description	How the Company Implements It
1. Proactive not Reactive	Anticipate and prevent privacy-invasive events before they occur. Do not wait for a breach to discover a privacy risk.	DPIA process (Section 14) for all high-risk processing. DPO involvement in system design decisions. Privacy requirements in the project kickoff checklist.
2. Privacy as the Default Setting	Personal data must be automatically protected — individuals should not need to take action to protect their privacy. The maximum privacy settings should be the default.	Systems default to minimum data collection, restricted access, and shortest retention. Users must opt in to data sharing, not opt out.
3. Privacy Embedded into Design	Privacy is integral to the system architecture and business practices — not bolted on as an add-on after the core design is complete.	DPO is a mandatory reviewer in the technical design review process for all systems that process personal data. Architecture decisions that affect privacy require DPO sign-off.
4. Full Functionality — Positive-Sum	Achieve all legitimate purposes without privacy trade-offs. Do not treat privacy and functionality as a zero-sum game.	Privacy requirements are stated alongside functional requirements in project specifications. Teams are required to find privacy-preserving solutions that meet the functional need, not to sacrifice privacy for functionality.
5. End-to-End Security	Strong security throughout the lifecycle — from collection to deletion. Full lifecycle protection.	Encryption by default at rest and in transit. Access controls from system design. Secure deletion provisions designed in at system inception.
6. Visibility and Transparency	All stakeholders can verify that the privacy promises are kept. Operate openly — not covertly.	Privacy notices for all processing. Data Protection Register accessible to regulators. DPO contact details published. Annual data privacy programme report.
7. Respect for User Privacy — User-Centric	Respect individual privacy interests and rights. Design systems around the individual, not the organisation.	Data Principal rights mechanisms designed into systems from the start. Consent management designed for genuine user control, not dark patterns.

15.2 Privacy by Default — Implementation Standard

Privacy by default means that, in the absence of any specific action by the user or Data Principal, the system should automatically apply the most privacy-protective settings available. This applies to data collection (collect the minimum), data sharing (share nothing by default), data retention (apply the shortest defensible retention period), and data visibility (restrict access to the minimum necessary by default). The following checklist is applied by the DPO in the design review of every new system or significant change to an existing system that processes personal data.

Privacy by Default Check	Standard	Pass / Fail Criteria
Data collection minimum	Does the system collect only the personal data elements that are necessary for the stated processing purpose? Are there any data fields that are collected but not used?	Pass: every collected field is mapped to a specific processing purpose in the DPIA/Data Protection Register. Fail: any collected field that cannot be mapped to a specific purpose.
Access control defaults	Is the default access setting for personal data "restricted to named individuals" rather than "accessible to all team members" or "publicly visible"?	Pass: system defaults to minimum access. New users have no access until explicitly granted. Fail: system defaults to broad access that must be restricted manually.
Data sharing defaults	Does the system default to not sharing personal data with third parties or other systems? Is sharing an active decision rather than a passive default?	Pass: no data leaves the system without an active decision and a documented lawful basis. Fail: data is shared by default and sharing must be disabled manually.
Retention and deletion	Does the system have automated deletion built in for personal data at the end of the applicable retention period? Or does retention require manual action to terminate?	Pass: automated deletion or archival at end of retention period with minimal manual intervention. Fail: data retained indefinitely unless manually deleted.
Consent and transparency	Does the system present clear, plain-language information about data collection before collection begins? Is the consent mechanism (where consent is the lawful basis) compliant with the DPDP Act standards?	Pass: privacy notice presented before collection; consent (where required) is DPDP Act compliant. Fail: no privacy notice; or consent is pre-ticked, bundled, or otherwise non-compliant.
Children data protections	If the system is accessible to individuals under 18: is age verification in place? Are tracking, behavioural monitoring, and targeted advertising disabled for verified minors?	Pass: age verification mechanism in place; tracking and advertising disabled for minors. Not applicable: system is demonstrably accessible only to adults. Fail: system accessible to minors without age verification.

15.3 Privacy by Design — Developer and Engineer Obligations

Software engineers, data engineers, and system architects at Arjun Technologies are among the individuals who most directly give effect to the privacy by design obligation — because the privacy characteristics of a system are largely determined by the technical decisions made during development. The following engineering practices are required for all systems and components that process personal data at the CONFIDENTIAL or RESTRICTED classification.

Engineering Practice	Requirement	Verification Method
Encryption at rest	All personal data stored in databases or file storage must be encrypted at rest using AES-256 or equivalent. Database-level encryption, field-level encryption for RESTRICTED data.	Security review in pull request. Architecture design review. Penetration test.
Encryption in transit	All personal data transmitted between services, between client and server, and between the company and third parties must be encrypted using TLS 1.2 or higher.	SSL/TLS configuration review. Certificate management audit.
Access control by design	Systems must implement role-based access control from the first version. Personal data must not be accessible to unauthenticated or unauthorised users in any state of the system — including development, staging, and testing environments.	Code review. Access control test in QA. DPIA review.
Pseudonymisation where feasible	Where the processing purpose can be served with pseudonymised data (replacing direct identifiers with codes), pseudonymisation should be used in preference to processing identified data.	DPO review of data architecture. DPIA.

Engineering Practice	Requirement	Verification Method
No real personal data in development or testing	Development and test environments must use synthetic or anonymised test data. Real personal data from production systems must not be used in development, test, or QA environments without DPO approval and documented necessity.	Environment audit. CI/CD pipeline check.
Logging for accountability	All access to CONFIDENTIAL and RESTRICTED personal data must be logged with user ID, timestamp, and action. Logs must be tamper-resistant and retained per Section 13.2.	Logging architecture review. Log integrity check.
Secure deletion capability	Systems must be designed with the ability to securely and completely delete personal data when required — both for individual deletion (Data Principal erasure requests) and for bulk deletion at end of retention period.	Deletion function code review. Deletion test in QA.

16. Data Sharing — Joint Controllers and Independent Disclosures

16.1 The Distinction Between Sharing and Processing

Not all personal data that leaves the company goes to a Data Processor operating under instruction. Some disclosures of personal data are to parties who receive the data and process it for their own independent purposes — making them independent Data Controllers (or Data Fiduciaries in DPDP Act terminology) in their own right. Others are joint processing arrangements where the company and another party jointly determine the purpose and means of processing. These arrangements require different legal mechanisms from a Data Processor relationship and different considerations in terms of the company residual obligations for the shared data after it leaves the company's control.

Sharing Arrangement	Legal Characterisation	Legal Mechanism Required	Company Residual Obligations
Sharing employee data with a statutory authority (Income Tax Department, EPFO, ESIC)	Disclosure under legal obligation — the company is the Data Fiduciary; the statutory authority is an independent authority with its own legal basis.	No DPA required — legal obligation is the lawful basis. Record the disclosure in the Data Protection Register.	Disclose only what the statute requires. Notify the DPO of new statutory disclosure obligations. No ongoing obligations after disclosure unless the statute imposes them.
Sharing client contact data with a co-organiser for a joint event	Potentially Joint Data Fiduciary arrangement — both organisations determine the purpose of using the contact data jointly.	Joint Data Fiduciary Agreement specifying which party handles Data Principal rights requests and breach notification.	Ensure the contact has been informed that both organisations will process their data. Maintain the ability to honour rights requests from the shared contacts.
Sharing anonymised analytics data with an industry consortium	Not personal data if genuinely anonymised. Standard commercial arrangement.	Data sharing agreement confirming anonymisation standard. No DPA or consent required for genuinely non-personal anonymised data.	DPO confirms anonymisation quality. If re-identification risk exists, treat as personal data.
Providing employee reference to a former employee prospective employer	Disclosure of third-party personal data (the former employee) — requires a lawful basis.	No formal agreement required for standard employment reference. Lawful basis: legitimate interest of the prospective employer and the employee. Note: the employee prior consent is not required but the reference must be factually accurate.	Reference must be accurate. Reference should not disclose information beyond what is relevant to the professional assessment.
Sharing personal data with a regulatory investigation (DPBI, SEBI, RBI)	Disclosure under legal compulsion — no consent or DPA required.	No DPA required. Legal team manages the regulatory request. DPO notified.	Disclose only what is required by the regulatory request. Challenge requests that exceed the regulator authority. Legal team advises.

16.2 Authorisation Process for Non-Routine Data Disclosures

Any disclosure of personal data to a third party that is not covered by an existing DPA, a statutory obligation, or an employee privacy notice must be approved by the DPO before the disclosure is made. This includes: sharing employee data with third-party survey or benefits providers not already on the approved processor list; sharing client contact data with partner organisations; providing personal data in response to a request from a former employee about their own data to a third party on their behalf; and any ad-hoc sharing request that does not fit an established category. The DPO assesses: the lawful basis for the disclosure; whether the Data Principal has been informed; whether the recipient has adequate data protection standards; and whether a DPA or data sharing agreement is required. No non-routine disclosure proceeds without DPO approval documented in the Data Protection Register.

17. Artificial Intelligence and Algorithmic Processing of Personal Data

17.1 The Data Privacy Dimensions of AI Processing

The use of artificial intelligence and algorithmic systems to process personal data creates specific data privacy obligations that go beyond the standard processing provisions in this policy. AI systems that process personal data may amplify privacy risks in several ways: they may infer sensitive attributes (political opinions, health conditions, sexual orientation) from non-sensitive input data; they may make consequential automated decisions about individuals based on patterns in historical data that reflect historical biases; they may process large volumes of personal data for training purposes in ways that make subsequent deletion of individual data technically complex; and they may create outputs (synthesised images, text, or audio) that can be associated with real individuals in ways that create new privacy risks.

The Code of Conduct Section 10.3 establishes the general ethical framework for AI tool use at the company. This policy section establishes the data privacy-specific obligations that apply when AI tools process personal data. Both sets of obligations apply simultaneously — an AI processing activity must comply with both the Code of Conduct AI ethics provisions and the data privacy provisions in this section.

AI Processing Context	Key Data Privacy Obligations	DPIA Required?	DPO Action Required
Using an approved AI coding assistant (GitHub Copilot or equivalent) for code that processes personal data	Personal data and system credentials must not be entered into AI prompts. Code generated by AI for personal data processing must be reviewed for privacy compliance before use in production.	No — for the AI tool use itself. Yes — for the system being built if it meets DPIA triggers.	DPO reviews Approved Tools Register annually to confirm AI tool data handling standards.
Training an internal AI/ML model using employee or customer personal data	Lawful basis required for using personal data for AI training. Data minimisation applies — use anonymised or synthetic data where the training objective can be achieved without real personal data. DPIA mandatory. Retention obligation: personal data used for training must be deletable from the model where technically feasible.	Yes — mandatory. Training AI on personal data is high-risk processing.	DPO reviews training data plan before data access. DPIA completed before training commences. Legal team confirms lawful basis.
Deploying an AI model that makes or influences decisions about individuals (automated decision-making)	Where the AI makes decisions that have significant effects on individuals (employment, credit, access to services), the company must ensure: the decision is subject to meaningful human review; Data Principals can request human review of AI decisions affecting them; the system is assessed for discriminatory bias.	Yes — mandatory. Automated decision-making with significant effects is a standard DPIA trigger.	DPO reviews decision-making logic and human review mechanism. Annual bias audit of model outputs.
Using generative AI tools that process personal data outside company-managed infrastructure	Prohibited for CONFIDENTIAL or RESTRICTED personal data. For INTERNAL USE ONLY data: use only tools on the Approved Tools Register that have executed a DPA meeting company standards.	Yes — when first adding a generative AI tool to the Approved Tools Register for personal data processing.	DPO approves addition of generative AI tools to the Approved Tools Register. No personal data in unapproved tools.
AI-generated content depicting real individuals	Content generated by AI that depicts or is attributed to real individuals (deepfakes, synthetic quotes, synthetic images) creates privacy and reputation risks. Prohibited where it would constitute a privacy violation or a misrepresentation.	No — but governed by Code of Conduct Section 10.3 prohibition on impersonation using AI.	DPO notified of any AI content generation use case involving real individuals for assessment.

Segment 2 — Compliance Verification and Certification

This page confirms that the operational provisions in Segment 2 have been reviewed and verified against the applicable legal framework and the company operational environment as at 01 April 2024.

Section	Subject	Certifying Party	Standard Met	Date
Section 8 — Operational Handling Standards	Encryption standards (AES-256 at rest, TLS 1.2+ in transit) verified against current company IT infrastructure.	Head of IT / CISO (Mr. Kiran Bhat)	ISO 27001 Controls A.10.1, A.13.2	April 2024
Section 9 — Context-Specific Standards	HR data access controls verified against HRMS role configuration. Salary and health data field restrictions confirmed.	VP-HR (Ms. Priya Menon) + DPO	HRMS access audit completed	April 2024
Section 10 — Breach Management	Breach detection tools operational. IT Security incident response procedure in place. Breach register active.	Head of IT / CISO + DPO	SIEM operational. IR procedure tested Q3 2023.	April 2024
Section 11 — Processor Management	Processor Register reviewed. All active processors with DPAs confirmed. 3 processors awaiting DPA renewal — Legal team managing.	DPO + General Counsel	DPA register current. 3 renewals in progress.	April 2024
Section 12 — Employee Monitoring	IT monitoring tools reviewed against privacy principles. No productivity surveillance tools in use. Communications monitoring policy confirmed.	Head of IT / CISO + DPO	Monitoring scope confirmed within policy limits.	April 2024
Section 13 — Data Retention	Retention schedule reviewed. Deletion audit for FY2022-23 completed. SAP 7-year deletion cycle active. HRMS retention automation in development (target: Q3 2024).	DPO + Finance Controller	FY2022-23 deletion audit report available.	April 2024
Section 14 — DPIAs	DPIA register reviewed. All current DPIAs completed and signed off. 2 new processing activities with DPIAs in progress.	DPO	DPIA register current.	April 2024
Section 15 — Privacy by Design	PbD checklist deployed in project management tooling. Engineering team training completed Q1 2024.	DPO + Head of Engineering	PbD checklist in Jira project template.	April 2024
Sections 16–17 — Data Sharing and AI	Data sharing authorisation process active. AI Approved Tools Register current. Generative AI data handling training completed.	DPO	Approved Tools Register on HRMS portal.	April 2024

Role	Name	Signature	Date
Chief Executive Officer	Mr. Rajesh Arjun		01 April 2024
General Counsel / Document Owner	Mr. Sandeep Iyer		01 April 2024
Data Protection Officer	Designated Legal Team Member		01 April 2024
VP Human Resources	Ms. Priya Menon		01 April 2024
Head of IT / CISO	Mr. Kiran Bhat		01 April 2024

Segment 2 Summary and Continuation to Segment 3

This completes Segment 2 of the Arjun Technologies Pvt. Ltd. Data Privacy Policy and Procedures Framework, Version 2.1. Segment 2 has translated the foundational framework of Segment 1 into the operational standards that govern daily data handling at every level of the organisation. Section 8 established the practical data handling framework across three data states — in transit (with a six-channel transmission standards table), at rest (with a six-storage-location encryption and access control table), in use (with a five-situation screen and environment standards table) — and addressed portable media and secure disposal. Section 9 provided context-specific handling standards for the four principal processing environments: HR and employment data (with a six-category access and permitted-use table), client and engagement data (with a five-scenario fiduciary/processor comparison table), marketing and external communications (with a four-activity lawful basis and consent table), and IT systems and infrastructure data (with a five-type operational data handling table). Section 10 delivered the complete breach management framework — breach definition and examples, detection obligations and no-blame reporting culture, four-level severity classification with response timelines, containment actions by breach type, notification obligations to the DPBI and affected Data Principals with a four-recipient table, post-breach review obligations, and the Breach Register. Section 11 governed third-party data processor management — processor classification across seven categories, six-element due diligence requirements, nine mandatory DPA provisions with legal bases, and ongoing oversight and sub-processing controls. Section 12 established the employee monitoring framework — the four governing principles, four-type IT monitoring standards table, building access governance, and the clear prohibition on productivity surveillance and routine communications monitoring. Section 13 provided the complete data retention framework — retention philosophy, fifteen-row retention schedule covering all principal data categories, six-medium deletion procedure standards, the Legal Hold framework, and the annual deletion audit process.

Segment	Sections Covered	Key Topics	Pages	Status
Segment 1	1–7	Purpose and Scope · DPDP Act 2023 · Statutory Framework · Data Fiduciary Obligations · DPO · Consent Framework · Classification · Data Principal Rights	1–50	Published April 2024
Segment 2 — This Document	8–13	Operational Handling Standards · Context-Specific Standards · Breach Management · Processor Management · Employee Monitoring · Data Retention and Deletion	51–100	Published April 2024
Segment 3	14–18 + Appendices A–H	Cross-Border Transfers · Sector Obligations · Privacy by Design · Enforcement · Governance Programme · DPIA Templates · DPA Template · Privacy Notice Templates · Consent Record Form · Breach Report Form · Rights Request Form · Retention Schedule (complete) · Processor Register	101–150	Published April 2024

Segment 2 — At-a-Glance Reference

Topic	Key Rule	Where to Find Full Detail
Sending personal data by email	CONFIDENTIAL: verify recipient, no personal email. RESTRICTED: encrypt and DPO-notify first transmission externally.	Section 8.2
Storing personal data	Never on personal devices. Company systems only. RESTRICTED: DPO-approved storage with encryption and named access only.	Section 8.3
Working with personal data in public	Privacy screen required for CONFIDENTIAL. RESTRICTED: office or private residence only.	Section 8.4
Suspected data breach	Report to IT Security AND DPO within hours. Do not investigate alone. Reporting in good faith = no disciplinary consequence.	Section 10.2

Topic	Key Rule	Where to Find Full Detail
Engaging a new third-party tool or supplier that handles personal data	Stop before sharing data. DPO due diligence first. DPA signed before any data transfer.	Section 11.1–11.3
Building a system that processes personal data	Encrypt by default. No real data in dev/test. Log all access. Privacy by Design checklist with DPO before go-live.	Section 15.3
Employee requests access to their own data	Forward to dpo@arjuntech.in immediately. Do not fulfil yourself.	Section 7.8 (Segment 1)
Retaining personal data	Follow the retention schedule. Delete at end of period. Never retain indefinitely. Legal Hold suspends deletion.	Section 13.2–13.4
AI tools and personal data	Approved Tools Register only for personal data. No CONFIDENTIAL/RESTRICTED data in unapproved AI tools. DPIA for AI decision-making.	Section 17
Building a DPIA	Required for high-risk processing. 6-step process. DPO facilitates. Must complete before go-live.	Section 14

All three segments available on HRMS portal under Policies and Documents. For data privacy queries: legal@arjuntech.in or dpo@arjuntech.in. For Data Principal rights requests: dpo@arjuntech.in. For anonymous reporting of data privacy concerns: ethics@arjuntech.in (24/7). Document reference: LEGAL-POL-004-v2.1. Owner: Mr. Sandeep Iyer, General Counsel. Approved: Mr. Rajesh Arjun, CEO. Effective: 01 April 2024.

Data Privacy Compliance — Segment 2 Scenarios and Reference

The following scenarios apply the operational provisions of Segment 2 to common situations encountered by employees and managers across the organisation.

Scenario	Facts	Correct Action
New SaaS tool procurement	A project manager wants to subscribe to a new project management SaaS tool. The tool will sync with HRMS and will have access to employee names, email addresses, and task assignments.	Stop before subscribing. The tool is a Data Processor — it will process employee personal data on the company behalf. HRBP and DPO must be notified before any personal data is shared. DPO conducts processor due diligence (Section 11.2). A Data Processing Agreement must be executed before the HRMS sync is enabled. If the tool does not accept a DPA: it cannot be used for any processing involving personal data. (Section 11.1 and 11.3.)
Developer testing with real data	An engineer needs to test a new feature of a client analytics system. They copy a sample of real client customer data from the production database into the test environment to use as test data.	Prohibited. Real personal data must not be used in development or test environments (Section 15.3 — Privacy by Design, developer obligations). The engineer must use synthetic or anonymised test data. The DPO must be notified if real data has already been copied to the test environment, as this constitutes an unauthorised disclosure — a potential breach (Section 10.1). IT Security should delete the test environment copy immediately.
Employee requests deletion of data after leaving	A former employee who left the company 2 years ago emails the DPO requesting that all their personal data be deleted.	The DPO registers the request within 48 hours and assesses the erasure right against the retention schedule (Section 13.2). Most employee personal data is retained for 7 years post-employment under tax and employment law. The DPO responds explaining the retention obligation and the specific categories of data that will be deleted at the 7-year mark. Any data that is not subject to a retention obligation and is held beyond its retention period should be deleted promptly. (Section 7.4 and 13.2.)
Client asking for data deletion from a completed engagement	A client project concluded 18 months ago. The client now requests that all client end-user personal data processed by the company during the engagement be confirmed as deleted.	The DPO checks the Data Processing Agreement for the engagement. The DPA should specify the deletion or return obligation at engagement end. The DPO co-ordinates with the engagement team and IT to confirm deletion has been completed per the DPA terms. If deletion was not completed at engagement end: complete it now and certify to the client. If completed: provide the deletion certificate. (Section 9.2 and DPA obligations.)
CCTV footage request from a police investigation	A police officer arrives at the office and requests access to CCTV footage from the past 30 days relating to a criminal investigation.	The Facilities team should not provide access without legal authority. The police officer must provide a valid court order or production notice under the applicable legislation. The General Counsel should be contacted immediately. The DPO is notified. Legal team reviews the authority and confirms the scope of the required disclosure. Only the specifically requested footage is disclosed. The disclosure is recorded in the Data Protection Register. (Section 16.2 — regulatory disclosure.)

Scenario	Facts	Correct Action
Marketing email sent to an unsubscribed contact	A marketing team member sends a promotional email to a contact list, not realising that 50 contacts on the list had previously unsubscribed.	This is a potential violation of the DPDP Act consent provisions and may also violate TRAI regulations on unsolicited commercial communications. The DPO is notified. The 50 unsubscribed contacts are identified and logged. A corrective email is sent acknowledging the error. The unsubscribe list management process is reviewed to identify why the unsubscribes were not applied. If any contact complains to the DPBI: the company cooperates fully. (Section 9.3.)

Segment 2 — Data Privacy Obligations Quick Reference by Role

Role	Key Segment 2 Obligations	First Contact for Queries
All employees	Apply classification-based handling standards (Section 8). Report suspected breaches immediately to IT Security and DPO (Section 10.2). Do not share personal data with third parties without DPO approval. Complete mandatory data privacy training annually.	DPO at dpo@arjuntech.in
Managers and team leads	Ensure team follows data handling standards. Approve only systems on the Approved Tools Register for personal data processing. Ensure no real personal data is used in dev/test environments. Alert DPO to any new processing activity or third-party tool that involves personal data.	DPO + HRBP
HR Business Partners	Apply Section 9.1 HR data handling standards. Control access to health and salary data strictly. Manage Data Principal rights requests for employment data. Ensure deletion at end of retention periods per Section 13.2.	DPO
Software engineers and data engineers	Apply Privacy by Design principles (Section 15.3). No real personal data in dev/test environments. Encrypt personal data at rest and in transit by default. Log all access to personal data systems.	DPO + Line Manager
Finance and payroll team	Apply Section 9.1 financial personal data standards. Restrict salary and bank details to authorised payroll personnel. Manage annual deletion audit for payroll records at 7-year mark.	DPO + CFO
IT Security team	Manage breach detection and contain confirmed breaches (Section 10.4). Maintain access logs for all personal data systems. Implement deletion procedures in Section 13.3. Manage portable media controls.	DPO
Legal and DPO	Manage all Data Principal rights requests. Conduct DPIAs (Section 14). Maintain Data Protection Register and Breach Register. Manage processor due diligence and DPAs. Conduct annual deletion audit.	General Counsel for escalation
Account managers and business development	Apply Section 9.2 and 9.3 client and marketing data standards. Ensure DPAs are in place before sharing personal data with clients or receiving client end-user data. Obtain marketing consent before adding contacts to distribution lists.	DPO + Legal team

Arjun Technologies Pvt. Ltd.

Bengaluru, Karnataka — 560 001

CIN: U72200KA2008PTC044521 | www.arjuntech.in

DATA PRIVACY POLICY AND PROCEDURES FRAMEWORK

Segment 3 of 3 — Cross-Border Data Transfers · Sector-Specific Obligations · Enforcement and Penalties · Data Privacy Governance Programme · Appendices A–H · Complete Policy Summary

Version	2.1	**Effective Date**	01 April 2024
Review Date	31 March 2025	**Classification**	Internal Use Only
Approved By	Mr. Rajesh Arjun	**Document Owner**	Mr. Sandeep Iyer
Legal Author	Mr. Sandeep Iyer	**Department**	Legal & Compliance
Doc Reference	LEGAL-POL-004-v2.1	**DPO Contact**	dpo@arjuntech.in
Segment	3 of 3 (Pages 101–150)	**Total Segments**	3

This is Segment 3 — the concluding segment — of the Arjun Technologies Pvt. Ltd. Data Privacy Policy and Procedures Framework, Version 2.1. It covers four specialist areas and the complete appendices suite. Section 18 addresses cross-border personal data transfers — the DPDP Act 2023 framework, currently available transfer mechanisms, Standard Contractual Clauses for EU/UK engagements, and the company's interim transfer risk management approach pending publication of the approved country list. Section 19 addresses sector-specific data privacy obligations across the company's principal client verticals. Section 20 covers enforcement, regulatory engagement, and how the company manages DPBI investigations and inquiries. Section 21 describes the comprehensive data privacy governance programme — training, awareness, audit, and continuous improvement. Appendices A through H provide the operational tools: DPIA template, DPA template, privacy notice templates, consent record form, breach report form, data principal rights request form, data retention schedule, and the processor register template. For queries: dpo@arjuntech.in or legal@arjuntech.in.

Table of Contents — Segment 3

SEGMENT 3 — This Document (Pages 101–150)

Section 18 — Cross-Border Personal Data Transfers

18.1 The DPDP Act 2023 Cross-Border Transfer Framework
18.2 The Approved Country List — Current Status and Interim Approach
18.3 Standard Contractual Clauses — EU and UK Client Engagements
18.4 Cross-Border Transfer Risk Assessment Process
18.5 Cross-Border Transfers in Specific Operational Contexts

Section 19 — Sector-Specific Data Privacy Obligations

19.1 Financial Services — RBI, SEBI, and IRDAI Requirements
19.2 Healthcare and Life Sciences — DISHA and Health Data Standards
19.3 Telecommunications and Digital Services
19.4 Government and Public Sector Engagements
19.5 Education Technology

Section 20 — Enforcement, Regulatory Engagement, and DPBI Interactions

20.1 The Data Protection Board of India — Jurisdiction and Powers
20.2 Responding to DPBI Complaints and Inquiries
20.3 Voluntary Undertakings and Settlement
20.4 Regulatory Engagement — Proactive Relationship Management
20.5 Legal Proceedings and Litigation Involving Personal Data

Section 21 — The Data Privacy Governance Programme

21.1 Programme Structure and Annual Calendar
21.2 Mandatory Training — Curriculum and Delivery
21.3 Data Privacy Culture — Beyond Compliance
21.4 Annual Data Privacy Audit — Scope and Process
21.5 Continuous Improvement — How the Programme Evolves
21.6 Data Privacy Metrics and Governance Reporting

APPENDICES

Appendix A — Data Protection Impact Assessment (DPIA) Template
Appendix B — Data Processing Agreement (DPA) — Key Clauses Summary
Appendix C — Employee Privacy Notice
Appendix D — Candidate and Recruitment Privacy Notice
Appendix E — Consent Record Form
Appendix F — Personal Data Breach Report Form
Appendix G — Data Principal Rights Request Form
Appendix H — Complete Policy Summary and Glossary of Defined Terms

18. Cross-Border Personal Data Transfers

18.1 The DPDP Act 2023 Cross-Border Transfer Framework

Section 16 of the Digital Personal Data Protection Act 2023 establishes the framework for cross-border transfers of personal data. The Act permits the Central Government to restrict the transfer of personal data to countries outside India by notifying such restrictions. Conversely, by remaining silent on a country, the Central Government effectively permits transfers to that country. The legal effect is that transfers of personal data to countries outside India are presumptively permitted unless the Central Government specifically restricts a country by notification. This is a positive-list model in reverse — restriction rather than permission is what requires notification — which differs from the EU GDPR model where transfers to third countries require a lawful transfer mechanism unless the country has been specifically approved.

As at April 2024, no country restrictions have been notified by the Central Government under Section 16 of the DPDP Act. The Draft Digital Personal Data Protection Rules, published for public consultation in January 2025, are expected to specify the procedures governing cross-border transfers. The company's position — consistent with the Legal team's advice — is that the absence of current restriction notifications does not mean the company should transfer personal data to any country without consideration of the risks involved. The company applies a risk-based transfer assessment to all cross-border personal data transfers, as described in Section 18.4, to ensure that personal data is only transferred to countries and recipients with adequate protection levels.

18.2 The Approved Country List — Current Status and Interim Approach

The DPDP Act Rules are expected to establish a list of countries to which personal data may be transferred without additional safeguards, and a list of countries to which transfer is restricted or prohibited. Until this list is published and in force, the company applies the following interim framework to all cross-border personal data transfers.

Transfer Destination	Interim Company Position	Basis	DPO Action Required
European Union / European Economic Area	Transfers permitted with Standard Contractual Clauses (EU SCCs) where the EU GDPR applies to the recipient or the data. Even where GDPR does not apply, the company applies SCCs as a best-practice safeguard for EU-bound transfers.	EU adequacy and SCC framework. Company standard for EU/UK client engagements.	DPO confirms SCC execution for all new EU data transfers. SCC register maintained.
United Kingdom	Transfers permitted with UK SCCs (International Data Transfer Agreement / IDTA) for UK GDPR-governed data.	UK adequacy and IDTA framework.	DPO confirms IDTA execution for UK client engagements involving UK personal data.
United States	Transfers permitted with contractual safeguards (DPA with security and privacy commitments). No adequacy designation applicable for DPDP Act purposes.	Risk-based assessment. Contractual safeguards.	DPO conducts risk assessment. DPA with US-based processors reviewed for adequacy of security commitments.
Singapore, UAE, Japan, Australia	Transfers permitted with DPA and risk assessment. These jurisdictions have mature data protection frameworks that provide comparable protection levels.	Risk-based assessment. Comparable protection level.	DPO risk assessment on first transfer to a new recipient in these countries.

Transfer Destination	Interim Company Position	Basis	DPO Action Required
Countries with no formal data protection framework	Transfers only where: a specific legal obligation requires the transfer; contractual necessity requires it; or the Data Principal has given explicit informed consent. Enhanced DPA provisions required.	DPDP Act Section 7 legitimate use. Specific necessity.	DPO approval required before any transfer. Legal team review. Enhanced DPA executed.
Countries subject to international sanctions (OFAC, UN)	No transfer of any company data, including personal data, to sanctioned countries or sanctioned entities.	Legal compliance with international sanctions law.	Legal team approval required before any engagement involving sanctioned country personnel or entities.

18.3 Standard Contractual Clauses — EU and UK Client Engagements

For client engagements where the company processes personal data of EU or UK data subjects as a Data Processor, the company executes Standard Contractual Clauses with the client to provide the lawful transfer mechanism required by the EU GDPR and UK GDPR. The company uses the EU Commission's Standard Contractual Clauses (2021 version, Module 2: Controller to Processor) for EU GDPR contexts and the UK International Data Transfer Agreement (IDTA) for UK GDPR contexts. These are incorporated into the company's standard Data Processing Agreement (LEGAL-DPA-001-v3.1) as annexes.

SCC/IDTA Element	Company Obligation	Standard Implementation	DPO Responsibility
Binding nature of SCCs	The SCCs create binding legal obligations on the company as Data Processor that supplement the commercial DPA terms. The SCCs cannot be varied by commercial agreement.	SCCs incorporated in DPA as a non-negotiable annex. Commercial team cannot agree modifications to SCC clauses.	DPO reviews any client requests to modify SCC terms. All modifications require DPO and General Counsel approval.
Technical and organisational measures (Annex II of SCCs)	The company must describe its technical and organisational security measures in Annex II of the SCCs. These measures are legally binding commitments to the client.	Standard Annex II describes company security measures: ISO 27001 controls, encryption standards, access controls, incident response.	DPO ensures Annex II is kept current following any material change to the security programme. Annual review.
Sub-processor provisions	The SCCs require the company to flow down equivalent obligations to sub-processors and to notify the client before engaging new sub-processors.	Standard DPA includes sub-processor notification provision (30-day prior notice to client).	DPO manages sub-processor register and notification process.
Data subject rights assistance	The SCCs require the company to assist the client in responding to EU/UK Data Subject rights requests that affect data processed by the company.	Standard DPA includes rights assistance provision.	DPO receives and handles rights requests from EU/UK data subjects in respect of processing activities under SCCs.
Audit rights under SCCs	The SCCs give the client (as Data Controller) an audit right over the company as Data Processor.	Standard DPA provides for audit on reasonable notice. Typically managed through security questionnaire, certification sharing, or on-site audit for major clients.	DPO co-ordinates audit responses. ISO 27001 certificate and SOC 2 report shared as primary audit evidence.

18.4 Cross-Border Transfer Risk Assessment Process

Every new cross-border personal data transfer — a new arrangement under which personal data flows from the company to a recipient outside India or from outside India to the company — requires a Transfer Risk Assessment (TRA) conducted by the DPO before the transfer commences. The TRA assesses: the legal framework of the

destination country for personal data protection; the nature and sensitivity of the data being transferred; the purpose and necessity of the transfer; the security measures in place at the recipient; and the practical risks of the transfer given the specific context. The TRA output is either approval of the transfer with or without additional safeguards, or escalation to the General Counsel for a risk acceptance decision where residual risk remains elevated.

TRA Factor	Assessment Question	Risk Indicator	Mitigation Measure
Destination country legal framework	Does the destination country have a comprehensive data protection law with effective enforcement?	High risk: no data protection law. Medium: law exists but enforcement is weak. Low: mature and enforced data protection framework.	High risk: enhanced contractual protections. Encryption of data before transfer. Minimise data transferred.
Nature and sensitivity of the data	What categories of personal data are being transferred? Is any special category data (health, biometric, financial account details) involved?	High risk: RESTRICTED personal data categories. Medium: CONFIDENTIAL personal data. Low: INTERNAL USE ONLY data.	High risk: DPO approval required. Legal team review. Enhanced encryption. Data minimisation.
Purpose and necessity	Is the transfer necessary for a specific, identified purpose? Could the purpose be achieved without the cross-border transfer?	High risk: transfer is for general purposes or convenience. Low risk: transfer is necessary for a specific contracted obligation.	Reject convenience transfers. Approve necessity transfers with appropriate safeguards.
Recipient security measures	Does the recipient have adequate security measures? ISO 27001 or equivalent?	High risk: no certification, weak security. Medium: some controls but not independently certified. Low: ISO 27001 or equivalent.	High risk: require enhanced security commitments in DPA. Consider whether the transfer should proceed.
Recipient accountability	Is the recipient subject to an enforceable data protection obligation? Can the Data Principal exercise rights against the recipient?	High risk: recipient operates in a jurisdiction with no enforceable data protection law and no mechanism for Data Principal rights.	High risk: SCCs or equivalent contractual mechanism required to give Data Principals rights they would otherwise lack.

18.5 Cross-Border Transfers in Specific Operational Contexts

Several common operational contexts at Arjun Technologies regularly involve cross-border personal data transfers. The following table provides the standard treatment for each context, representing the DPO's pre-assessed position for recurring transfer scenarios. New transfer scenarios not covered here require a fresh TRA.

Transfer Context	Typical Data	Transfer Direction	Mechanism	Standard Treatment
EU/UK client engagement — company processes EU/UK personal data as processor	End-user personal data of EU/UK data subjects	India (company systems) ← EU/UK client system	EU SCCs (Module 2) or UK IDTA incorporated in DPA.	DPO confirms SCC/IDTA in place before engagement commences.
International employee on assignment in a non-India location	Employee HRMS data (name, payroll, leave records)	India (HRMS) → host country local HR system / shadow payroll provider	DPA with local HR/payroll provider. TRA conducted by DPO.	DPO conducts TRA at assignment start. Local HR provider executes DPA.
US-based parent company of a client requesting access to client data processed by company	Client end-user personal data in company-operated systems	India → USA (client parent company)	DPA between company and US parent. EU SCCs where EU data is involved.	Legal team reviews client group data sharing arrangement. DPO confirms mechanism.

Transfer Context	Typical Data	Transfer Direction	Mechanism	Standard Treatment
Cloud infrastructure hosted partly outside India	Employee and client data stored in multi-region cloud	India primary ← cloud regions (Singapore, EU, US as backup/DR)	Cloud service DPA with data location commitments. SCCs where EU data involved.	IT Security ensures primary data residency is India. DPO reviews cloud DPA annually.
Candidate recruitment — candidate based outside India	Candidate personal data (CV, interview records)	Candidate location → India (HRMS)	Candidate consents to processing in India through the recruitment application form.	Recruitment privacy notice updated to confirm India processing.

19. Sector-Specific Data Privacy Obligations

19.1 Financial Services — RBI, SEBI, and IRDAI Requirements

Financial services engagements are the most heavily regulated of the company's client vertical obligations from a data privacy perspective. The Reserve Bank of India, SEBI, and IRDAI each maintain specific data protection requirements that apply to entities regulated by them and, by extension through the contractual supply chain, to technology service providers like Arjun Technologies that process regulated entities' customer data.

Regulator	Key Data Obligation	Company Implementation	Engagement Trigger
RBI — Payment System Data	All data related to payment systems must be stored in India only. Foreign payment system operators may keep a copy outside India but the primary data must reside in India.	Client systems built or operated by the company that process payment data must have India-hosted data storage as a design requirement.	Any engagement involving payment processing, payment gateway technology, or payment data analytics.
RBI — Account Aggregator Framework	The Account Aggregator (AA) framework creates specific consent architecture requirements for sharing financial data between Financial Information Providers (FIPs) and Financial Information Users (FIUs).	Systems built for the AA ecosystem must implement the Sahamati/ReBIT technical standards for consent management, data flow, and audit trails.	Engagements involving AA integration, FIP systems, or FIU systems.
RBI — Cyber Security Framework for Banks	Banks must ensure that third-party service providers meet the RBI cyber security framework requirements — including annual security audits, penetration testing, and incident reporting.	Company engagements with banks must contractually commit to the RBI third-party risk management requirements. Annual security audit reports shared with banking clients.	All bank and NBFC client engagements.
SEBI — Cybersecurity and Cyber Resilience Framework	SEBI-regulated entities (stock exchanges, brokers, depositories, asset managers) must ensure their technology service providers meet SEBI cyber security requirements.	Company systems built for SEBI-regulated entities must meet SEBI security framework requirements. Security assessments shared with SEBI clients on request.	All stock broker, exchange, depository, and asset manager engagements.
IRDAI — Protection of Policyholders Interests	Insurance companies must protect policyholder personal data and ensure third-party processors meet data protection standards.	Insurance technology engagements require specific DPA provisions reflecting IRDAI policyholder protection requirements. Policyholder data handled as special category data.	All insurance company engagements involving policyholder personal data.

19.2 Healthcare and Life Sciences — Health Data Standards

Health data is simultaneously the most sensitive category of personal data under both the DPDP Act 2023 and the IT Rules 2011 (as Sensitive Personal Data or Information), and one of the most commercially significant data categories in the company's client portfolio. Healthcare technology, digital health platforms, and life sciences informatics are growing engagement areas that require specific privacy governance provisions beyond the general framework.

The Digital Information Security in Health Act (DISHA) — pending enactment as at the date of this policy — will create a comprehensive regulatory framework specific to digital health data, including the creation of the National Digital Health Authority (NDHA) as the sector regulator. Until DISHA is enacted and in force, health data processing is governed by the DPDP Act 2023 (as the primary framework), the IT SPDI Rules 2011 (for SPDI categories including medical records and health information), and the National Health Authority guidelines for Ayushman Bharat Digital Mission (ABDM) ecosystem participants.

Health Data Context	Specific Obligation	Company Standard	DPIA Required?
Electronic Health Record (EHR) systems — building or operating	Health data in EHR systems is RESTRICTED under both SPDI Rules and DPDP Act. Processing requires explicit written consent from the patient for each category of health data use.	EHR engagements require a patient-facing privacy notice and consent mechanism as a design requirement. Consent records must be maintained and auditable.	Yes — mandatory for all EHR engagements.
Clinical trial data management	Clinical trial data may include genetic information, health outcomes, and identifiable patient data. Processing is subject to ICMR ethical guidelines in addition to DPDP Act.	ICMR ethical approval is a prerequisite for clinical trial data processing engagements. Data sharing agreements must reflect the ethical approval conditions.	Yes — and ICMR ethics committee approval required.
Health analytics and population health management	Aggregate health data analytics may create re-identification risks even where individual records are de-identified.	Anonymisation quality assessment by DPO mandatory before analytics outputs are shared. Minimum cell size requirements applied.	Yes for large-scale health data analytics.
Telemedicine platforms	Doctor-patient consultations generate sensitive health data. Telemedicine Regulations 2020 apply to the underlying service.	Telemedicine platform engagements require compliance with the Telemedicine Practice Guidelines 2020 data provisions. Consultation records classified as RESTRICTED.	Yes.
ABDM / Health ID ecosystem	Ayushman Bharat Digital Mission creates a federated health data architecture. Participants must comply with ABDM data sharing and consent policies.	ABDM ecosystem integrations must implement the ABDM consent manager specifications and the Health Data Management Policy under the ABDM framework.	Yes — in addition to ABDM governance requirements.

19.3 Telecommunications, 19.4 Government, and 19.5 Education

Telecommunications engagements are subject to TRAI regulations on privacy, security, and unsolicited commercial communications. Systems built for telecom clients that process subscriber personal data must comply with the telecom licence conditions relating to data localisation and security. The company's standard DPA for telecom engagements includes specific provisions on subscriber data handling, call record confidentiality, and the prohibition on using telecom subscriber data for purposes beyond the contracted service without subscriber consent. Any engagement involving interconnect or subscriber data sharing must be reviewed by the Legal team before commencement.

Government and public sector engagements present specific data privacy governance requirements arising from MeitY guidelines on government data classification, the Government of India data centre and cloud computing security guidelines, and the Digital India programme data sovereignty requirements. Government client data is classified at least at RESTRICTED level regardless of the government classification label. Government sector engagements require specific security clearances and data localisation commitments. The Legal team reviews all government engagement contracts for data sovereignty and security compliance before contract execution.

Education technology engagements present specific data privacy requirements arising from the sensitivity of student personal data — particularly data relating to minors — and the increasing regulatory attention on EdTech data practices following the National Education Policy 2020. Student data classified as RESTRICTED where it includes academic performance, behavioural assessments, or any other data relating to minor students. Parental consent is required for collection and processing of personal data of students under 18. The company implements the children's data protections in Segment 1, Section 5.5 in full for all EdTech engagements.

20. Enforcement, Regulatory Engagement, and DPBI Interactions

20.1 The Data Protection Board of India — Jurisdiction and Powers

The Data Protection Board of India is established under the DPDP Act 2023 as an independent statutory body with the power to adjudicate complaints from Data Principals, conduct inquiries into alleged violations of the Act, impose financial penalties up to the amounts specified in the Schedule, and issue orders requiring compliance. The DPBI operates independently of the courts — it is an alternative dispute resolution mechanism for data privacy matters, with the right of appeal to the Appellate Tribunal and thereafter to the High Court.

The DPBI has jurisdiction over all Data Fiduciaries and Data Processors who process personal data within India or who process data of Indian Data Principals for offering goods or services in India. The company is subject to DPBI jurisdiction in both its Data Fiduciary capacity (for its own data processing) and, potentially, in its Data Processor capacity where a client complaint about the company's processing of client end-user data reaches the DPBI.

DPBI Power	Scope	Typical Trigger	Company Response Protocol
Adjudication of complaints	Any Data Principal may file a complaint with the DPBI after first exhausting the company's grievance redressal mechanism.	Data Principal complaint to DPBI after the company DPO has not resolved it satisfactorily, or after 30 days without a response.	DPO notified immediately. Legal team engages. Response filed with DPBI within the prescribed timeline. General Counsel leads all DPBI communications.
Inquiry on its own motion	The DPBI may commence an inquiry against a Data Fiduciary on its own initiative — without a complaint — where it has reason to believe a violation has occurred.	Large-scale breach. Media report of privacy violation. Systemic non-compliance pattern. Information from another regulator.	CEO and Board notified. General Counsel leads response. DPO co-ordinates evidence and documentation. External counsel engaged for major inquiries.
Direction to comply	The DPBI may direct a Data Fiduciary to take specific compliance actions — implement security measures, suspend a processing activity, notify affected individuals.	Following an inquiry finding a violation. Interim order during an investigation.	Legal team reviews and implements compliant direction within the prescribed timeline. Board informed of any direction requiring material operational change.
Financial penalties	Penalties up to Rs 250 crore per violation category. The DPBI determines quantum based on statutory factors.	Following a finding of violation in an inquiry.	Legal team leads penalty proceedings. Appeals to Appellate Tribunal considered on legal merits. Board approves settlement vs appeal strategy.
Voluntary undertaking	A Data Fiduciary may offer a voluntary undertaking to the DPBI committing to specific actions.	Where the company believes a voluntary undertaking would resolve a DPBI concern efficiently and favourably.	General Counsel and CEO approve the undertaking before it is offered. Board notified. DPO tracks compliance with undertaking terms.

20.2 Responding to DPBI Complaints and Inquiries

When the company receives notification of a DPBI complaint or inquiry, the following response protocol is activated immediately. The General Counsel takes personal ownership of the response. The DPO assembles the relevant documentation — the Data Protection Register entry for the relevant processing activity, the privacy notice provided to the complainant, all Data Principal rights request records relating to the complainant, the breach register if the complaint relates to a breach, and the DPIA for the relevant processing activity. External data privacy counsel is engaged for DPBI proceedings that could result in a penalty above Rs 10 crore. The CEO is briefed within 24 hours of receiving a DPBI notification. The Board Audit Committee is briefed at the next scheduled meeting or immediately if the potential penalty exceeds Rs 50 crore.

20.3–20.5 Voluntary Undertakings, Regulatory Relationships, and Litigation

The company's approach to regulatory engagement is proactive and transparent. The General Counsel maintains a constructive relationship with MeitY (as the ministry responsible for the DPDP Act), the DPBI (when constituted), and sector regulators with data privacy oversight in the company's client verticals. Proactive engagement includes: participating in industry consultations on data privacy regulations where the company has relevant expertise; submitting comments on draft rules and guidance documents; and attending regulatory seminars and industry working groups on data privacy. This engagement reflects the company's genuine commitment to data privacy as a value, not merely a compliance obligation, and builds the regulatory relationship capital that is valuable when a compliance issue arises.

Where a Data Principal brings civil proceedings against the company arising from a data privacy matter — whether under Section 43A of the IT Act or under other applicable civil law — the Legal team manages the litigation. The DPO provides technical data privacy support to the litigation team. All litigation involving personal data triggers a Legal Hold that suspends normal deletion schedules for the affected data categories until the Legal team releases the hold. Board awareness is required for any litigation with a potential liability exposure above Rs 25 lakh.

21. The Data Privacy Governance Programme

21.1 Programme Structure and Annual Calendar

The data privacy governance programme is the coordinated set of policies, training, auditing, reporting, and continuous improvement activities through which the company builds and maintains its data privacy compliance posture. The programme is owned by the DPO with co-ownership from the VP-HR (for employee data governance) and the Head of IT (for technical security measures). It operates under the strategic oversight of the General Counsel, the CEO, and the Board Audit Committee.

Month	Activity	Audience	Owner	Output
April	Annual policy review effective date. Updated privacy notices published. Employee awareness communication from CEO.	All employees	DPO + General Counsel	Updated policy live on HRMS. Privacy notices on website updated.
May	Data privacy mandatory training module available in HRMS. Previous year deletion audit initiated.	All employees (training). DPO (audit).	DPO + HRBP Operations	Training completion tracking begins. Deletion audit report by June.
June	Deletion audit report completed. Processor register annual review for RESTRICTED data processors.	DPO (audit). Legal team (processor review).	DPO	Deletion audit report. Processor register updated.
July	Q2 DPO governance report to General Counsel. DPIA register review.	General Counsel. DPO.	DPO	Q2 governance report. DPIA register current.
August	Breach register half-year review. Training completion chase for outstanding employees.	DPO (breach review). HRBP (training chase).	DPO	Breach register reviewed. Training completion rate reported.
September	Mandatory training completion deadline — all employees.	All employees	DPO + HRBP Operations	Training completion certificate.
October	Annual data privacy audit commences. Audit Committee receives Q3 governance report.	DPO (audit). Audit Committee.	DPO + External Auditor (if engaged)	Audit commencement. Q3 report to Audit Committee.
November	Annual data privacy audit completed. Draft audit report reviewed by General Counsel.	DPO + General Counsel	DPO	Draft audit report.
December	Final audit report to Audit Committee. CEO Annual Data Privacy Certification.	Audit Committee. CEO.	DPO + General Counsel	Final audit report. CEO certification completed.
January	Policy review initiated. DPIA register annual review.	DPO + Legal team	General Counsel	Policy review findings. DPIA register reviewed.
February	Draft updated policy circulated for review and comment. Processor register annual review for CONFIDENTIAL data processors.	Legal team. VP-HR. Head of IT.	DPO	Draft updated policy. Processor register updated.

Month	Activity	Audience	Owner	Output
March	Updated policy approved by CEO. All-employee communication drafted for April effective date.	CEO + Board (for material changes). All employees.	General Counsel + DPO	Approved policy. Communication ready.

21.2 Mandatory Training — Curriculum and Delivery

The company's mandatory data privacy training programme comprises six modules covering the full spectrum of data privacy obligations relevant to different employee populations. The core module (Module 1) is mandatory for all employees; the remaining modules are mandatory for the specific populations indicated. All modules are delivered through the HRMS learning management system and must be completed within the deadlines set out in Section 9.3 of Segment 2. The DPO reviews and updates each module annually to reflect any regulatory changes and to incorporate lessons from the preceding year's breach incidents and DPBI developments.

Module	Title	Audience	Duration	Key Content	Annual Deadline
Module 1	DPDP Act 2023 and Data Privacy Fundamentals	All employees	45 min	DPDP Act overview. Classification scheme. Handling standards summary. Breach reporting obligation. Data Principal rights.	30 September
Module 2	Data Privacy for HR and People Management	All HRBP, HR Operations, Payroll, TA	60 min	Employee data handling. Medical certificate protocols. Recruitment data obligations. Consent for optional processing. Rights requests for employment data.	31 July
Module 3	Data Privacy for Software Engineers and Data Professionals	All engineers, data scientists, ML engineers, IT	60 min	Privacy by Design. Developer obligations. Encryption standards. No real data in dev/test. Logging for accountability. AI and personal data.	31 July
Module 4	Data Privacy for Client-Facing and Commercial Roles	Account managers, engagement managers, BDMs, consulting	60 min	Client data as processor. DPA obligations. Data minimisation in client engagements. Sector-specific obligations overview. Breach notification to clients.	31 August
Module 5	Data Privacy for Managers and Team Leads	All Band 4+ managers	45 min	Manager obligations. Approving new tools. Ensuring no real data in test environments. Recognising breach indicators. Escalation to DPO.	31 August
Module 6	Advanced Data Privacy — DPO and Legal Team	DPO and Legal team	External certification programme (CIPP/A, FIP, or equivalent)	Full DPDP Act technical competency. DPBI procedures. DPIA facilitation. SCC management. Cross-border transfer assessment.	Ongoing CPD

21.3 Data Privacy Culture — Beyond Compliance

A data privacy programme that is experienced by employees as a compliance obligation rather than a shared value will be less effective than one in which the reasoning behind the obligations is genuinely understood and the protection of individuals' personal data is seen as part of professional identity — not just a rule to follow. The DPO's communications programme aims to build this cultural dimension through the following mechanisms: the annual CEO communication on data privacy (sent in April with the updated policy, framing data privacy as a professional and

ethical commitment, not just a legal one); data privacy as a standing agenda item in the Ethics Champions network quarterly briefings; case studies from real (anonymised) company incidents shared in the annual training to make the abstract concrete; recognition of employees who report potential breaches promptly and in good faith; and the explicit link between data privacy compliance and the Values and Conduct competency in the annual performance assessment.

21.4 Annual Data Privacy Audit — Scope and Process

The annual data privacy audit is conducted in October and November of each year by the DPO, supported by an external data privacy auditor where the Audit Committee requires independent assurance. The audit scope covers the full data privacy programme: policy currency and completeness; Data Protection Register accuracy; DPIA completion and quality; processor register and DPA status; breach register and response quality; Data Principal rights request handling; deletion audit completion; training completion rates; and the specific sector-specific obligations relevant to the year's major client engagements. The audit methodology combines document review, system access testing, staff interviews, and technical security assessment (in co-ordination with the annual IT security audit).

Audit Area	Assessment Method	Key Questions	Output
Data Protection Register	Review completeness against company processing inventory. Cross-check with IT system inventory.	Is every significant processing activity documented? Are purposes, legal bases, and retention periods current?	Register gap analysis. Update recommendations.
DPIA register	Review all DPIAs completed in the year. Assess quality against DPIA template standard. Confirm mitigations are implemented.	Were all required DPIAs conducted? Were mitigations actually implemented? Are any DPIAs overdue for review?	DPIA quality report. Overdue DPIA list.
Processor register and DPAs	Review DPA status for all active processors. Confirm certifications are current.	Do all active processors have current DPAs? Are any certifications expired? Are sub-processor lists current?	Processor compliance status report.
Breach register and response quality	Review all breach incidents in the year. Assess response against policy timelines. Confirm remediation actions are complete.	Were breaches reported promptly? Were notifications made within timelines? Is remediation complete?	Breach response quality assessment.
Data Principal rights requests	Review all rights requests in the year. Assess response times against policy standards.	Were all requests acknowledged within 48 hours? Were responses provided within 30 days? Were any requests improperly refused?	Rights request compliance report.
Training completion	HRMS training completion data for all mandatory modules.	What is the completion rate for each module? Which business units have the lowest completion rates?	Training compliance report with BU-level detail.
Technical security measures	IT Security provides evidence of encryption implementation, access control configuration, and deletion procedure execution.	Are the technical measures described in Segment 2 actually implemented in all relevant systems?	Technical compliance evidence pack.

21.5 Continuous Improvement and 21.6 Metrics

The data privacy programme improves continuously through the annual audit findings, the lessons identified in breach incidents and near-misses, the regulatory developments tracked by the Legal team, employee feedback collected through the annual Ethics Culture Survey, and the benchmarking of the company's programme against industry peers

and international best practice. Each annual audit generates a Remediation Action Plan with specific improvements, owners, and deadlines that is tracked by the DPO and reported quarterly to the General Counsel until all actions are closed.

Metric	Definition	Target	Reporting Frequency	Audience
Policy acknowledgement rate	% of employees who have acknowledged the current version of all three policy segments.	100% within 30 days of effective date.	Monthly	VP-HR + DPO
Mandatory training completion rate	% of employees who have completed all mandatory modules assigned to their role.	100% by annual deadline. Above 95% at mid-year check.	Monthly	DPO + HRBP
DPIA completion rate	% of processing activities meeting DPIA trigger criteria that have a completed, current DPIA.	100%	Quarterly	DPO + General Counsel
Processor DPA coverage	% of active data processors with a current DPA in place.	100%	Quarterly	DPO
Breach response timeliness	% of reported breaches where DPBI notification (where required) was made within 72 hours of company awareness.	100%	Per incident + annual	DPO + General Counsel + Audit Committee
Rights request response timeliness	% of Data Principal rights requests responded to within 30 days.	100%	Monthly	DPO
Annual deletion audit completion	Annual deletion audit completed within the scheduled window (October/November).	100% on schedule.	Annual	DPO + Audit Committee
Training completion — high-risk roles	% of employees in high-risk roles (HR, engineering, client-facing) completing role-specific modules.	100% by deadline.	Monthly	DPO + BU Heads

22. Enforcement Scenarios and Company Response Playbook

The following scenarios address enforcement situations the company may face under the DPDP Act 2023. Each scenario sets out the recommended response protocol. In all enforcement scenarios, the General Counsel takes personal ownership and the DPO provides technical data privacy support.

Scenario	Facts	Company Response Protocol
1 — DPBI complaint from a former employee	A former employee who left 18 months ago files a complaint with the DPBI claiming the company failed to respond to their data access request sent 6 weeks ago.	The DPO checks the rights request register immediately. If the request was received and not responded to: acknowledge the failure, respond within 48 hours with the full access response, and notify the DPBI that the matter has been resolved. If the request was not received: investigate why (junk mail filtering, wrong email address) and demonstrate this to the DPBI with evidence. In both cases: implement a process improvement to prevent recurrence. General Counsel manages DPBI communication. Response filed within the DPBI prescribed timeline. (Section 20.2 and Section 7.8 of Segment 1.)
2 — DPBI initiates own-motion inquiry following a media report	A technology news outlet reports that an Arjun Technologies employee left a laptop containing client data on a train. The DPBI sees the report and opens an inquiry.	The DPO and General Counsel are notified immediately. CEO briefed within 4 hours. Verify whether the incident was reported and managed per the breach protocol (Section 10 of Segment 2). If DPBI notification was required and was made: provide the DPBI with the breach report and response documentation. If notification was not made when it should have been: make immediate voluntary notification to the DPBI and acknowledge the delay. Engage external data privacy counsel. Board informed within 24 hours. Full cooperation with DPBI inquiry. (Section 20.1.)
3 — Client receives a DPBI complaint from one of their customers about data processed by the company	A fintech client receives a DPBI complaint from a customer about inaccurate personal data in the account aggregator system built by the company. The client asks the company to provide the relevant data and correction.	The company is a Data Processor in this engagement — the client is the Data Fiduciary and must respond to the DPBI. The company supports the client as required under the DPA: provides the relevant data extract, assists with the correction if the inaccuracy is in company-managed systems, and documents all support actions. The DPO co-ordinates with the account manager and the client HRBP. The company does not communicate directly with the DPBI in its processor capacity except where the DPBI specifically directs it to do so. (Section 19.1 and DPA obligations.)

Scenario	Facts	Company Response Protocol
4 — RBI audit of a banking client identifies data localisation gap in company systems	An RBI inspection of a banking client finds that customer transaction data processed by the company is being temporarily cached in a Singapore-based load balancer before being written to the India-hosted database.	The company acknowledges the gap to the client immediately. The engineering team implements a fix to remove the non-India caching within the agreed remediation timeline. The DPO conducts a Transfer Risk Assessment for the temporary caching arrangement to confirm the risk profile. The client is supported in responding to the RBI with the company remediation plan. A broader review of all financial services client system architectures is conducted to identify any similar data localisation gaps. (Section 18 and Section 19.1.)
5 — Employee reports that a colleague photographed HRMS screens showing health data	An employee reports to the HRBP that they saw a colleague photographing their laptop screen which was displaying HRMS health data fields for multiple employees.	The HRBP notifies the DPO and the Head of IT immediately. IT Security reviews the HRMS access logs to determine what health data fields were visible and which employees are affected. This is a potential breach of RESTRICTED personal data — the DPO applies the severity classification (likely HIGH given health data involved). Breach protocol activated (Section 10 of Segment 2). The colleague is interviewed under a conduct investigation. The DPO assesses DPBI notification obligation. The affected employees (whose health data was photographed) are informed if the DPO determines significant harm is likely. The conduct investigation proceeds under the Code of Conduct. (Section 10 of Segment 2 and Code of Conduct Section 14.)

23. Data Privacy Governance Programme — Full Annual Compliance Checklist

This checklist is completed by the DPO in conjunction with the annual audit (October/November). It provides a comprehensive view of the compliance programme status across all three policy segments. Results are reported to the Audit Committee in December.

Programme Element	Compliance Check	Status	Evidence Required
Policy currency	All three policy segments reflect the current legal framework as at the review date. All changes since the last version have been incorporated.	● Compliant ● Gaps identified:	DPO sign-off on policy currency. Legal team confirmation.
Data Protection Register	100% of significant processing activities documented. All entries current (purpose, legal basis, retention period, security measures).	● Compliant ● Gaps:	Register extract. DPO review record.
DPIA register	All processing activities meeting DPIA trigger criteria have completed DPIAs. All DPIAs reviewed on schedule.	● Compliant ● Overdue DPIAs:	DPIA register. DPO review dates.
Processor register and DPA coverage	100% of active processors have current DPAs. All DPA certifications current.	● Compliant ● Processors without current DPA:	Processor register. DPA date log.
Mandatory training completion	All employees have completed all mandatory modules by the annual deadline.	● Compliant ● % incomplete:	HRMS training completion report.
Policy acknowledgement	All employees have acknowledged all three segments of the current policy version.	● Compliant ● % outstanding:	HRMS acknowledgement report.
Breach register	All breach incidents documented. All required DPBI notifications made within 72-hour window. All remediation actions complete.	● Compliant ● Open items:	Breach register extract.
Rights request register	All Data Principal rights requests responded to within 30-day timeline.	● Compliant ● Overdue items:	Rights request register.
Annual deletion audit	Deletion audit completed for prior financial year. All overdue deletions performed.	● Complete ● Pending:	Deletion audit report.
Cross-border transfer register	All cross-border transfers documented. Transfer Risk Assessments current. SCCs/IDTAs executed where required.	● Compliant ● Gaps:	Transfer register. SCC log.
Sector-specific obligations	All financial services, healthcare, government, and other sector-specific requirements met for current client engagements.	● Compliant ● Issues:	Client engagement compliance confirmation from BU Heads.
Privacy by Design adoption	PbD checklist in use for all new processing activities meeting the criteria. DPO involved in design reviews.	● Compliant ● Gaps:	PbD checklist completion log. DPO design review records.
AI and personal data governance	Approved Tools Register current. No prohibited AI tool use reported. AI DPIA programme current.	● Compliant ● Issues:	Approved Tools Register. IT Security confirmation.

Programme Element	Compliance Check	Status	Evidence Required
Employee Privacy Notice currency	Employee Privacy Notice current and reflects current processing activities.	● Compliant ● Update required:	DPO privacy notice review record.
Overall compliance assessment	Overall programme compliance level	● FULLY COMPLIANT ● SUBSTANTIALLY COMPLIANT ● MATERIAL GAPS IDENTIFIED	DPO annual certification. Audit Committee report.

24. Data Privacy Policy — Regulatory Change Monitoring

Data privacy law in India is evolving rapidly. The DPDP Act 2023 is a framework law whose operational detail will be determined by Rules, orders, and guidance from the Central Government and the Data Protection Board of India. The company must monitor regulatory developments continuously and update its programme accordingly — a policy that is accurate today may require amendment within months as the Rules are published and the DPBI begins operating. The following table identifies the key regulatory developments the Legal team is monitoring as at April 2024.

Regulatory Development	Current Status (April 2024)	Expected Timeline	Company Impact	Monitoring Owner
DPDP Act 2023 commencement notification	Act has received presidential assent (August 2023). Commencement date not yet notified. Company treating Act as operationally effective.	Expected H1 or H2 2024. No official date confirmed.	Full legal compliance obligations activated on notification date. Company already compliant.	General Counsel. Policy update within 30 days of notification.
Digital Personal Data Protection Rules	Draft Rules published for public consultation (January 2025 draft). Final Rules awaited.	Final Rules expected within 6 months of commencement notification.	Rules will specify: DPBI constitution, consent manager registration, approved country list for cross-border transfers, Significant Data Fiduciary criteria, breach notification timelines.	DPO monitors. Policy update within 60 days of Rules publication.
Approved country list for cross-border transfers (DPDP Act Section 16)	No country list notified as at April 2024. Company applying risk-based interim approach.	Expected with or shortly after Rules publication.	Company cross-border transfer approach will need to be updated once the list is published. Current interim framework replaced by the official list.	DPO monitors. Transfer policies updated within 30 days of list publication.
Data Protection Board of India constitution	DPBI not yet constituted as at April 2024.	Expected within 6 months of commencement notification.	Once constituted, the DPBI can receive Data Principal complaints and conduct inquiries. Company grievance process must be fully operational before DPBI opens.	DPO monitors. DPO portal and grievance process confirmed operational.
Digital Information Security in Health Act (DISHA)	Pending enactment. Draft circulated in 2022. No Bill tabled as at April 2024.	Timeline uncertain. May be tabled in 2024 or 2025.	When enacted, DISHA will create sector-specific health data obligations beyond the DPDP Act for healthcare technology engagements.	Legal team monitors. Healthcare engagement DPIAs include DISHA readiness assessment.
Significant Data Fiduciary criteria	Criteria not yet published. Expected in Rules.	With Rules publication.	If company is designated an SDF: additional obligations including mandatory data auditor appointment, additional DPIAs, enhanced DPO requirements.	DPO monitors. Proactive SDF programme already in place.

25. Data Privacy Maturity Model — Company Self-Assessment

The data privacy maturity model provides a structured framework for assessing the company data privacy programme against five levels of maturity. It is used as a self-assessment tool in the annual audit and as a roadmap for continuous improvement. The DPO completes the maturity assessment annually and presents the results to the Audit Committee alongside the audit report.

Maturity Level	Description	Characteristics	Company Status (April 2024)
Level 1 — Ad Hoc	Privacy is addressed reactively. No formal programme. Compliance depends on individuals.	No written policy. No DPO. Breaches handled informally. No DPIA process. Training absent.	Not applicable — company is above Level 1.
Level 2 — Developing	Basic privacy policy exists. Some procedures in place. Compliance is inconsistent.	Written policy but not fully implemented. DPO role informally assigned. Some training. Breach process exists but not consistently followed.	Not applicable — company is above Level 2.
Level 3 — Defined	Formal privacy programme with documented procedures. Consistent implementation across most areas. DPO appointed with defined authority.	Comprehensive written policy. Formal DPO. DPIA process in use. Mandatory training delivered. Processor register maintained. Breach register current.	Company meets Level 3 fully. All core elements in place and operating.
Level 4 — Managed	Privacy programme is measured and monitored. Data-driven management. Continuous improvement based on metrics and audit findings.	All Level 3 characteristics plus: formal metrics dashboard. Annual audit. Privacy by Design embedded. Benchmarking against industry. Regulatory engagement proactive.	Company substantially meets Level 4. Metrics dashboard active. Annual audit programme in place. Some PbD gaps being addressed in H2 2024.
Level 5 — Optimised	Privacy is fully embedded in organisational culture and design. Innovation in privacy-enhancing technologies. Leading industry practice.	All Level 4 characteristics plus: Privacy Enhancing Technologies (PETs) deployed. Privacy culture survey demonstrates genuine employee ownership. External recognition as privacy-responsible organisation.	Company is working toward Level 5. PET evaluation underway. Ethics Culture Survey privacy dimension being developed. Target: Level 5 by FY2025-26.

25.1 Improvement Roadmap — FY2024-25 Priorities

Based on the annual audit findings and the maturity assessment, the following priorities have been identified for the FY2024-25 programme year. Each priority has an owner, a target completion date, and a success measure. Progress is reviewed quarterly by the DPO and reported to the General Counsel.

Priority	Description	Owner	Target Date	Success Measure
HRMS automated deletion	Implement automated deletion in HRMS for employee records at the 7-year post-employment retention trigger. Currently requires manual action.	Head of IT + DPO	Q3 FY2024-25 (December 2024)	Automated deletion running for the first cohort of eligible records. Manual deletion process retired.

Priority	Description	Owner	Target Date	Success Measure
Privacy by Design in Jira	Embed the PbD checklist as a mandatory Jira epic template for all new projects involving personal data processing. Currently optional.	DPO + Head of Engineering	Q2 FY2024-25 (September 2024)	PbD checklist completion rate above 90% for qualifying new projects.
Consent Manager interface development	Develop technical interface capability to connect company products to Consent Manager platforms as the DPBI Consent Manager ecosystem becomes operational.	Head of IT + DPO + product teams	Q4 FY2024-25 (March 2025) — subject to Consent Manager framework publication	Technical interface specification completed and approved by DPO. Ready for integration when first Consent Manager is registered.
Privacy Enhancing Technologies evaluation	Evaluate the applicability of differential privacy, federated learning, and synthetic data generation as PETs for the company analytics and AI workloads.	DPO + Head of Data Science	Q3 FY2024-25	PET evaluation report produced. At least one PET pilot commenced for an identified use case.
Ethics Culture Survey — privacy dimension	Add a dedicated privacy culture dimension to the annual Ethics Culture Survey measuring employee understanding, confidence, and genuine ownership of data privacy obligations.	DPO + VP-HR	Q4 FY2024-25 (in time for the FY2024-25 annual survey)	Privacy culture questions added to survey. Baseline score established. Business unit-level results available to DPO and BU Heads.
Sector-specific DPIA library	Develop standard DPIA templates for the five most common sector-specific engagement types (fintech, healthcare, government, telecom, edtech) to reduce DPIA preparation time for new engagements.	DPO + Legal team	Q2 FY2024-25	Five sector templates available on HRMS Legal Documents portal. Engagement teams briefed.

26. Cross-Document Policy Consistency — Final Verification Table

This table verifies consistency between the Data Privacy Policy (all three segments) and the other principal company policies as at April 2024. The Legal team and HRBP Operations review this table annually as part of the policy review process.

Topic	DPP Reference	Cross-Document Reference	Consistency Status
Health data handling — access restricted to HRBP only	Segment 2, Section 9.1; Segment 1, Section 6.3	Leave and Attendance Policy Segment 1, Section 3.9; PMP Segment 4, Section 17.1	Consistent — all three documents confirm that line managers do not access medical certificate content; HRBP only.
Employee monitoring — no productivity surveillance	Segment 2, Section 12.4	Code of Conduct Section 10.1 (dignity at work); PMP Section 18.2 (matrix performance — visibility-based assessment risks)	Consistent — all documents prohibit surveillance-based performance management. PMP references the specific risk of visibility bias in matrix structures as distinct from surveillance.
AI tools — no personal data in unapproved tools	Segment 2, Section 17	Code of Conduct Section 10.3 (AI ethics)	Consistent — CoC Section 10.3 and DPP Segment 2 Section 17 both prohibit use of unapproved AI tools for personal or confidential data. DPP provides the privacy law basis; CoC provides the values basis.
Data breach reporting — immediate, no blame	Segment 2, Section 10.2	Code of Conduct Section 8 (speak up provisions); IT Security Policy Section 12	Consistent — all three documents reinforce prompt reporting as the right behaviour and confirm that good-faith reporting does not lead to adverse consequences.
DPDP Act consent standards	Segment 1, Section 5.1	Leave and Attendance Policy Segment 1, Section 3.9 (health data consent); PMP Segment 4, Section 22.3 (BGV consent)	Consistent — all references to consent in other policies are consistent with the five-element DPDP Act consent standard in DPP Segment 1.
Cross-border transfer of employee data during international assignments	Segment 3, Section 18.5	Leave and Attendance Policy Segment 3, Section 23.5	Consistent — both documents require a Transfer Risk Assessment and DPA with local HR/payroll providers before employee data is transferred to the host country.
Whistleblower hotline — data privacy concerns	Segment 1, Section 4.3 (DPO contact); Segment 3, Section 20 (enforcement)	Code of Conduct Section 19 (Whistleblower provisions)	Consistent — DPP directs anonymous data privacy concerns to ethics@arjuntech.in, which is the same Whistleblower channel referenced in the Code of Conduct.
Retention of recruitment data	Segment 2, Section 13.2 (6 months for unsuccessful candidates without consent)	Onboarding SOP Segment 1, Section 2.3 (pre-joining documentation)	Consistent — Onboarding SOP confirms candidate data is retained during the recruitment process. DPP specifies the post-process retention period.

Sector Obligations Reference — Detailed Compliance Standards

The following detailed reference consolidates the sector-specific data privacy obligations most relevant to the company current engagement portfolio. It supplements Section 19 with the operational detail needed by engagement managers and their technical teams when setting up new client engagements.

Obligation	Applicable Sector	Regulatory Source	Company Implementation Standard	DPIA Required?
Payment data must be stored only in India	Banking, fintech, payment systems	RBI Storage of Payment System Data circular (2018)	All payment data processed in client systems built by the company must be stored in India-hosted infrastructure. No transit through foreign servers. Architecture reviewed by DPO at design stage.	Yes — for every new payment system engagement.
Account Aggregator consent framework compliance	Banking, NBFC, insurance, mutual funds — any AA ecosystem participant	RBI Account Aggregator Master Direction 2016 as amended. Sahamati/ReBIT technical standards.	Systems built for FIPs and FIUs must implement the AA consent artefact standard — signed consent objects, consent expiry, consent revocation. DPO reviews consent architecture before go-live.	Yes — AA engagement DPIA mandatory.
Bank-grade security for core banking and payment systems	Banks, NBFCs, payment system operators	RBI Master Direction on Digital Payment Security Controls (2021). RBI Cyber Security Framework for Banks.	Penetration testing by CERT-In empanelled auditor annually. Vulnerability assessment quarterly. Security findings remediated within timelines specified in the RBI framework. Audit reports available to banking clients on request.	Yes — annual security DPIA for ongoing banking engagements.
Policyholder data treated as special category	Insurance	IRDAI Protection of Policyholders Interests Regulations. SPDI Rules 2011 (medical data).	All insurance engagement DPAs specify that policyholder data is classified RESTRICTED. Health data (medical history, claims) requires explicit policyholder consent for sharing. No policyholder data shared between the company and third parties without the insurer authorisation.	Yes — for health insurance technology engagements.
Government data classified at RESTRICTED minimum	Central and state government, PSUs, statutory bodies	MeitY Government Data Classification Policy. National Informatics Centre cloud guidelines.	All government engagement data classified RESTRICTED regardless of government label. India-only cloud hosting mandatory. No transfer outside India without explicit government client approval and Legal team review.	Yes — for all government engagements.
Student data — parental consent for minors	Education technology, school and college management systems	DPDP Act 2023 Section 9. NEP 2020 data governance provisions.	EdTech systems accessible to students under 18 must implement age verification. Parental consent mechanism required for collection of any personal data of students under 18. No tracking, behavioural monitoring, or targeted advertising for minors.	Yes — mandatory for all EdTech engagements involving minors.
Subscriber data confidentiality — telecom	Telecom operators, ISPs, OTT service providers	TRAI Telecom Commercial Communications Customer Preference Regulations. IT Act Section 72A.	Telecom subscriber personal data treated as RESTRICTED. Call data records (CDRs) accessible only to personnel with specific operational need. No commercial use of subscriber data without subscriber consent. Engagement DPA specifies CDR handling restrictions.	Yes — for telecom subscriber data analytics engagements.

Obligation	Applicable Sector	Regulatory Source	Company Implementation Standard	DPIA Required?
ABDM Health ID ecosystem — consent compliance	Healthcare providers, health technology platforms, ABDM ecosystem participants	National Health Authority Health Data Management Policy. ABDM Consent Manager specifications.	ABDM-integrated systems must implement the ABDM consent artefact standard. Personal Health Record (PHR) data handled as RESTRICTED. No sharing of health data outside the ABDM consent framework without patient consent.	Yes — mandatory for all ABDM integration engagements.
Clinical trial data — ICMR ethics compliance	Pharmaceutical, CROs, hospital research departments	ICMR National Ethical Guidelines for Biomedical and Health Research. New Drugs and Clinical Trials Rules 2019.	Clinical trial data processing requires ICMR institutional ethics committee approval as a prerequisite. Patient consent for data processing must meet ICMR standards (which are stricter than standard DPDP Act consent for clinical research contexts). Data pseudonymised in transit and at rest. No patient-identifiable data in analysis outputs.	Yes — DPIA plus ICMR ethics approval.

Data Privacy Policy — Complete Document Certification

This final certification page confirms that all three segments of the Data Privacy Policy and Procedures Framework have been reviewed, approved, and certified as current as at 01 April 2024. The complete framework represents the company definitive statement of its data privacy obligations, standards, and governance programme.

Document Component	Status	Certifying Party	Date
Segment 1 — Foundational Framework (Sections 1–7)	Published and effective	General Counsel + DPO	01 April 2024
Segment 2 — Operational Standards (Sections 8–17)	Published and effective	General Counsel + DPO + Head of IT	01 April 2024
Segment 3 — Transfers, Enforcement, Governance (Sections 18–26 + Appendices A–H)	Published and effective	General Counsel + DPO	01 April 2024
Employee Privacy Notice (HR-PN-001-v2.1)	Published on HRMS and provided to all employees	DPO + VP-HR	01 April 2024
Candidate Privacy Notice (HR-PN-003-v1.2)	Published in recruitment application process	DPO + TA Lead	01 April 2024
Standard Data Processing Agreement (LEGAL-DPA-001-v3.1)	Current — reviewed for DPDP Act compliance	General Counsel	01 April 2024
Data Protection Register	Current as at audit date — 14 processing activities documented	DPO	01 April 2024
DPIA Register	Current — 8 active DPIAs; 2 in progress	DPO	01 April 2024
Processor Register	Current — 23 active processors; all with DPAs except 3 in renewal	DPO + Legal team	01 April 2024
Breach Register	Current — 4 incidents in FY2023-24; all closed; remediation complete	DPO	01 April 2024
Mandatory Training Programme	Modules 1–5 updated for DPDP Act. Available in HRMS from 01 April 2024.	DPO + HRBP Operations	01 April 2024

Role	Name	Signature	Date
Chief Executive Officer — Final Approval	Mr. Rajesh Arjun		01 April 2024
General Counsel — Document Owner	Mr. Sandeep Iyer		01 April 2024
Data Protection Officer	Designated Legal Team Member		01 April 2024
VP Human Resources — Employee Data Provisions	Ms. Priya Menon		01 April 2024
Head of IT / CISO — Technical Measures	Mr. Kiran Bhat		01 April 2024
Chief Financial Officer — Financial Data Provisions	Ms. Lakshmi Rajan		01 April 2024

Complete Data Privacy Policy — LEGAL-POL-004-v2.1 (Three Segments). Effective 01 April 2024. Owner: Mr. Sandeep Iyer, General Counsel. DPO: dpo@arjuntech.in. Approved: Mr. Rajesh Arjun, CEO. For queries: legal@arjuntech.in. For anonymous concerns: ethics@arjuntech.in. All segments on HRMS portal under Policies and Documents.

Appendix A: Data Protection Impact Assessment (DPIA) Template

Complete this template for every processing activity meeting the DPIA trigger criteria in Section 14.1 of Segment 2. Submit to DPO for review before processing commences. All six steps must be completed.

DPIA TEMPLATE — LEGAL-DPA-DPIA-001	Version 2.1 | April 2024
Processing Activity Name	
Business Unit / Engagement	
DPO Reference Number	Assigned by DPO on receipt
STEP 1 — SCOPE	
What personal data is being processed? (categories, approximate volume)	
Who are the Data Principals?	
What is the stated processing purpose?	
What systems and teams are involved?	
What is the intended retention period?	
STEP 2 — NECESSITY AND PROPORTIONALITY	
Is the processing necessary for the stated purpose?	● Yes ● No (reconsider)
Could the purpose be achieved with less personal data?	● No — all data elements are necessary ● Yes — reduce as follows:
Could the purpose be achieved without cross-border transfer (if applicable)?	● No ● Yes — revise design
STEP 3 — RISK IDENTIFICATION	
Risk 1: Description / Affected individuals / Likelihood (H/M/L) / Impact (H/M/L)	
Risk 2: Description / Likelihood / Impact	
Risk 3: Description / Likelihood / Impact	
STEP 4 — RISK MITIGATION	
Mitigation for Risk 1: Measure / Owner / Deadline / Residual Risk	
Mitigation for Risk 2	
Mitigation for Risk 3	
STEP 5 — RESIDUAL RISK ASSESSMENT	
Overall residual risk after mitigations	● LOW — acceptable to proceed ● MEDIUM — proceed with conditions ● HIGH — General Counsel / DPBI consultation required
Conditions (if MEDIUM)	
STEP 6 — SIGN-OFF	
Product / Engagement Lead Signature	Date:
DPO Review and Approval Signature	Date:
General Counsel Sign-Off (HIGH residual risk)	Date:

DPIA TEMPLATE — LEGAL-DPA-DPIA-001	Version 2.1 | April 2024
Implementation Checklist Confirmed at Go-Live	Date:

Appendix B: Data Processing Agreement — Key Clauses Summary

The company's full Standard Data Processing Agreement (LEGAL-DPA-001-v3.1) is available from the Legal team and on the HRMS portal under Legal Documents. The following table summarises the nine mandatory clauses and their key content for quick reference. All nine clauses must be present in any DPA executed by the company — whether using the company's standard template or a processor's own template.

Clause	Mandatory Content	Basis
1. Processing Instructions	Processor must only process personal data as specifically instructed by the company. No processing outside instructions without written company authorisation.	DPDP Act processor obligations; GDPR Article 28(3)(a)
2. Confidentiality	All processor personnel with access to personal data must be bound by written confidentiality obligations.	GDPR Article 28(3)(b); DPDP Act security obligation
3. Security Measures	Processor implements appropriate technical and organisational security measures. Minimum: AES-256 encryption at rest; TLS 1.2+ in transit; access controls; MFA for privileged access.	DPDP Act Section 8(5); GDPR Article 32
4. Sub-Processing	No sub-processors without prior written company consent. Sub-processors bound by equivalent DPA obligations. Sub-processor list disclosed and kept current.	GDPR Article 28(2) and (4); DPDP Act flow-down obligations
5. Data Principal Rights Assistance	Processor assists company in fulfilling Data Principal rights requests — access, correction, erasure, grievance.	DPDP Act Data Principal rights; GDPR Article 28(3)(e)
6. Breach Notification	Processor notifies company within 24 hours of becoming aware of any actual or suspected personal data breach involving company personal data.	GDPR Article 33(2); DPDP Act breach notification
7. Audit Rights	Company has the right to audit processor's DPA compliance on reasonable notice (typically 30 days). May use an independent auditor.	GDPR Article 28(3)(h); DPDP Act accountability principle
8. Data Return / Deletion	At engagement end, processor returns all company personal data to the company or deletes it, and certifies deletion in writing within 30 days.	GDPR Article 28(3)(g); DPDP Act storage limitation
9. Liability	Processor is liable for damage caused by processing not in accordance with the DPA. Indemnification for company liability arising from processor breach of DPA.	GDPR Article 82; DPDP Act liability provisions

Appendix C: Employee Privacy Notice (Summary)

The full Employee Privacy Notice (HR-PN-001-v2.1) is provided to all employees at joining and is available on HRMS under Policies and Documents. This appendix provides a structured summary of its key content for quick reference.

EMPLOYEE PRIVACY NOTICE — KEY CONTENT SUMMARY	HR-PN-001-v2.1 | Effective 01 April 2024
Who processes your data	Arjun Technologies Pvt. Ltd., Bengaluru (Data Fiduciary). DPO: dpo@arjuntech.in
What personal data we collect	Identity and contact details. Employment contract details. Salary and bank details. Tax information (PAN, TDS). Leave and attendance records. Performance assessments. Health information (sick leave and medical certificates — access restricted to HRBP). Disciplinary records (where applicable). Emergency contact details. IT system usage logs (security monitoring only).
Why we process your personal data	Employment contract performance. Legal obligations (tax, PF, ESI, statutory filings). Legitimate use — HR management, performance management, security, safety. Consent — for optional processing activities (diversity monitoring surveys, optional benefits, talent pool retention after employment ends).
How long we retain your data	Employment duration plus 7 years for most records (tax law and employment claim limitation periods). Health data: same retention period, access restricted to HRBP. Payroll: 7 years from financial year of payment. See Data Retention Schedule in Segment 3 Appendix H for full details.
Who we share your data with	Finance software provider (SAP) — payroll processing. Government portals (EPFO, TRACES, ESIC) — statutory filing. External auditors — annual audit. Background verification provider — pre-employment and periodic checks (with your consent). Benefits providers — health insurance, EAP (with your consent for optional benefits).
Your rights	Right of access: request a summary of your personal data — contact dpo@arjuntech.in. Right of correction: request correction of inaccurate data. Right of erasure: after retention period expires. Right of grievance: contact dpo@arjuntech.in. Right to nominate: nominate someone to exercise your rights if you are incapacitated.
How to contact us	DPO: dpo@arjuntech.in. General Counsel: legal@arjuntech.in. Escalation to DPBI: after exhausting company grievance process.

Appendix D: Candidate Privacy Notice (Summary)

CANDIDATE PRIVACY NOTICE — KEY CONTENT SUMMARY	HR-PN-003-v1.2 | Effective 01 April 2024
Who processes your data	Arjun Technologies Pvt. Ltd. (Data Fiduciary). DPO: dpo@arjuntech.in
What data we collect	CV and application materials. Interview notes and assessments. References and background verification results (with your consent). Test and assessment scores. Correspondence during the recruitment process.
Why we collect it	To assess your suitability for the role applied for. To conduct pre-employment background checks (with your consent). To make an offer and commence employment (if selected).
How long we retain it	Successful candidates: data transferred to employee record (see Employee Privacy Notice). Unsuccessful candidates with consent to retain: 2 years. Unsuccessful candidates without consent: 6 months from rejection.
Sharing	Background verification provider (with your consent). Hiring manager and interview panel. HRBP. No sharing with third parties for marketing or other purposes.
Your rights	Access, correction, erasure (after retention period), grievance. Contact dpo@arjuntech.in.
Withdrawing consent	You may withdraw consent for talent pool retention at any time. Request deletion via dpo@arjuntech.in.

Appendix E: Consent Record Form

CONSENT RECORD FORM — LEGAL-POL-004-CF-001	Version 2.1 | April 2024
Data Principal Full Name	Employee ID / Applicant Reference
Date of Consent	Consent Channel (tick one): ● Online form ● HRMS ● Paper form
Processing Activity for which Consent is Given	
Specific Purpose (as described in the privacy notice presented to the Data Principal)	
Categories of Personal Data Covered by this Consent	
Privacy Notice Provided? ● Yes — version and date:	● No — reason consent is valid without notice:
Was Consent Freely Given? ● Yes — no conditioning of service on this consent	● No — explain:
Was Consent Specific? ● Yes — for this purpose only	● No — explain:
Was Consent Informed? ● Yes — notice provided before consent collected	● No — explain:
Was Consent Unambiguous? ● Yes — affirmative action taken (checkbox checked / button clicked)	● No — explain:
Consent Withdrawn? ● No ● Yes — date of withdrawal:	Action on withdrawal: ● Processing ceased ● Alternative lawful basis applies (specify):
Recorded By (DPO or HRBP)	Date Recorded
Consent stored in	● HRMS Consent Register ● CRM ● Marketing Platform ● DPO Records

Appendix F: Personal Data Breach Report Form

PERSONAL DATA BREACH REPORT FORM — LEGAL-POL-004-BRF-001	Version 2.1 | April 2024
Reported By (Name and Role)	Date and Time of Report
Date and Time Breach Was First Detected	Date and Time Breach Occurred (if known)
How Was the Breach Discovered?	● Automated alert ● Employee observation ● Third-party notification ● Customer complaint ● Other:
SECTION A — BREACH DESCRIPTION	
Type of Breach	● Unauthorised access ● Misdirected email ● Lost/stolen device ● Ransomware/attack ● Accidental deletion ● Physical document loss ● Other:
Personal Data Categories Involved	
Approximate Number of Individuals Affected	
Classification of Affected Data	● RESTRICTED ● CONFIDENTIAL ● INTERNAL USE ONLY
SECTION B — CONTAINMENT	
Immediate Containment Actions Taken	
Has the Breach Been Contained? ● Yes ● No — ongoing	Date Contained:
SECTION C — ASSESSMENT	
Severity Classification	● CRITICAL ● HIGH ● MEDIUM ● LOW
Likelihood of Significant Harm to Data Principals	● High ● Medium ● Low ● Negligible
SECTION D — NOTIFICATION	
DPBI Notification Required? ● Yes — date to notify: ● No — basis for no notification:	
Data Principal Notification Required? ● Yes ● No — basis:	
Client Notification Required (if client data affected)? ● Yes ● No	Date Notified:
SECTION E — REVIEW	
Post-Breach Review Scheduled?	● Yes — date: ● No — reason:
DPO Signature	General Counsel Signature (HIGH/CRITICAL)
Date Recorded in Breach Register	Breach Register Reference Number

Appendix G: Data Principal Rights Request Form

DATA PRINCIPAL RIGHTS REQUEST FORM — LEGAL-POL-004-RRF-001	Version 2.1 | April 2024
SECTION A — DATA PRINCIPAL DETAILS	
Full Name of Data Principal	
Contact Email Address	
Relationship to Arjun Technologies	● Current Employee ● Former Employee ● Job Applicant ● Client Contact ● Website Visitor ● Other:
Employee ID (if current or former employee)	
SECTION B — RIGHT BEING EXERCISED	
Right Requested (tick one or more)	● Right of Access (information summary) ● Right of Correction ● Right of Erasure ● Right of Grievance Redressal ● Right to Nominate
Description of the Request	
For Correction Requests — specify what is inaccurate and what the correct information is	
For Erasure Requests — specify the data category and why the purpose has been fulfilled	
For Grievance Requests — describe the complaint in full	
SECTION C — IDENTITY VERIFICATION	
Identity Verified? ● Yes — method:	● No — DPO follow-up required before processing
SECTION D — DPO USE ONLY	
Date Received by DPO	DPO Reference Number
Acknowledgement Sent to Data Principal (within 48 hours)	Date Sent:
Team(s) Assigned for Data Collection	
Response Drafted	Date Drafted:
Response Sent to Data Principal	Date Sent:
Request Fulfilled? ● Yes ● No — reason:	
Data Principal Satisfied? ● Yes ● No — escalation to DPBI offered:	
Case Closed	Date Closed:

Appendix H: Complete Policy Summary and Glossary of Defined Terms

H.1 — Complete Three-Segment Policy Summary

Segment	Sections	Key Topics	Pages	Status
Segment 1	1–7	General Counsel Message · Purpose and Scope · DPDP Act 2023 Framework · Statutory Basis · Data Fiduciary Obligations · DPO Role · Consent Framework · Lawful Bases · Data Classification · Data Principal Rights · DPDP Act Penalty Reference · Data Inventory	1–50	Published April 2024
Segment 2	8–17	Operational Handling Standards (transit, rest, use) · Context-Specific Standards (HR, client, marketing, IT) · Breach Management (7-step) · Processor Management · Employee Monitoring · Data Retention (15-row schedule) · DPIAs · Privacy by Design · Data Sharing · AI and Personal Data	51–100	Published April 2024
Segment 3 — This Document	18–21 + Appendices A–H	Cross-Border Transfers · Sector-Specific Obligations (5 verticals) · Enforcement and DPBI · Data Privacy Governance Programme · Training Curriculum · Annual Audit · Metrics · All Forms and Templates	101–150	Published April 2024

H.2 — Glossary of Defined Terms

Term	Definition	First Used
Consent Manager	A person registered with the DPBI who enables Data Principals to give, manage, review, and withdraw consent across multiple Data Fiduciaries through a single platform.	Segment 1, Section 5.4
Data Fiduciary	Any person who alone or in conjunction with others determines the purpose and means of processing of personal data.	Segment 1, Section 3.2
Data Principal	The individual to whom personal data relates. The human being whose personal data is being processed.	Segment 1, Section 3.2
Data Processor	Any person who processes personal data on behalf of a Data Fiduciary, under the instructions of the Data Fiduciary.	Segment 1, Section 3.2
Data Protection Board of India (DPBI)	The independent statutory adjudicatory body constituted under the DPDP Act 2023 with powers to investigate complaints and impose penalties.	Segment 1, Section 3.1
Data Protection Impact Assessment (DPIA)	A structured process for identifying and mitigating the privacy risks of a new or changed processing activity before it commences.	Segment 2, Section 14
Data Protection Officer (DPO)	The designated senior officer within the company with independent authority over data privacy compliance, policy, and regulatory engagement.	Segment 1, Section 4.3
Data Protection Register	The company record of all personal data processing activities (Record of Processing Activities / ROPA).	Segment 1, Section 4.5
Digital Personal Data Protection Act 2023 (DPDP Act)	Act No. 22 of 2023. The primary legislation governing the processing of digital personal data in India.	Segment 1, Section 3.1
Legal Hold	An instruction from the Legal team to suspend normal deletion schedules for personal data that is or may be relevant to legal proceedings.	Segment 2, Section 13.4
Personal Data	Any data about an individual who is identifiable by or in relation to such data.	Segment 1, Section 3.2
Privacy by Design	The principle that privacy protections should be embedded into the design and architecture of systems, products, and processes from the outset.	Segment 2, Section 15
Processing	Any operation performed on digital personal data — collection, storage, use, sharing, erasure, and all intermediate steps.	Segment 1, Section 3.2

Term	Definition	First Used
Significant Data Fiduciary	A Data Fiduciary designated by the Central Government as significant based on volume, sensitivity, and risk criteria, subject to enhanced obligations.	Segment 1, Section 4.2
Significant Harm	Categories of harm arising from a personal data breach including financial loss, reputational damage, loss of employment, bodily harm, and mental injury.	Segment 1, Section 3.2
Standard Contractual Clauses (SCCs)	Pre-approved contractual provisions that provide a lawful mechanism for cross-border personal data transfers under the EU GDPR.	Segment 3, Section 18.3
Transfer Risk Assessment (TRA)	A structured assessment of the risks associated with a cross-border personal data transfer, conducted by the DPO before the transfer commences.	Segment 3, Section 18.4

Complete Data Privacy Policy — LEGAL-POL-004-v2.1. All three segments effective 01 April 2024. Owner: Mr. Sandeep Iyer, General Counsel. DPO: dpo@arjuntech.in. Approved: Mr. Rajesh Arjun, CEO. For queries: legal@arjuntech.in. For anonymous concerns: ethics@arjuntech.in (24/7). All segments on HRMS portal under Policies and Documents.